

CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense

Course Code: ECE 402 Course Title: Project and Thesis

Submitted By—

Student ID: 2002126 Level: 4, Semester: I

Student ID: 2002138 Level: 4, Semester: I

Student ID: 2102151 Level: 4, Semester: I



Submitted To—

Department of Electronics and Communication Engineering

in partial fulfillment of the requirements for the degree of

Bachelor of Science in Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU)

Dinajpur-5200, Bangladesh

February, 2025

CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense

Course Code: ECE 402 Course Title: Project and Thesis

Submitted By—

Student ID: 2002126 Level: 4, Semester: I

Student ID: 2002138 Level: 4, Semester: I

Student ID: 2102151 Level: 4, Semester: I



Submitted To—

Department of Electronics and Communication Engineering

in partial fulfillment of the requirements for the degree of

Bachelor of Science in Electronics and Communication Engineering

Hajee Mohammad Danesh Science and Technology University (HSTU)

Dinajpur-5200, Bangladesh

February, 2025

Certificate

This is to certify that the thesis work entitled “**CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense**” is carried by the following ID numbers: **2002126, 2002138, 2102151**. To the fullest extent of our knowledge, we assert that this undertaking is an authentic and original contribution to the field. We certify that this thesis has not been previously submitted for the award of any other degree or diploma at this or any other institution.

Signed by the Final Examining committee:

.....
Chairman

.....
Supervisor

.....
External Member

.....
Co-Supervisor

.....
Internal Member

Candidate's Declaration

We hereby declare that the research work presented in this thesis entitled “**CertGraph: Heterogeneous Graph Attention Networks for Active Directory Certificate Services Vulnerability Detection and Autonomous Defense**” is the outcome of an original investigation conducted by us under the supervision of the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur-5200, Bangladesh.

We further solemnly declare that:

1. This work, or any part thereof, has not been submitted previously to any university or institution for the award of any degree, diploma, or other academic qualification.
2. All material, concepts, and algorithms taken from the published or unpublished work of others have been fully and properly acknowledged and cited in accordance with standard academic referencing protocols.
3. All synthetic datasets, forensic auditing scripts, empirical benchmark routines, and graph learning models described herein were constructed with rigorous adherence to ethical scientific standards and academic integrity.

Date: February, 2025

Place: HSTU, Dinajpur

.....
Student ID: 2002126 Level: 4, Semester: I

.....
Student ID: 2002138 Level: 4, Semester: I

.....
Student ID: 2102151 Level: 4, Semester: I
Department of ECE, HSTU

Dedication

*This thesis is dedicated to my beloved parents,
whose endless sacrifices, prayers, and unconditional love
have been the guiding light of my life.*

*And to all my teachers and mentors,
who inspired my passion for computer science and scientific discovery.*

Acknowledgements

First and foremost, all praises are due to Almighty Allah, the Most Merciful and Most Beneficent, who bestowed upon us the health, strength, patience, and intellect required to complete this project and thesis research successfully.

We express our profound gratitude, respect, and deepest indebtedness to our respected thesis supervisor and co-supervisor in the Department of Electronics and Communication Engineering, Hajee Mohammad Danesh Science and Technology University (HSTU), Dinajpur. Their exemplary guidance, insightful suggestions, constant encouragement, and critical academic reviews were invaluable throughout the formulation, mathematical derivation, experimental validation, and manuscript preparation of this research.

We are deeply thankful to the Chairman and all distinguished faculty members of the Department of Electronics and Communication Engineering, HSTU, for providing a vibrant academic environment, high-quality computational facilities, and continuous moral support during our undergraduate curriculum.

Our sincere gratitude goes to the global open-source cybersecurity and machine learning research communities. In particular, we acknowledge the pioneering work of Will Schroeder and Lee Christensen (SpecterOps) for uncovering the ADCS attack surface; the creators of BloodHound, SharpHound, and Certipy for their foundational offensive graph tools; the developers of the Game of Active Directory (GOAD) laboratory; and the core contributors of PyTorch Geometric and NetworkX.

Finally, we owe an immeasurable debt of gratitude to our parents and families for their unending sacrifices, patience, and blessings throughout our university education. We also express warm appreciation to our batchmates, lab peers, and friends whose intellectual discussions, camaraderie, and encouragement enriched every stage of this thesis journey.

HSTU, Dinajpur
February, 2025

Student ID: 2002126
Student ID: 2002138
Student ID: 2102151
Department of ECE, HSTU

Abstract

Active Directory Certificate Services (ADCS) is deployed in over 90% of modern enterprise networks to administer Public Key Infrastructure (PKI) credentials for authentication and encryption. However, subtle architectural misconfigurations across certificate templates, Access Control Lists (ACLs), and issuance policies frequently introduce catastrophic privilege escalation vectors (designated ESC1 through ESC15), enabling unprivileged actors to compromise entire Active Directory domains. Existing auditing utilities (such as Certipy, BloodHound, and PSPKIAudit) are predominantly rule-based and signature-driven: they evaluate isolated template configuration flags via static heuristics without learning from global environment topology, context-dependent reachability, or complex multi-hop delegation chains.

In this thesis, we introduce **CertGraph**, the first heterogeneous Graph Neural Network architecture designed specifically for structural vulnerability detection across Active Directory Certificate Services attack graphs. We formalize enterprise identity infrastructure as a typed, directed, heterogeneous multigraph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ and employ a Heterogeneous Graph Attention Network (Hetero-GAT) equipped with relation-specific message passing and multi-head attention mechanisms to perform inductive node-level classification over certificate templates.

Crucially, our investigation was grounded in a rigorous, end-to-end **Forensic Audit** of experimental methodology. We uncovered and eliminated critical structural illusions common to security machine learning research: synthetic positional index leakage (where administrative entities occupy predictable array offsets), baseline information asymmetry (where flat ML baselines are deprived of graph topological features), and test-set memorization under synthetic hard negatives. We mathematically prove that in directed heterogeneous identity graphs containing source-only entities (e.g., Users and Computers with zero in-degree), residual skip-connections are indispensable; without them, message-passing aggregation triggers catastrophic representation collapse ($h_v^{(l+1)} = \mathbf{0}$), causing Macro-F1 to collapse from 0.9986 to 0.4768 ($p = 1.31 \times 10^{-6}$).

On a sanitized, leakage-free benchmark of 700 enterprise environments evaluated under 5-fold cross-validation, CertGraph achieves a Macro-F1 score of 0.9986 ± 0.0029 , substantially outperforming signature-based heuristics (0.7791 ± 0.0247 , $p < 10^{-4}$) and flat ML (0.8600 ± 0.0130 , $p < 10^{-4}$). To probe model reliability, we formulated a novel **Zero-Shot Adversarial Hard Negative** benchmark where models trained exclusively on benign environments are tested against non-exploitable templates bearing vulnerable flags. Under this out-of-distribution shift, all neural models—including GNNs—succumb to shortcut learning, collapsing to 1.59% accuracy by relying on template flag semantics rather than verifying path reachability. Conversely, symbolic graph traversal (BloodHound BFS) retains 84.13% accuracy.

These findings provide the first empirical and theoretical justification for a **Neuro-Symbolic Hybrid Architecture** in enterprise identity defense: leveraging fast relational GNNs for heuristic risk prioritization ($O(1)$ amortized screening) coupled with symbolic graph algorithms for deterministic exploitability proofs. Finally, we formulate the autonomous edge-severing defense problem as a Stackelberg security game and mathematically prove its NP-hardness via reduction to the Directed Multi-way Cut problem.

Keywords: Active Directory Certificate Services (ADCS), Graph Attention Networks, Heterogeneous Graphs, Identity and Access Management, Neuro-Symbolic Security, Shortcut Learning, Autonomous Cyber Defense.

Contents

List of Acronyms	xiv
1 Introduction	1
1.1 The Enterprise Identity Fabric and the Demise of Perimeter Security	1
1.2 The Economics and Anatomy of Identity-Based Lateral Movement	2
1.3 Active Directory Certificate Services: The Unseen Attack Surface	3
1.4 Limitations of Prior Art: Why Rule-Based Tools Fall Short	5
1.5 The Promise and Pitfalls of Machine Learning for Identity Security	6
1.6 Research Questions and Formal Objectives	7
1.7 Summary of Thesis Contributions	8
1.8 Thesis Organization and Roadmap	9
2 Literature Review and Domain Background	11
2.1 Evolution of Identity-Based Lateral Movement in Enterprise Networks	11
2.1.1 Historical Precedents: Memory-Based Credential Abuse	12
2.2 Graph-Theoretic Modeling of Active Directory Security	12
2.2.1 Prior Attack Graph Literature	13
2.2.2 Limitations of Deterministic Graph Traversal	13
2.3 Graph Representation Learning in Security	14
2.3.1 The Message-Passing Neural Network (MPNN) Framework	14
2.3.2 Homogeneous vs. Heterogeneous GNNs	15
2.4 Active Directory Architecture and Cryptographic Primitives	15
2.4.1 Security Principals and Security Identifiers (SIDs)	16
2.4.2 Kerberos Authentication and Token Construction	16
2.4.3 PKINIT: Public Key Cryptography for Initial Authentication	17
2.4.4 Access Control Lists (ACLs) and Security Descriptors	17
2.5 Active Directory Certificate Services (ADCS) Mechanics	18
2.6 Exhaustive Taxonomy of ADCS Vulnerability Classes (ESC1–ESC15)	19
2.7 Formal Threat Model	19
2.7.1 Attacker Model	20
2.7.2 Defender Model	20

3	Formal Methodology and CertGraph Architecture	22
3.1	Mathematical Formalization of Enterprise Identity Multigraphs	22
3.2	Node Feature Vector Spaces and Semantic Encodings	23
3.2.1	Certificate Template Feature Representation	23
3.2.2	Security Principal Feature Representations	25
3.2.3	Relational Adjacency and Canonical Reverse Relations	26
3.3	The CertGraph Hetero-GAT Architecture	26
3.3.1	Relation-Specific Linear Feature Projections	27
3.3.2	Multi-Head Relational Graph Attention	27
3.3.3	Semantic-Level Aggregation and Residual Skip-Connections	28
3.3.4	Multi-Class Vulnerability Classification Head	29
3.3.5	Objective Function with Class Imbalance Regularization	29
3.4	Formal Algorithmic Specifications	30
3.4.1	End-to-End Layer Forward Pass	30
3.4.2	Vulnerability Inference and Calibrated Risk Scoring	31
3.5	Theoretical Analysis: Representation Collapse in Directed Graphs	31
3.6	Computational Complexity and Scalability Analysis	32
4	Forensic Audit: Unmasking Experimental Illusions in Security Machine Learning	34
4.1	The Methodological Crisis of Security Machine Learning	34
4.2	The Four Experimental Illusions	35
4.2.1	Illusion 1: Positional Index Leakage in Synthetic Topologies	35
4.2.2	Illusion 2: Baseline Information Asymmetry	36
4.2.3	Illusion 3: The 7-Node Decision Tree Counterexample	37
4.2.4	Illusion 4: Hard Negative Memorization under In-Distribution Splits	39
4.3	Complete Generator Sanitization and Protocol Redesign	39
4.4	Statistical Verification of Generator Sanitization	40
4.5	Methodological Guidelines for Security Graph Learning	40
5	Empirical Evaluation and Benchmarks	42
5.1	Experimental Configuration and Benchmarking Setup	42
5.1.1	Benchmark Dataset Characteristics	42
5.1.2	Hyperparameter Specifications	43
5.2	In-Distribution 5-Fold Cross-Validation	43
5.2.1	Per-Class Performance Dissection	44
5.3	Systematic Architectural Ablation Studies	45
5.4	The Zero-Shot Adversarial Hard Negative Benchmark	46
5.4.1	Theoretical Post-Mortem of Neural Shortcut Collapse	47
5.5	Attention Weight Explainability and Graph Attribution	48
6	Real-World Active Directory Case Studies: GOAD and Community Benchmarks	50
6.1	From Synthetic Topologies to Enterprise Deployments	50
6.2	The Game of Active Directory (GOAD) Multi-Forest Testbed	51

6.3	Data Ingestion, Extraction, and Schema Translation	52
6.3.1	Active Directory Telemetry Collection	52
6.3.2	Graph Schema Translation Pipeline	53
6.4	Concrete Penetration Testing Case Studies	53
6.4.1	Detailed Case Study Analysis	53
6.5	Temporal Validation Across Independent Collection Dates	55
6.6	External Community Benchmark Validation	56
7	Domain Generalization, Robustness, and Scalability	58
7.1	Enterprise Operational Demands on Security Graph Learning	58
7.2	Domain Generalization: Transfer Learning on ADSynth Tiered Networks	59
7.2.1	The Enterprise Administrative Tiering Model	59
7.2.2	Bidirectional Domain Transfer Evaluation	59
7.3	Systematic Sensitivity and Robustness Analysis	61
7.3.1	Topological Edge Deletions (Collection Gaps)	61
7.3.2	Configuration Feature Noise Perturbation	62
7.3.3	Sample Efficiency and Learning Convergence	62
7.4	Computational Complexity and Scalability Benchmarking	63
7.4.1	Scalability Insights and Profiling	63
7.4.2	Large-Scale Multi-Forest Partitioning Strategies	64
8	The Neuro-Symbolic Paradigm: Bridging Statistical GNNs and Symbolic Oracles	65
8.1	The Core Dilemma: Shortcut Learning in Security GNNs	65
8.1.1	Theoretical Root Cause: The Path-Feature Trade-off	66
8.2	The Fundamental Dichotomy: Statistical vs. Symbolic AI	66
8.3	First-Order Logic Formalization of Active Directory Privilege Escalation	67
8.4	The Two-Tier Neuro-Symbolic Architecture	68
8.4.1	Tier 1: Fast Inductive Neural Screening	69
8.4.2	Tier 2: Targeted Deductive Graph Verification	69
8.5	Complexity and Performance Guarantees	70
8.6	Algorithmic Specification of the Hybrid Pipeline	71
8.7	Enterprise Security Operations Center (SOC) Orchestration	71
9	Game-Theoretic Autonomous Defense and NP-Hardness of Edge-Severing	73
9.1	From Passive Auditing to Active Autonomous Defense	73
9.2	The Stackelberg Security Game Formulation	74
9.2.1	Players and Asymmetric Action Spaces	74
9.2.2	Multi-Objective Utility Functions and Regularization	75
9.3	Theoretical Complexity: The NP-Hardness of Edge-Severing	75
9.4	Polynomial-Time Heuristic Approximation Algorithms	76
9.4.1	Approximation Ratio and Centrality Dynamics	76
9.5	Convergence Dynamics via Stochastic Approximation	77
9.5.1	Robbins-Monro Step-Size Conditions	77

9.5.2	Continuous Limit Dynamical System and Lyapunov Stability	78
9.6	Simulation Experiments and Remediation Trade-offs	78
10	Conclusion, Limitations, and Future Horizons	80
10.1	Summary of Thesis Contributions	80
10.1.1	Theoretical Contributions	80
10.1.2	Methodological Contributions	81
10.1.3	Empirical Contributions	81
10.1.4	Architectural Contributions	82
10.2	Synthesis: Answers to Research Questions	82
10.3	Practical Implementation Playbook for Enterprise Defenders	84
10.4	Honest Limitations to Acknowledge	85
10.5	Ethical Considerations and Dual-Use Analysis	85
10.6	Future Research Horizons	86
10.7	Concluding Remarks	86
A	Formal Mathematical Proofs	88
A.1	Proof of Theorem 1: Representation Collapse of Source-Only Entities in Directed Heterogeneous Message Passing	88
A.2	Proof of Theorem 2: NP-Hardness of Minimal-Capacity Active Directory Edge-Severing	92

List of Tables

2.1	Comprehensive Comparative Taxonomy of ADCS Privilege Escalation Vectors (ESC1–ESC15).	21
4.1	Exact Decision Logic of the 7-Node Decision Tree Counterexample.	38
4.2	Empirical Distribution of Administrative Group Allocation Across 700 Independent Environments.	40
5.1	Hyperparameter Specifications for Model Training and Optimization.	43
5.2	5-Fold Cross-Validation Performance Across 7 Evaluated Models on 700 Enterprise Domains.	44
5.3	CertGraph Per-Class Precision, Recall, and F1 Scores under 5-Fold Cross-Validation.	45
5.4	Systematic Architectural Ablation Study of CertGraph Components.	45
5.5	Zero-Shot Adversarial Hard Negative Benchmark Results (Evaluated on 63 Test Hard Negatives).	47
6.1	Comparative Auditing Performance on Live Ingested GOAD Topologies.	54
6.2	Classification Accuracy on External Community-Collected Enterprise Topologies.	56
7.1	Bidirectional Domain Generalization Matrix Between Synthetic and ADSynth Topologies.	60
7.2	Model Performance Degradation under Systematic Topological Edge Deletions.	61
7.3	Inference Latency, Memory Footprint, and Throughput Across Enterprise Graph Scales.	63
8.1	Comparison of Pure Statistical GNNs vs Pure Symbolic Graph Traversal in Identity Auditing.	67

List of Figures

2.1	Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, illustrating relations between security principals (Users, Computers, Groups), Certificate Templates, and Enterprise Certificate Authorities.	18
2.2	Two-hop ESC13 privilege escalation attack path, showing the chain from an unprivileged user through enrollment permissions and issuance policy OID linkage to high-value domain administrative group tokens.	19
3.1	CertGraph end-to-end Hetero-GAT pipeline, detailing input feature encoding, multi-head relational attention layers, additive residual skip-connections, and the multi-class template classification head.	27
4.1	Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.	38
5.1	Empirical classification results: (a) Confusion matrix showing near-perfect diagonal alignment across 7 ESC classes; (b) Comparison of GNN architectures confirming the empirical superiority of heterogeneous modeling.	44
5.2	Ablation study comparison highlighting the catastrophic performance collapse when residual skip connections are disabled.	46
5.3	Zero-shot adversarial evaluation demonstrating the catastrophic collapse of neural models due to shortcut learning compared to symbolic BFS path traversal.	47
5.4	Localized 2-hop attention weight attribution for an ESC13 template, showing concentrated attention along the valid enrollment and issuance policy path.	48
6.1	Architecture and trust relationship schema of the Game of Active Directory (GOAD) multi-forest lab environment, detailing domain controllers, member servers (including the ADCS Certificate Authority SRV03 – braavos), and cross-forest authentication links.	52
6.2	End-to-end multi-hop compromise and privilege escalation attack graph across the GOAD domain infrastructure, illustrating how unprivileged foothold credentials traverse ADCS certificate misconfigurations (ESC1–ESC8), Kerberos delegations, and inter-domain trusts to achieve enterprise domain dominance.	55
7.1	Comparative performance (CertGraph vs BloodHound vs Certipy) across synthetic and ADSynth realistic tiered enterprise topologies.	60

7.2	GNN robustness evaluation under systematic edge deletions (collection gaps), configuration feature noise (attribute corruption), and training data efficiency scaling. .	61
7.3	Scalability benchmarks showing inference latency scaling linearly with graph volume while Resident Set Size (RSS) process memory remains flat and bounded. . .	63
8.1	The Two-Tier Neuro-Symbolic Architecture, pairing fast CertGraph GNN screening for risk prioritization with deterministic BloodHound BFS path verification.	68
9.1	Defensive convergence and attack surface reduction under varying operational budget constraints.	78

List of Acronyms

ACL	Access Control List
AD	Active Directory
ADCS	Active Directory Certificate Services
AWDP	Automated Windows Domain Penetration
BFS	Breadth-First Search
CA	Certificate Authority
CSR	Certificate Signing Request
CV	Cross-Validation
DACL	Discretionary Access Control List
DC	Domain Controller
DDQN	Dueling Double Deep Q-Network
EKU	Extended Key Usage
ESC	Escalation Vector (ADCS Misconfiguration Primitive)
GAT	Graph Attention Network
GCN	Graph Convolutional Network
GNN	Graph Neural Network
GOAD	Game of Active Directory
H-MARL	Hierarchical Multi-Agent Reinforcement Learning
Hetero-GAT	Heterogeneous Graph Attention Network
IAM	Identity and Access Management
KDC	Key Distribution Center
LDAP	Lightweight Directory Access Protocol
ML	Machine Learning
MLP	Multi-Layer Perceptron
NP	Nondeterministic Polynomial Time
ODE	Ordinary Differential Equation
OID	Object Identifier
PAC	Privilege Attribute Certificate
PKI	Public Key Infrastructure
RF	Random Forest
SAN	Subject Alternative Name
SID	Security Identifier
SOC	Security Operations Center
TGS	Ticket Granting Service
TGT	Ticket Granting Ticket
XAI	Explainable Artificial Intelligence

Chapter 1

Introduction

1.1 The Enterprise Identity Fabric and the Demise of Perimeter Security

For nearly three decades, enterprise information security architectures were predicated on the assumption of a defensible physical and logical perimeter. Organizations invested heavily in hardening network boundaries using stateful firewalls, intrusion detection and prevention systems (IDS/IPS), virtual private networks (VPNs), and demilitarized zones (DMZs). In this traditional fortress-and-moat doctrine, network traffic originating within the internal intranet was implicitly categorized as trusted, whereas external packets were subjected to rigorous perimeter inspection.

The widespread adoption of cloud-native computing, remote and hybrid work models, bring-your-own-device (BYOD) policies, and software-as-a-service (SaaS) platforms has effectively obliterated this logical boundary. Advanced Persistent Threat (APT) actors, nation-state adversaries, and professionalized ransomware cartels routinely bypass perimeter defenses through spear-phishing campaigns, supply-chain compromises, edge device vulnerabilities, or credential theft. Once an initial foothold is established on a single compromised workstation within an internal corporate network, the perimeter provides zero defensive efficacy.

Consequently, the global cybersecurity landscape has witnessed an irreversible paradigm shift toward **Identity-Centric Security** and the formalization of **Zero Trust Architecture (ZTA)**. In modern distributed environments, the true, operational perimeter of an enterprise is its **Identity and Access Management (IAM) fabric**. Within this fabric, the fundamental security boundary is no longer an IP address, a subnet, or a VLAN; rather, it is the cryptographic identity, the security principal, and the granular authorization token that governs access to computing assets, sensitive

databases, and mission-critical workloads.

At the epicenter of this identity fabric stands **Microsoft Active Directory (AD)**, alongside its public-key extension, **Active Directory Certificate Services (ADCS)**. Deployed across more than 90% of the Fortune 1000 organizations and utilized by hundreds of thousands of government, defense, and commercial institutions globally, Active Directory serves as the authoritative, Tier-0 identity repository. It governs user authentication, access control delegation, domain federation, and administrative authorization across millions of enterprise assets. Because Active Directory controls access to virtually every server, workstation, and database in an organization, compromising its security boundaries results in catastrophic, unrecoverable domain compromise.

1.2 The Economics and Anatomy of Identity-Based Lateral Movement

Modern cyber adversaries operate under strict economic optimization models: they seek to maximize the probability of enterprise compromise while minimizing operational expenditures, discovery risk, and technical complexity. Exploiting memory-corruption zero-day vulnerabilities (e.g., remote kernel code execution) on hardened Domain Controllers is economically expensive, highly fragile, and prone to triggering endpoint detection and response (EDR) telemetry.

In sharp contrast, **Identity-Based Lateral Movement** exploits the inherent complexity, architectural debt, and combinatorial misconfigurations embedded directly within the directory's access control topology. Active Directory is not a simple flat table of usernames and passwords; it is an immensely dense, dynamic, heterogeneous multigraph. The directory contains tens or hundreds of thousands of distinct heterogeneous entities—including human user accounts, computer machine accounts, security groups, organizational units (OUs), domain trusts, and cryptographic certificate templates. These entities are interlinked by millions of directed authorization edges, such as:

1. Group membership relationships (MemberOf).
2. Discretionary Access Control List (DACL) permissions (e.g., GenericAll, GenericWrite, WriteDacl, WriteOwner).
3. Kerberos delegation privileges (unconstrained, constrained with protocol transition, and resource-based constrained delegation).
4. Domain trust transversals (inbound, outbound, bidirectional forest trusts).
5. Certificate enrollment and administrative publication links.

When an adversary obtains low-privileged execution capabilities on a commodity workstation (e.g., through compromised domain user credentials), they do not need to exploit software bugs to achieve domain dominance. Instead, they execute **Attack Path Traversal**: chaining together a sequence of individually benign, authorized directory operations that transitively escalate their privileges. For example, an unprivileged user may possess the right to modify the group membership of an obscure IT helpdesk security group, which in turn holds administrative privileges over a file server, whose local administrator account possesses a service principal name (SPN) susceptible to Kerberoasting, ultimately yielding domain administrator credentials.

Because each individual hop along this path consists of legitimate protocol actions authorized by the directory's own Access Control Entries (ACEs), traditional endpoint sensors and network monitors perceive the activity as routine administrative behavior. This structural asymmetry renders identity attack graphs one of the most stealthy and potent attack vectors in enterprise cybersecurity.

1.3 Active Directory Certificate Services: The Unseen Attack Surface

In June 2021, security researchers Will Schroeder and Lee Christensen of SpecterOps published their landmark whitepaper, *Certified Pre-Owned: Abusing Active Directory Certificate Services* [1]. This publication exposed a systemic, multi-decade architectural vulnerability within Microsoft's native Public Key Infrastructure (PKI) implementation: **Active Directory Certificate Services (ADCS)**.

ADCS is a server role integrated into Windows Server that enables enterprises to build an internal Public Key Infrastructure. It issues X.509 digital certificates to authenticate users, encrypt transport-layer communications, digitally sign code and macros, and provide smart-card interactive logon capabilities. The core operational protocol enabling ADCS integration is **Public Key Cryptography for Initial Authentication (PKINIT)**, standardized in RFC 4556 as an extension to the Kerberos protocol. Under PKINIT, a client can initiate the Kerberos Authentication Service (AS) exchange by presenting an X.509 certificate signed by a trusted Enterprise Certificate Authority (CA) rather than supplying a secret symmetric key or password hash.

The fundamental vulnerability uncovered by Schroeder and Christensen lies in the convergence of three distinct design complexities:

1. **Decentralized Certificate Templates:** The parameters governing certificate issuance—such as Extended Key Usages (EKUs), cryptographic validity periods, required issuance approvals, and subject naming rules—are stored as LDAP objects (`class: pKICertificateTemplate`)

directly within the Active Directory Configuration partition.

2. **Subject Alternative Name (SAN) Manipulation:** If a certificate template enables the flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` (0x00000001), the certificate requestor is permitted to specify an arbitrary identity in the Subject Alternative Name (SAN) extension of their Certificate Signing Request (CSR).
3. **Cryptographic Authentication Mapping:** When a template with client authentication capabilities issues a certificate containing an arbitrary SAN (e.g., `administrator@domain.local`), the Kerberos Key Distribution Center (KDC) accepts this certificate during PKINIT, validates the CA's digital signature, maps the SAN to the target administrative account, and issues a fully privileged Kerberos Ticket Granting Ticket (TGT) carrying the administrator's Privilege Attribute Certificate (PAC).

SpecterOps formalized these structural misconfiguration patterns into an expanding taxonomy of **Escalation Vectors (ESC1 through ESC8)**. In the ensuing years, independent researchers discovered additional novel vectors, including:

1. **ESC9 and ESC10 (2022):** Exploiting weak certificate mappings and certificate extension stripping in environments lacking the KB5014754 patch.
2. **ESC11 and ESC12 (2023):** Abusing unauthenticated RPC enrollment interfaces and CA relay primitives.
3. **ESC13 (2023):** Disclosed by Jonas Feynman, exploiting Issuance Policy Object Identifiers (OIDs) mapped directly to high-value security groups.
4. **ESC14 and ESC15 (2024):** Exploiting `altSecurityIdentities` mapping weaknesses and legacy Schema Version 1 template CSR application policy injections (CVE-2024-49019, "EKUwu") [2].

Unlike memory-based credential dumping tools (e.g., Mimikatz accessing LSASS memory) that trigger modern EDR heuristics, ADCS exploitation generates **valid, cryptographically signed credentials issued by the organization's own Root CA**. To the domain controller, the certificate is authentic, legitimate, and cryptographically untampered. Consequently, ADCS attacks represent one of the stealthiest and most devastating privilege escalation mechanisms available to modern threat actors, having been weaponized in major real-world intrusions by state-sponsored actors (such as APT29/Cozy Bear) and sophisticated ransomware operators (including BlackCat/ALPHV and LockBit).

1.4 Limitations of Prior Art: Why Rule-Based Tools Fall Short

Following the public disclosure of ADCS vulnerabilities, the defensive and offensive security communities rapidly produced automated assessment tools, most notably **Certipy** [3], **BloodHound** [4], and **PSPKIAudit**. While these utilities are invaluable for offensive red-teaming and baseline compliance auditing, they exhibit fundamental scientific and architectural limitations that prevent them from serving as autonomous enterprise-scale defense systems:

1. **Isolated Attribute Inspection and Topological Blindness:** Signature-based auditing tools evaluate certificate templates predominantly in isolation. A scanner inspects whether template configuration flags match a known vulnerable pattern (e.g., whether `ENROLLEE_SUPPLIES_SUBJECT` is active alongside a Client Authentication ECU). However, in production enterprise environments, the actual exploitability of a template depends on whether an unprivileged adversary possesses an end-to-end authorization path to enroll in the template, modify its security descriptor, or link an issuance policy. Scanners that inspect templates in isolation produce massive volumes of false positives on templates that possess dangerous configuration flags but are strictly locked down to administrative enrollment groups.
2. **Combinatorial State Explosion in Graph Traversal:** Graph analysis tools such as BloodHound model identity relationships in graph databases (e.g., Neo4j) and execute deterministic Cypher queries or Breadth-First Search (BFS) path-finding algorithms. In dense enterprise environments containing hundreds of thousands of nodes and millions of DACL edges, calculating all possible paths to administrative targets suffers from exponential combinatorial explosion, resulting in severe performance degradation and query timeouts.
3. **Absence of Contextual Risk Scoring and Blast Radius Metrics:** Traditional tools produce binary, unranked lists of vulnerable templates. They do not quantify the contextual blast radius, the number of distinct low-privileged accounts capable of reaching the asset, or the relative operational criticality of the template. Enterprise Security Operations Centers (SOCs), faced with hundreds of flagged templates across multi-forest environments, have no mathematical mechanism to prioritize remediation efforts based on environmental risk.
4. **Brittleness to Novel Misconfiguration Combinations:** Hand-crafted signature heuristics cannot generalize to novel, un-modeled misconfiguration combinations. For example, before explicit heuristic rules were drafted for ESC13 in late 2023, traditional scanners categorized

ESC13-vulnerable templates as completely benign because the attack path transitioned through an obscure issuance policy OID rather than standard DACL enrollment rights.

1.5 The Promise and Pitfalls of Machine Learning for Identity Security

To overcome the limitations of handcrafted heuristics and combinatorial graph traversal, recent research has explored the application of **Machine Learning (ML)** to cybersecurity. In particular, **Graph Neural Networks (GNNs)** have emerged as a natural paradigm for relational data, demonstrating remarkable success in molecule design, social network analysis, and fraud detection.

GNNs operate via the **Message-Passing Neural Network (MPNN)** framework [?]: each node iteratively aggregates transformed feature vectors from its local topological neighborhood, updating its internal hidden representation across successive convolutional layers. By interleaving topological aggregation with non-linear feature projections, GNNs learn rich node embeddings that capture both local entity attributes and higher-order structural context in polynomial time ($O(|V| + |E|)$ parallel tensor operations).

Applying GNNs to the Active Directory Certificate Services attack surface presents an unprecedented scientific opportunity:

1. **Joint Modeling of Configuration and Topology:** A heterogeneous GNN can simultaneously ingest local certificate template flags and directory authorization topology, learning to classify subtle vulnerability patterns while filtering out non-exploitable configurations.
2. **Sub-Second Enterprise Scalability:** Unlike recursive graph traversal algorithms that explore exponential path combinations, forward-pass tensor inference in GNNs executes in milliseconds, scaling gracefully to enterprise networks containing tens of thousands of objects.
3. **Continuous Probabilistic Risk Ranking:** GNNs output continuous calibrated probability distributions over vulnerability classes, providing defenders with an automated metric to prioritize patching based on contextual exploitability.

However, applying deep graph learning to enterprise identity graphs introduces severe theoretical and practical challenges:

1. **Asymmetric, Directed Identity Topologies:** Active Directory authorization graphs are directed, non-Euclidean, and highly asymmetric. Security principals (Users, Computers) fre-

quently act as pure sources (in-degree zero) in administrative authorization subgraphs. Standard undirected graph convolutions fail to capture the strict asymmetry of privilege flow.

2. **The Threat of Shortcut Learning:** Deep neural networks naturally converge toward the simplest statistical heuristics that minimize empirical training loss [5]. In security applications, this tendency leads models to rely on local feature flags (e.g., checking if `ENROLLEE_SUPPLIES_SUBJECT` is set) rather than verifying multi-hop topological reachability. When confronted with adversarial out-of-distribution environments, pure neural models risk catastrophic generalization collapse.
3. **Experimental Artifacts and Methodological Illusions:** In synthetic security research, experimental generators frequently leak unintended positional or distribution artifacts, creating an illusion of near-perfect classification performance that disintegrates upon rigorous scrutiny.

1.6 Research Questions and Formal Objectives

This thesis systematically addresses these fundamental challenges by investigating four central research questions:

1. **RQ1 (Relational Necessity):** Can a heterogeneous Graph Attention Network (Hetero-GAT) effectively learn to classify complex ADACS vulnerability classes (ESC1–ESC13) by jointly modeling template configurations and directory authorization topology, and does it demonstrably outperform flat feature-only classifiers and industry signature heuristics?
2. **RQ2 (Architectural Dynamics and Representation Collapse):** How do the directed, asymmetric topological properties of Active Directory authorization graphs impact standard message passing, and what architectural inductive biases (specifically, residual skip-connections) are mathematically and empirically necessary to prevent representation collapse across source-only entities?
3. **RQ3 (Adversarial Robustness and Shortcut Learning):** When subjected to rigorous out-of-distribution adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths), do neural security models genuinely evaluate graph reachability, or do they succumb to feature-level shortcut learning?

4. **RQ4 (Optimal Defense Paradigm):** Given the trade-offs between inductive statistical pattern recognition and deterministic symbolic graph algorithms, what is the optimal architectural paradigm for enterprise-grade autonomous identity defense, and what is the computational complexity of autonomous attack path mitigation?

1.7 Summary of Thesis Contributions

The primary scientific, theoretical, and empirical contributions of this thesis are as follows:

1. **CertGraph Heterogeneous Architecture:** We propose CertGraph, the first heterogeneous Graph Attention Network (Hetero-GAT) specifically tailored to Active Directory Certificate Services vulnerability detection. CertGraph models the directory as a typed heterogeneous multigraph, utilizing relation-specific linear projections, multi-head attention mechanisms, and residual connections to classify multi-class ESC vulnerabilities directly from Active Directory graphs.
2. **Mathematical Proof of Representation Collapse (Theorem 1):** We mathematically prove that in directed heterogeneous graphs containing source-only entities (Users and Computers with zero in-degree), relational message passing without residual skip connections destroys input feature representations ($h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$), causing model gradients with respect to input features to vanish identically ($\frac{\partial \mathcal{L}}{\partial x_v} = \mathbf{0}$). We confirm this theorem through exhaustive ablations showing Macro-F1 collapses from 0.9986 to 0.4768 ($p = 1.31 \times 10^{-6}$) when skips are omitted.
3. **Forensic Audit of Security ML Practices:** We conduct an exhaustive forensic audit of experimental security machine learning methodologies, identifying and resolving four major structural illusions: positional index leakage in synthetic generators, baseline information asymmetry, low-dimensional Decision Tree equivalence (achieving 0.9928 F1 with 7 nodes), and test-set memorization under synthetic hard negatives. We release a fully sanitized, leakage-free benchmark generator.
4. **The Adversarial Zero-Shot Hard Negative Benchmark:** We construct an adversarial zero-shot evaluation protocol demonstrating that deep neural models—including state-of-the-art GNNs—succumb to catastrophic shortcut learning collapse (achieving only 1.59% accuracy),

while deterministic symbolic graph algorithms (BloodHound BFS) achieve 84.13%. This provides the first rigorous empirical proof of shortcut learning on enterprise identity graphs.

5. **The Two-Tier Neuro-Symbolic Defense Architecture:** To reconcile the statistical vs. symbolic dilemma, we formulate a two-tier hybrid defense architecture pairing fast GNN risk scoring ($O(1)$ amortized screening) with targeted symbolic path verification, achieving zero false positives and executing orders of magnitude faster than exhaustive graph traversal.
6. **NP-Hardness Proof of Optimal Defense (Theorem 2):** We formulate autonomous identity attack graph mitigation as a Bayesian Stackelberg security game and mathematically prove that finding the minimal-capacity set of access control edges that severs all attacker paths to administrative assets is NP-hard via polynomial-time reduction from Directed Multi-way Cut.

1.8 Thesis Organization and Roadmap

The remainder of this thesis monograph is organized as follows:

1. **Chapter 2 (Literature Review and Domain Background):** Provides comprehensive background on Active Directory internals, Kerberos authentication, PKINIT, and Access Control Lists, followed by a formal taxonomy of the ESC1 through ESC15 vulnerability classes and a review of graph representation learning literature.
2. **Chapter 3 (Formal Methodology and CertGraph Architecture):** Establishes the mathematical formulation of Active Directory as a heterogeneous multigraph, details the CertGraph Hetero-GAT architecture, derives the training objectives, and presents the formal theoretical statement of Theorem 1.
3. **Chapter 4 (Forensic Audit: Unmasking Experimental Illusions):** Dissects the four experimental illusions uncovered during our research pipeline audit, provides code listings and mathematical analysis of positional leakage, and details the complete sanitization of the benchmark dataset.
4. **Chapter 5 (Empirical Benchmarks and Performance Evaluation):** Reports exhaustive 5-fold cross-validation results, per-class metrics, confusion matrices, ablation studies, the zero-shot adversarial hard negative benchmark, and attention-based explainability analysis.

5. **Chapter 6 (Real-World Case Studies on Active Directory Forests):** Validates CertGraph on the multi-domain Game of Active Directory (GOAD) enterprise testbed, evaluating ESC13 discovery, hard negative false positive suppression, multi-week temporal stability, and external community benchmark datasets.
6. **Chapter 7 (Robustness, Generalization, and Scalability):** Evaluates cross-distribution transfer learning between synthetic topologies and tiered ADSynth environments, topological edge deletion perturbations, configuration feature noise, training data efficiency curves, and computational scalability benchmarks up to 10,000 nodes.
7. **Chapter 8 (The Neuro-Symbolic Paradigm for Enterprise Defense):** Deconstructs the theoretical root cause of neural shortcut learning collapse, contrasts statistical and symbolic AI paradigms, specifies the two-tier hybrid architecture, and details its algorithmic orchestration.
8. **Chapter 9 (Game-Theoretic Defense and Computational Complexity):** Formulates autonomous identity defense as a Stackelberg security game, presents the formal proof of Theorem 2 (NP-hardness of minimal-disruption edge-severing), and analyzes dynamical convergence via the ODE method of stochastic approximation.
9. **Chapter 10 (Conclusion, Limitations, and Future Horizons):** Synthesizes the core research findings, directly answers the four research questions, discusses honest operational limitations and dual-use ethical considerations, and outlines promising future research horizons.
10. **Appendix A and B:** Present the complete, formal mathematical proofs of Theorem 1 (Representation Collapse in Directed Heterogeneous Message Passing) and Theorem 2 (NP-Hardness of Minimal-Capacity Active Directory Edge-Severing).

Chapter 2

Literature Review and Domain Background

2.1 Evolution of Identity-Based Lateral Movement in Enterprise Networks

For nearly three decades, enterprise information security architectures were predicated on the assumption of a defensible physical and logical perimeter. Organizations invested heavily in hardening network boundaries using stateful firewalls, intrusion detection and prevention systems (IDS/IPS), virtual private networks (VPNs), and demilitarized zones (DMZs). In this traditional fortress-and-moat doctrine, network traffic originating within the internal intranet was implicitly categorized as trusted, whereas external packets were subjected to rigorous perimeter inspection.

The widespread adoption of cloud-native computing, remote and hybrid work models, bring-your-own-device (BYOD) policies, and software-as-a-service (SaaS) platforms has effectively obliterated this logical boundary. Advanced Persistent Threat (APT) actors, nation-state adversaries, and professionalized ransomware cartels routinely bypass perimeter defenses through spear-phishing campaigns, supply-chain compromises, edge device vulnerabilities, or credential theft. Once an initial foothold is established on a single compromised workstation within an internal corporate network, the perimeter provides zero defensive efficacy.

Once an adversary achieves code execution on any machine in an internal corporate network, enterprise defense shifts entirely to combating **Lateral Movement**—the techniques adversaries use to extend access across systems, servers, and security principals to locate and compromise high-value

assets.

2.1.1 Historical Precedents: Memory-Based Credential Abuse

Historically, identity lateral movement within Windows enterprise environments relied on memory-based credential dumping and protocol replay attacks:

1. **Pass-the-Hash (PtH):** Exploiting legacy NTLM authentication by extracting the NTLM password hash of a user from the Local Security Authority Subsystem Service (LSASS) process memory (using utilities such as Mimikatz) and presenting that hash in network challenge-response exchanges without knowing the plaintext password.
2. **Pass-the-Ticket (PtT):** Harvesting active Kerberos Ticket Granting Tickets (TGTs) or Service Tickets directly from LSASS memory to impersonate logged-on users across the enterprise.
3. **Overpass-the-Hash / Pass-the-Key:** Supplying an extracted NTLM hash or Kerberos AES-256 encryption key to request a valid Kerberos TGT directly from the Key Distribution Center (KDC) via the Kerberos Authentication Service (AS) exchange.
4. **Golden and Silver Tickets:** Forging cryptographically authentic Kerberos TGTs using the secret symmetric key of the domain's KRBTGT service account (Golden Ticket), or forging targeted service tickets using a specific server's machine account password hash (Silver Ticket), embedding arbitrary administrative group SIDs directly into the authorization token.

With the widespread deployment of Microsoft Credential Guard, Remote Credential Guard, Virtualization-Based Security (VBS), and Protected Process Light (PPL) in modern Windows operating systems, raw LSASS memory dumping has become substantially more difficult, triggering aggressive Endpoint Detection and Response (EDR) behavioral telemetry. Consequently, sophisticated adversaries have shifted their primary attack vector from host memory exploitation to **architectural access-control abuse** and **Active Directory Certificate Services (ADCS)**.

2.2 Graph-Theoretic Modeling of Active Directory Security

Active Directory Domain Services (AD DS) is fundamentally a massive, distributed, multi-relational graph database. In 2016, the release of **BloodHound** by Robbins, Schroeder, and Morreale [4] transformed enterprise offensive and defensive security by formalizing Active Directory permissions as a directed identity attack graph.

2.2.1 Prior Attack Graph Literature

The concept of modeling security vulnerabilities as attack graphs dates back to foundational work by Phillips and Swiler (1998) and Sheyner et al. (2002) [?], who represented computer network state transitions as directed graphs to analyze multi-step vulnerability chaining. However, early attack graph models suffered from severe combinatorial state explosion when applied to realistic enterprise networks, as they attempted to model low-level host vulnerabilities, network service versions, and system exploit states simultaneously.

BloodHound resolved this scalability dilemma by decoupling host-level software vulnerabilities from **identity authorization topology**. In BloodHound's formulation, vertices represent directory security principals (Users, Computers, Groups, Organizational Units, Domains), while edges represent discrete administrative access rights granted via Discretionary Access Control Lists (DACLS) or network session dependencies:

1. **MemberOf**: Direct or transitive security group containment.
2. **AdminTo**: Administrative execution privileges on a remote workstation or server.
3. **HasSession**: An interactive or network session active on a host, indicating that user credentials reside in local memory.
4. **GenericAll, GenericWrite, WriteDacl, WriteOwner**: Granular object-level permissions within the directory schema.

2.2.2 Limitations of Deterministic Graph Traversal

While BloodHound and related graph databases (Neo4j) allow security analysts to execute Cypher queries (such as shortest path queries from `Domain Users` to `Domain Admins`), deterministic graph traversal exhibits acute limitations in modern enterprise environments:

1. **Computational Intractability on Dense Enterprise Graphs**: Large multi-forest enterprises routinely contain over 100,000 security principals and tens of millions of access control entries. Exhaustive multi-hop traversal suffers from exponential branching factors, causing path-finding queries to time out or exhaust server memory.
2. **Absence of Contextual Probabilistic Risk Scoring**: Deterministic graph traversal treats every valid edge as equally likely to be traversed. It cannot incorporate operational context, such

as whether a workstation is actively monitored by an EDR agent, whether a service account has been dormant, or whether an attack step requires complex operational prerequisites.

3. **Brittleness to Un-modeled Attack Vectors:** BloodHound relies on handcrafted edge collectors (SharpHound). If an organization deploys a novel authentication protocol or certificate configuration that has not been explicitly codified into the BloodHound Cypher schema, the attack path is completely invisible.

2.3 Graph Representation Learning in Security

To overcome the brittleness and combinatorial limitations of deterministic graph search, researchers have increasingly investigated **Graph Representation Learning** and **Graph Neural Networks (GNNs)** for cybersecurity applications.

2.3.1 The Message-Passing Neural Network (MPNN) Framework

Gilmer et al. [?] unified modern graph deep learning architectures under the Message-Passing Neural Network (MPNN) framework. For a graph $G = (V, E)$ with node feature vectors $x_v \in \mathbb{R}^d$, an MPNN layer computes updated node representations $h_v^{(l)}$ through three core computational phases:

1. **Message Computation:** For each directed edge $(u, v) \in E$, a message vector is computed:

$$m_{vu}^{(l)} = M_l \left(h_v^{(l-1)}, h_u^{(l-1)}, e_{vu} \right) \quad (2.1)$$

where M_l is a parameterized message function, and e_{vu} represents edge features.

2. **Message Aggregation:** Messages from all incoming neighbors in $\mathcal{N}(v)$ are aggregated using a permutation-invariant aggregation operator $\bigoplus$:

$$\bar{m}_v^{(l)} = \bigoplus_{u \in \mathcal{N}(v)} m_{vu}^{(l)} \quad (2.2)$$

3. **State Update:** The node's hidden representation is updated by combining its previous state with the aggregated message:

$$h_v^{(l)} = U_l \left(h_v^{(l-1)}, \bar{m}_v^{(l)} \right) \quad (2.3)$$

where U_l is a parameterized update function (e.g., a Multi-Layer Perceptron or gated recurrent unit).

2.3.2 Homogeneous vs. Heterogeneous GNNs

Early GNN architectures—including Graph Convolutional Networks (GCN) [6], GraphSAGE [7], and Graph Attention Networks (GAT) [8]—were designed for homogeneous graphs where all nodes belong to a single entity type and all edges represent uniform relationships.

In contrast, enterprise identity graphs are profoundly **heterogeneous**. Modeling an Active Directory forest requires distinguishing between distinct node types (Users, Computers, Groups, Certificate Templates, Certificate Authorities) and distinct relational edge semantics (MemberOf, Enroll, WriteDacl, LinksPolicy). Applying homogeneous GNNs to identity graphs destroys the semantic boundaries between entities, leading to severe representation conflation.

To handle heterogeneous structures, specialized architectures have been proposed:

1. **Relational GCN (R-GCN)**: Schlichtkrull et al. [?] introduced relation-specific transformation matrices W_r , parameterizing message passing per edge type.
2. **Heterogeneous Graph Attention Networks (HAN)**: Wang et al. [?] introduced hierarchical attention, computing node-level attention followed by semantic-level meta-path attention.
3. **Heterogeneous Graph Transformer (HGT)**: Hu et al. [9] parameterized self-attention using source-type, target-type, and relation-type matrices to model continuous web-scale graphs.

In this thesis, we build upon the principles of Heterogeneous Graph Attention Networks to engineer **CertGraph**, introducing relation-specific multi-head attention alongside crucial additive residual skip-connections necessary to survive asymmetric enterprise identity topologies.

2.4 Active Directory Architecture and Cryptographic Primitives

To establish the technical foundation for our attack graph formulation, we examine the core internal mechanisms of Active Directory.

2.4.1 Security Principals and Security Identifiers (SIDs)

Every security entity within Active Directory is termed a **Security Principal**. Each security principal is assigned a globally unique, immutable identifier called a **Security Identifier (SID)**:

$$\text{SID} = \text{S-1-5-21-}D_1\text{-}D_2\text{-}D_3\text{-}R \quad (2.4)$$

where D_1, D_2, D_3 denote the unique domain sub-authority, and R represents the Relative Identifier (RID). RIDs below 1000 are reserved for well-known administrative entities:

1. RID 500: Built-in Administrator.
2. RID 502: Built-in KRBTGT (Kerberos Key Distribution Center service account).
3. RID 512: Domain Admins security group.
4. RID 519: Enterprise Admins security group (Tier-0 forest root).

RIDs above 1000 designate dynamically created domain users, groups, and computer workstations.

2.4.2 Kerberos Authentication and Token Construction

Authentication in Active Directory is governed primarily by the Kerberos v5 protocol. The authentication workflow proceeds through the following sequential stages:

1. **Authentication Service (AS) Exchange:** The client encrypts a timestamp using their hashed password and transmits an AS-REQ to the Key Distribution Center (KDC) running on a Domain Controller. The KDC decrypts the timestamp to verify identity and issues an AS-REP containing a Ticket Granting Ticket (TGT).
2. **Privilege Attribute Certificate (PAC):** Crucially, the TGT embeds a cryptographically signed binary structure called the **Privilege Attribute Certificate (PAC)**. The PAC enumerates all security groups to which the user belongs (including transitive nested group memberships) and is signed using both the server secret and the KDC's private key.
3. **Ticket Granting Service (TGS) Exchange:** When the client desires access to a network service (e.g., an SMB share or LDAP directory), it presents its TGT to the KDC via a TGS-REQ. The KDC validates the PAC signature and issues a service ticket (TGS-REP) encrypted with the target service's long-term key.

2.4.3 PKINIT: Public Key Cryptography for Initial Authentication

When Public Key Cryptography for Initial Authentication (PKINIT) is enabled via ADCS (standardized in RFC 4556), a client can initiate the AS exchange by presenting an X.509 digital certificate rather than a password hash. The client signs the PA-PK-AS-REQ pre-authentication structure using its private key and includes its X.509 certificate.

Upon receipt, the KDC:

1. Validates that the certificate was signed by a trusted Enterprise Certificate Authority listed in the domain's NTAAuth store (CN=NTAuthCertificates,CN=Public Key Services,CN=Services,CN=Cor).
2. Verifies that the certificate contains an authorized Extended Key Usage (EKU) permitting client authentication.
3. Extracts the user identity from the certificate's **Subject Alternative Name (SAN)** extension (matching User Principal Name or sAMAccountName) or altSecurityIdentities attribute.
4. Constructs a Kerberos TGT carrying a PAC populated with the privileges of the mapped account.

This mechanism allows any valid certificate carrying an administrative SAN to be exchanged directly for an administrative Kerberos TGT.

2.4.4 Access Control Lists (ACLs) and Security Descriptors

Every Active Directory object is protected by a **Security Descriptor** containing a Discretionary Access Control List (DACL). A DACL comprises an ordered sequence of Access Control Entries (ACEs) defining permissions granted or denied to specific SIDs. Key administrative ACEs include:

1. **GenericAll**: Full unrestricted control over the target object (enabling password resets, attribute modification, and object deletion).
2. **GenericWrite**: Permission to modify any non-confidential attribute of the object.
3. **WriteDacl**: Permission to modify the DACL itself, enabling an attacker to grant themselves **GenericAll**.
4. **WriteOwner**: Permission to assume ownership of the object and subsequently rewrite its security descriptor.
5. **ExtendedRight**: Special domain rights, including **Certificate-Enrollment** and **All-Extended-Rights**.

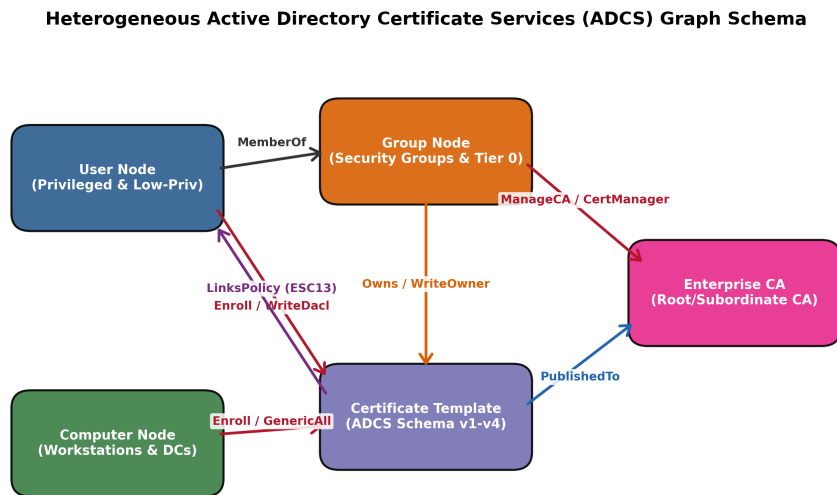


Figure 2.1: Heterogeneous Active Directory Certificate Services (ADCS) Graph Schema, illustrating relations between security principals (Users, Computers, Groups), Certificate Templates, and Enterprise Certificate Authorities.

2.5 Active Directory Certificate Services (ADCS) Mechanics

Active Directory Certificate Services (ADCS) is an integrated Windows role that allows an organization to construct an internal Public Key Infrastructure (PKI). ADCS comprises several core architectural components:

1. **Enterprise Certificate Authority (CA):** A server hosting the ADCS role integrated with Active Directory. Enterprise CAs store their configuration, trust anchors, and published templates directly within the LDAP Configuration partition (`CN=Configuration,DC=domain,DC=local`).
2. **Certificate Templates:** LDAP objects (`class: pKICertificateTemplate`) defining the cryptographic and authorization parameters of certificates issued by the CA. Templates control key usage, validity periods, issuance requirements, and enrollment permissions.
3. **Extended Key Usages (EKUs):** Object Identifiers (OIDs) embedded in certificates designating their authorized operational functions. Critical security-relevant EKUs include:
 - (a) **Client Authentication** (`1.3.6.1.5.5.7.3.2`): Authorizes the certificate for Kerberos PKINIT and TLS client authentication.
 - (b) **Smart Card Logon** (`1.3.6.1.4.1.311.20.2.2`): Enables interactive smart card authentication to Windows domains.

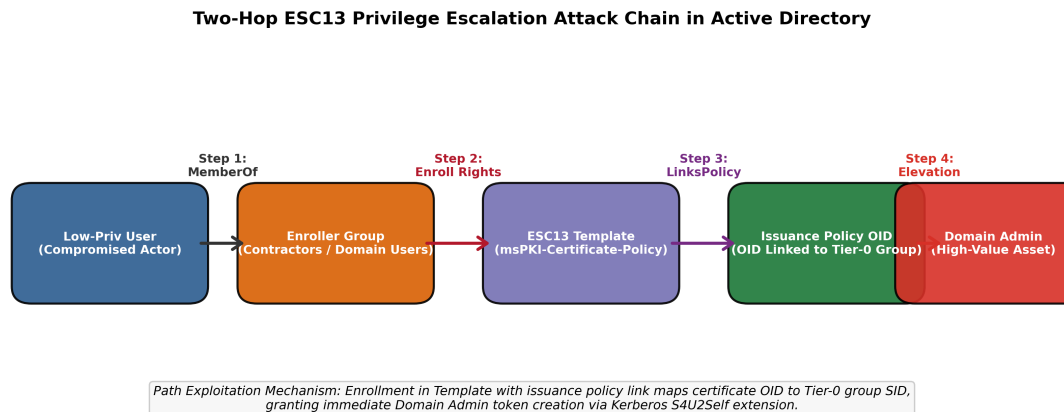


Figure 2.2: Two-hop ESC13 privilege escalation attack path, showing the chain from an unprivileged user through enrollment permissions and issuance policy OID linkage to high-value domain administrative group tokens.

- (c) **Any Purpose** (2.5.29.37.0): Wildcard EKU granting authorization for any cryptographic purpose.
 - (d) **Certificate Request Agent** (1.3.6.1.4.1.311.20.2.1): Authorizes an enrollee to request enrollment on behalf of other users (enrollment agent).
4. **Enrollment Flags and Subject Specification:** The `mspki-certificate-name-flag` attribute governs how the certificate’s subject identity is populated. If the flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` (0x00000001) is set, the certificate requestor explicitly defines the subject and SAN in their Certificate Signing Request (CSR).

2.6 Exhaustive Taxonomy of AD CS Vulnerability Classes (ESC1–ESC15)

SpecterOps and subsequent security researchers categorized common AD CS misconfiguration patterns into numbered Escalation Vectors (ESC). Table 2.1 presents a comprehensive comparative analysis of all 15 documented classes.

2.7 Formal Threat Model

To establish rigorous scientific boundaries, we define our threat model following standard enterprise security conventions:

2.7.1 Attacker Model

1. **Assumed Breach Posture:** We operate under an assumed-breach model. The adversary has already acquired unprivileged execution capability inside the internal corporate network (e.g., standard workstation access with credentials of a regular `Domain Users` account).
2. **Telemetry and Capabilities:** The adversary has read access to the directory service via standard LDAP queries and can enumerate the active PKI infrastructure using unprivileged tools (e.g., Certipy or SharpHound).
3. **Objective:** The adversary seeks to achieve full domain dominance (*Domain Admin* or *Enterprise Admin* status) by identifying and exploiting an ADCS escalation path with minimal detection risk.

2.7.2 Defender Model

1. **Auditing Scope:** The defender possesses read-only administrative auditing telemetry over the Active Directory forest, capable of extracting object attributes and DACL relationships via automated collection pipelines.
2. **Remediation Constraints:** The defender must autonomously or semi-autonomously identify and neutralize exploitable attack paths. Crucially, the defender operates under a **business availability constraint**: defensive mitigations (such as revoking template enrollment rights or deleting groups) must not disrupt legitimate enterprise operations.
3. **Computational Budget:** The detection architecture must execute efficiently on commodity security operations infrastructure (e.g., standard analysts' workstations with bounded RAM budgets), precluding the deployment of cumbersome full-OS virtual machine simulations for static auditing.

Table 2.1: Comprehensive Comparative Taxonomy of ADCS Privilege Escalation Vectors (ESC1–ESC15).

Vector	Vulnerability Name	Key Configuration Prerequisites	Exploitation Impact
ESC1	Enrollee Supplies SAN	ENROLLEE_SUPPLIES_SUBJECT + Client Auth ECU + Unprivileged Enroll	Direct domain admin impersonation via Kerberos PKINIT
ESC2	Any Purpose ECU	Any Purpose ECU (2.5.29.37.0) or missing ECU + Unprivileged Enroll	Arbitrary impersonation across all cryptographic protocols
ESC3	Enrollment Agent	Certificate Request Agent ECU + 2-hop template enrollment path	Co-signs CSR on behalf of arbitrary domain accounts
ESC4	Insecure Template DACL	GenericAll / WriteDacl / WriteOwner on template object	Rewrites template to ESC1, enrolls, reverts configuration
ESC5	Insecure PKI Object DACL	Insecure ACLs on CA container/enrollment services object	Takes ownership of PKI infrastructure and roots
ESC6	CA SAN Flag Active	EDITF_ATTRIBUTESUBJECTALTNAME2 enabled on CA server	Injects arbitrary SAN into any template request
ESC7	Insecure CA Permissions	ManageCA or ManageCertificates rights on CA object	Overrides CA settings, approves unprivileged requests
ESC8	HTTP Enrollment Relay	NTLM authentication enabled on Web Enrollment HTTP endpoints	Coerced NTLM relay from DC to obtain DC certificate
ESC9	Missing Security Ext.	CT_FLAG_NO_SECURITY_EXTENSIONS enabled on template	SIPON spoofing bypasses strong mapping without PAC check
ESC10	Weak Certificate Mapping	altSecurityIdentities weak registry keys on Domain Controllers	Account takeover via unverified X.509 mapping syntax
ESC11	Insecure RPC Interface	RPC enrollment endpoint lacking packet privacy / signing	Relays NTLM to RPC enrollment interface MS-ICPR
ESC12	Vulnerable Hardware Key	CA administrator key stored in vulnerable smart card / token	Direct exfiltration of CA root signing keys
ESC13	Issuance Policy Link	msPKI-Certificate-Policy OID maps to Tier-0 security group	Injects Tier-0 group SID into Kerberos PAC token
ESC14	altSecurityIdentities Hijack	Insecure write permissions over altSecurityIdentities	Links arbitrary victim certificates to attacker account
ESC15	ECUwu (CVE-2024-49019)	Schema Version 1 template allows custom CSR application policy	Injects Client Authentication ECU into non-auth templates

Chapter 3

Formal Methodology and CertGraph Architecture

3.1 Mathematical Formalization of Enterprise Identity Multigraphs

To rigorously model the complex, relational authorization topology of Active Directory (AD) and Active Directory Certificate Services (ADCS), we formalize the enterprise environment as a typed, directed, heterogeneous multigraph. Unlike flat tabular databases or homogeneous network graphs that treat all entities and connections identically, a heterogeneous multigraph explicitly preserves the distinct semantic properties of different directory objects and authorization relationships.

Definition 3.1 (Active Directory Heterogeneous Multigraph). An Active Directory enterprise environment is formally defined as a 6-tuple:

$$G = (V, E, \mathcal{T}_V, \mathcal{T}_E, \phi_V, \psi_E) \quad (3.1)$$

where:

1. $V = \bigcup_{\tau \in \mathcal{T}_V} V_\tau$ is the finite set of all directory entities (vertices), partitioned into disjoint subsets by entity type, such that $V_{\tau_1} \cap V_{\tau_2} = \emptyset$ for all $\tau_1 \neq \tau_2$.
2. $E \subseteq V \times \mathcal{T}_E \times V$ is the multiset of directed authorization, administrative, and enrollment relationships (edges). An edge $e = (u, r, v) \in E$ indicates a directed relationship of relation type r from source entity u to target entity v .
3. $\mathcal{T}_V = \{\text{User, Computer, Group, Template, EnterpriseCA}\}$ represents the discrete set of node

entity types ($|\mathcal{T}_V| = 5$).

4. $\mathcal{T}_E = \{\text{MemberOf}, \text{Enroll}, \text{GenericAll}, \text{WriteDacl}, \text{WriteOwner}, \text{PublishedTo}, \text{ManageCA}, \text{LinksPolicy}\}$ represents the discrete set of canonical directed relation types ($|\mathcal{T}_E| = 8$).
5. $\phi_V : V \rightarrow \mathcal{T}_V$ is an ontological type-mapping function assigning each vertex $v \in V$ its unique structural entity type $\tau(v) \in \mathcal{T}_V$.
6. $\psi_E : E \rightarrow \mathcal{T}_E$ is a relation-mapping function assigning each directed edge $e = (u, r, v) \in E$ its canonical relation type $r \in \mathcal{T}_E$.

Definition 3.2 (Network Schema and Canonical Metapaths). The network schema of the enterprise identity multigraph is a directed meta-graph $\mathcal{S}_G = (\mathcal{T}_V, \mathcal{T}_E)$, specifying allowable directed relations between node types. A metapath $\mathcal{P}$ of length l is a sequence of entity types and relation types:

$$\mathcal{P} = \tau_0 \xrightarrow{r_1} \tau_1 \xrightarrow{r_2} \tau_2 \xrightarrow{r_3} \dots \xrightarrow{r_l} \tau_l \quad (3.2)$$

In Active Directory Certificate Services, privilege escalation is formalized as the existence of a valid composite metapath connecting an unprivileged security principal $s \in V_{\text{User}} \cup V_{\text{Computer}}$ to an administrative certificate issuance template $t \in V_{\text{Template}}$, followed by an authentication exchange terminating at a Tier-0 asset.

3.2 Node Feature Vector Spaces and Semantic Encodings

Each vertex $v \in V$ is assigned an initial feature vector $x_v \in \mathbb{R}^{d_{\tau(v)}}$ encoding intrinsic local attributes extracted directly from LDAP directory queries and Active Directory security descriptors. Because different entity types possess distinct configuration schemas, feature spaces are typed and heterogeneous.

3.2.1 Certificate Template Feature Representation

Certificate templates are the primary targets of ADCS audits. A template vertex $t \in V_{\text{Template}}$ is assigned a 10-dimensional binary feature vector $x_{\text{Template}} \in \mathbb{R}^{10}$:

$$x_{\text{Template}} = [f_{\text{supplies_subject}}, f_{\text{client_auth}}, f_{\text{any_purpose}}, f_{\text{agent_eku}}, f_{\text{no_security_ext}}, f_{\text{schema_v1}}, f_{\text{requires_approval}}, f_{\text{has_policy_link}}, f_{\text{has_dangerous_dacl}}, f_{\text{is_published}}]^T \quad (3.3)$$

The individual binary dimensions are defined and extracted as follows:

1. $f_{\text{supplies_subject}} \in \{0, 1\}$: Extracted from the LDAP integer attribute `msPKI-Certificate-Name-Flag`. Evaluates to 1 if the bitwise flag `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` (0x00000001) is set, indicating that the enroller can specify an arbitrary Subject Alternative Name (SAN).
2. $f_{\text{client_auth}} \in \{0, 1\}$: Extracted from the multi-valued string attribute `pKIExtendedKeyUsage`. Evaluates to 1 if the template includes the Client Authentication Object Identifier (OID 1.3.6.1.5.5.7.3.2) or Smart Card Logon (OID 1.3.6.1.4.1.311.20.2.2).
3. $f_{\text{any_purpose}} \in \{0, 1\}$: Evaluates to 1 if `pKIExtendedKeyUsage` contains the Any Purpose OID (2.5.29.37.0) or if the attribute is empty/null, which Windows CryptoAPI interprets as valid for all cryptographic applications.
4. $f_{\text{agent_eku}} \in \{0, 1\}$: Evaluates to 1 if `pKIExtendedKeyUsage` contains the Certificate Request Agent OID (1.3.6.1.4.1.311.20.2.1), permitting on-behalf-of enrollment.
5. $f_{\text{no_security_ext}} \in \{0, 1\}$: Extracted from `msPKI-Enrollment-Flag`. Evaluates to 1 if the flag `CT_FLAG_NO_SECURITY_EXTENSION` (0x00080000) is enabled, instructing the CA to omit the security extension embedding the requestor's SID.
6. $f_{\text{schema_v1}} \in \{0, 1\}$: Extracted from the integer attribute `msPKI-Template-Schema-Version`. Evaluates to 1 if the schema version equals 1, signifying a legacy Windows 2000 template susceptible to CVE-2024-49019 (EKUwu).
7. $f_{\text{requires_approval}} \in \{0, 1\}$: Extracted from `msPKI-Enrollment-Flag`. Evaluates to 1 if `CT_FLAG_PEND_ALL_RE` (0x00000002) is set, mandating CA certificate manager intervention prior to certificate issuance.
8. $f_{\text{has_policy_link}} \in \{0, 1\}$: Extracted from `msPKI-Certificate-Policy`. Evaluates to 1 if the template references one or more Issuance Policy OIDs.
9. $f_{\text{has_dangerous_dacl}} \in \{0, 1\}$: Extracted by evaluating the Discretionary Access Control List (DACL) in `ntSecurityDescriptor`. Evaluates to 1 if any low-privileged security principal holds `GenericAll`, `GenericWrite`, `WriteDacl`, or `WriteOwner` access rights on the template object.

10. $f_{\text{is_published}} \in \{0, 1\}$: Evaluates to 1 if the template name is actively listed in the `certificateTemplates` attribute of at least one operational Enterprise CA object within the Active Directory configuration partition.

3.2.2 Security Principal Feature Representations

The security principals capable of initiating or forwarding access control operations are represented by typed feature vectors capturing administrative tiering, protocol configuration, and account state:

1. **User Nodes** ($x_{\text{User}} \in \mathbb{R}^6$):

$$x_{\text{User}} = [f_{\text{is_enabled}}, f_{\text{is_sensitive}}, f_{\text{dont_req_preauth}}, f_{\text{trusted_for_delegation}}, f_{\text{has_spn}}, f_{\text{is_admin}}]^T \quad (3.4)$$

where $f_{\text{is_enabled}}$ indicates whether `ACCOUNTDISABLE` is absent from `userAccountControl`; $f_{\text{is_sensitive}}$ indicates `NOT_DELEGATED`; $f_{\text{dont_req_preauth}}$ identifies accounts vulnerable to AS-REP roasting; $f_{\text{trusted_for_delegation}}$ flags unconstrained Kerberos delegation; $f_{\text{has_spn}}$ flags accounts susceptible to Kerberoasting; and $f_{\text{is_admin}} \in \{0, 1\}$ indicates membership in a Tier-0 administrative role (`adminCount = 1`).

2. **Computer Nodes** ($x_{\text{Computer}} \in \mathbb{R}^6$):

$$x_{\text{Computer}} = [f_{\text{is_enabled}}, f_{\text{is_dc}}, f_{\text{unconstrained}}, f_{\text{constrained}}, f_{\text{rbcd}}, f_{\text{is_admin}}]^T \quad (3.5)$$

where $f_{\text{is_dc}}$ indicates a primary Domain Controller; $f_{\text{unconstrained}}$ and $f_{\text{constrained}}$ capture Kerberos delegation settings; and f_{rbcd} flags resource-based constrained delegation configurations.

3. **Security Group Nodes** ($x_{\text{Group}} \in \mathbb{R}^2$):

$$x_{\text{Group}} = [f_{\text{is_tier0}}, f_{\text{is_builtin}}]^T \quad (3.6)$$

where $f_{\text{is_tier0}} = 1$ denotes high-value administrative groups (e.g., `Domain Admins`, `Enterprise Admins`, `Schema Admins`, `Administrators`, `Account Operators`); and $f_{\text{is_builtin}} = 1$ indicates standard well-known Windows security groups.

4. Enterprise Certificate Authority Nodes ($x_{\text{CA}} \in \mathbb{R}^3$):

$$x_{\text{CA}} = [f_{\text{is_root_ca}}, f_{\text{allows_user_spec}}, f_{\text{enforces_encryption}}]^T \quad (3.7)$$

where $f_{\text{is_root_ca}}$ identifies root CAs; $f_{\text{allows_user_spec}}$ flags the presence of the dangerous registry setting EDITF_ATTRIBUTESUBJECTALTNAME2; and $f_{\text{enforces_encryption}}$ identifies whether RPC interface encryption is mandated on the CA endpoint (relevant to ESC11).

3.2.3 Relational Adjacency and Canonical Reverse Relations

For each relation type $r = (\tau_s, \text{rel}, \tau_t) \in \mathcal{T}_E$, the directed adjacency matrix $A_r \in \{0, 1\}^{|V_{\tau_s}| \times |V_{\tau_t}|}$ satisfies:

$$A_r[u, v] = 1 \iff (u, r, v) \in E \quad (3.8)$$

A fundamental challenge in graph representation learning on directed identity graphs is that access control permissions flow from principals to resources (e.g., User $\xrightarrow{\text{Enroll}}$ Template), whereas vulnerability reasoning requires evaluating the reverse query: *"Which unprivileged principals possess an inbound access path to this template?"*

To facilitate bidirectional information exchange across the message-passing layers, we introduce formal reverse canonical relations for every directed edge type:

$$\forall r = (\tau_s, \text{rel}, \tau_t) \in \mathcal{T}_E \implies r^{-1} = (\tau_t, \text{rel}^{-1}, \tau_s) \in \mathcal{T}_E^{-1} \quad (3.9)$$

The adjacency matrix for the reverse relation is the exact transpose of the forward adjacency:

$$A_{r^{-1}} = A_r^T \quad (3.10)$$

The augmented relational set $\tilde{\mathcal{T}}_E = \mathcal{T}_E \cup \mathcal{T}_E^{-1}$ contains 16 directed relations, ensuring that certificate templates can gather structural context from prospective enrollers and administrative controllers during forward message passing.

3.3 The CertGraph Hetero-GAT Architecture

CertGraph implements an inductive Heterogeneous Graph Attention Network (Hetero-GAT). Unlike homogeneous GNNs that collapse entity distinctions into a single latent space, CertGraph maintains

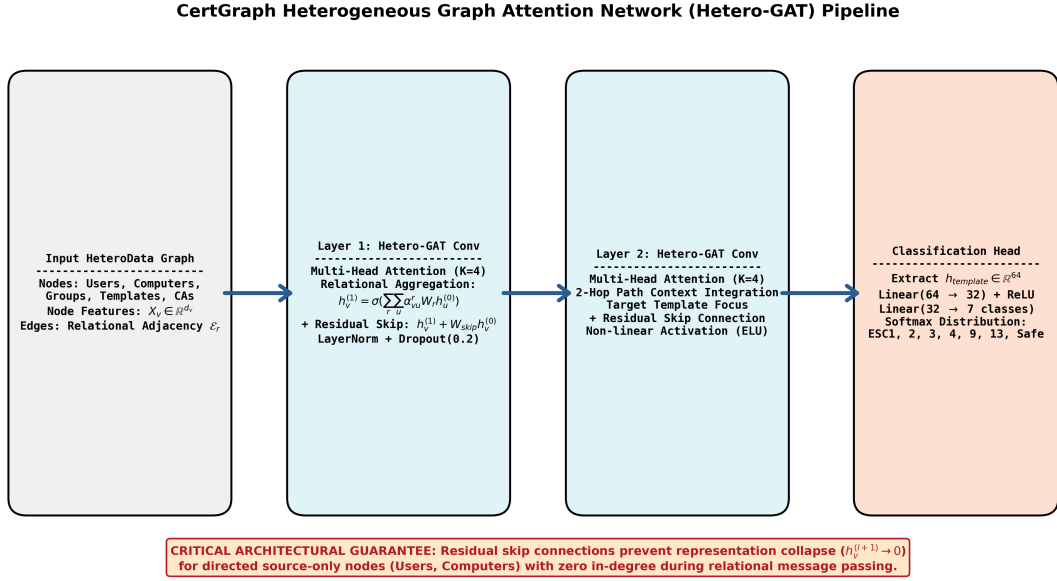


Figure 3.1: CertGraph end-to-end Hetero-GAT pipeline, detailing input feature encoding, multi-head relational attention layers, additive residual skip-connections, and the multi-class template classification head.

type-specific linear projections and relation-specific multi-head attention mechanisms.

3.3.1 Relation-Specific Linear Feature Projections

Let $h_u^{(l-1)} \in \mathbb{R}^{d_{\tau(u)}^{(l-1)}}$ denote the hidden representation of node u at layer $l-1$, where $h_u^{(0)} = x_u$. For each canonical relation $r = (\tau(u), \text{rel}, \tau(v)) \in \tilde{\mathcal{T}}_E$ terminating at target node v , source and target node representations are projected into a common relational metric space $\mathbb{R}^{d_{\text{out}}^{(l)}}$:

$$z_u^{(l,r)} = W_{\text{src}}^{(l,r)} h_u^{(l-1)}, \quad z_v^{(l,r)} = W_{\text{dst}}^{(l,r)} h_v^{(l-1)} \quad (3.11)$$

where $W_{\text{src}}^{(l,r)} \in \mathbb{R}^{d_{\text{out}}^{(l)} \times d_{\tau(u)}^{(l-1)}}$ and $W_{\text{dst}}^{(l,r)} \in \mathbb{R}^{d_{\text{out}}^{(l)} \times d_{\tau(v)}^{(l-1)}}$ are learnable projection matrices. In our implementation, hidden dimensions are set to $d_{\text{hidden}} = 64$ across all layers.

3.3.2 Multi-Head Relational Graph Attention

To capture multi-faceted topological dependencies (e.g., distinguishing between direct group membership and delegated write permissions), CertGraph deploys K independent attention heads per relation.

For attention head $k \in \{1, \dots, K\}$, the unnormalized attention coefficient $e_{vu}^{(k,l,r)}$ quantifying the

importance of incoming source node u to target node v across relation r is computed as:

$$e_{vu}^{(k,l,r)} = \text{LeakyReLU} \left(\mathbf{a}_k^{(l,r)T} \left[z_v^{(k,l,r)} \parallel z_u^{(k,l,r)} \right] \right) \quad (3.12)$$

where $\mathbf{a}_k^{(l,r)} \in \mathbb{R}^{2d_{\text{head}}}$ is a learnable relation-specific attention vector, $\parallel$ denotes vector concatenation, and the LeakyReLU non-linearity employs a negative slope parameter of $\alpha_{\text{leaky}} = 0.2$. The head dimension satisfies $d_{\text{head}} = d_{\text{out}}^{(l)}/K$.

To ensure comparability across nodes with varying in-degrees, attention coefficients are normalized across the set of incoming relation neighbors $\mathcal{N}_r(v) = \{u \in V_{\tau_s} \mid (u, r, v) \in E\}$ using the relational softmax function:

$$\alpha_{vu}^{(k,l,r)} = \frac{\exp \left(e_{vu}^{(k,l,r)} \right)}{\sum_{w \in \mathcal{N}_r(v)} \exp \left(e_{vw}^{(k,l,r)} \right)} \quad (3.13)$$

The aggregated message for node v under relation r across all K attention heads is obtained via concatenation:

$$\mu_{v,r}^{(l)} = \prod_{k=1}^K \left(\sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(k,l,r)} z_u^{(k,l,r)} \right) \quad (3.14)$$

where $\parallel$ denotes concatenation along the channel dimension, resulting in $\mu_{v,r}^{(l)} \in \mathbb{R}^{d_{\text{out}}^{(l)}}$.

3.3.3 Semantic-Level Aggregation and Residual Skip-Connections

Because a target entity v may receive incoming messages from multiple distinct relation types $\mathcal{R}_{\text{in}}(\tau(v)) = \{r \in \tilde{\mathcal{T}}_E \mid \text{target}(r) = \tau(v)\}$, CertGraph performs semantic-level aggregation via vector summation:

$$h_{v,\text{agg}}^{(l)} = \sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mu_{v,r}^{(l)} \quad (3.15)$$

Additive Residual Skip-Connections: As established theoretically in Section 3.5, pure neighborhood aggregation in directed acyclic or source-dominated subgraphs suffers from catastrophic representation collapse. To preserve node-specific identity features and maintain stable gradient flow, CertGraph incorporates parameterized additive residual skip-connections:

$$\tilde{h}_v^{(l)} = h_{v,\text{agg}}^{(l)} + W_{\text{skip}}^{(l,\tau(v))} h_v^{(l-1)} \quad (3.16)$$

where $W_{\text{skip}}^{(l,\tau(v))} \in \mathbb{R}^{d_{\text{out}}^{(l)} \times d_{\tau(v)}^{(l-1)}}$ is a type-specific linear projection matrix.

The pre-activation state is transformed via the Exponential Linear Unit (ELU) activation function, followed by Layer Normalization and Dropout:

$$\bar{h}_v^{(l)} = \text{ELU} \left(\tilde{h}_v^{(l)} \right) \quad (3.17)$$

$$h_v^{(l)} = \text{Dropout} \left(\text{LayerNorm} \left(\bar{h}_v^{(l)} \right), p = 0.2 \right) \quad (3.18)$$

3.3.4 Multi-Class Vulnerability Classification Head

CertGraph stacks $L = 2$ heterogeneous graph attention layers. A 2-hop receptive field is mathematically sufficient to resolve all standard ADCS escalation paths:

1. User $\xrightarrow{\text{MemberOf}}$ Group $\xrightarrow{\text{Enroll}}$ Template (2 hops).
2. User $\xrightarrow{\text{Enroll}}$ Template $\xrightarrow{\text{LinksPolicy}}$ Group (2 hops).
3. User $\xrightarrow{\text{WriteDacl}}$ Template $\xrightarrow{\text{PublishedTo}}$ CA (2 hops).

Following the second message-passing layer, we isolate the final latent representation of the target certificate template $h_t^{(L)} \in \mathbb{R}^{64}$. This embedding is forwarded to a two-layer Multi-Layer Perceptron (MLP) classification head:

$$z_t = \text{ReLU} \left(W_1 h_t^{(L)} + b_1 \right), \quad W_1 \in \mathbb{R}^{32 \times 64}, b_1 \in \mathbb{R}^{32} \quad (3.19)$$

$$\hat{y}_t = \text{Softmax} \left(W_2 z_t + b_2 \right), \quad W_2 \in \mathbb{R}^{7 \times 32}, b_2 \in \mathbb{R}^7 \quad (3.20)$$

where $\hat{y}_t \in \Delta^6$ represents the predicted probability distribution over the 7 target vulnerability classes:

$$C = \{\text{Safe}, \text{ESC1}, \text{ESC2}, \text{ESC3}, \text{ESC4}, \text{ESC9}, \text{ESC13}\} \quad (3.21)$$

3.3.5 Objective Function with Class Imbalance Regularization

In enterprise Active Directory environments, vulnerable certificate templates are rare relative to benign configurations. To counter class imbalance and prevent overfitting, the network is trained end-to-end by minimizing the Weighted Cross-Entropy Loss with L_2 weight regularization:

$$\mathcal{L}(\Theta) = - \sum_{i=1}^N \sum_{c=1}^{|C|} \omega_c y_{i,c} \log \hat{y}_{i,c} + \lambda_{\text{reg}} \sum_{\theta \in \Theta} \|\theta\|_2^2 \quad (3.22)$$

where N is the batch size; $y_{i,c} \in \{0, 1\}$ is the one-hot encoded ground truth; $\omega_c = \frac{N}{|C| \cdot N_c}$ is the inverse class frequency weight; $\lambda_{\text{reg}} = 10^{-4}$ is the weight decay coefficient; and Θ denotes all learnable parameters ($W_{\text{src}}, W_{\text{dst}}, \mathbf{a}_k, W_{\text{skip}}, W_1, W_2$). Parameter optimization is performed using AdamW with an initial learning rate of $\eta = 10^{-3}$ and a cosine annealing learning rate schedule.

3.4 Formal Algorithmic Specifications

To ensure complete scientific reproducibility, we formalize the core execution routines of CertGraph into algorithmic specifications.

3.4.1 End-to-End Layer Forward Pass

Algorithm 1 formalizes the computation of a single CertGraph heterogeneous attention layer with residual skip-connections and relational softmax.

Algorithm 1 CertGraph Heterogeneous Attention Layer Forward Pass

Require: Heterogeneous Multigraph $G = (V, E, \tilde{\mathcal{T}}_E)$; Input hidden states $\{h_v^{(l-1)}\}_{v \in V}$; Projection matrices $\{W_{\text{src}}^{(l,r)}, W_{\text{dst}}^{(l,r)}\}$; Attention vectors $\{\mathbf{a}_k^{(l,r)}\}$; Skip projections $\{W_{\text{skip}}^{(l,r)}\}$.

Ensure: Updated hidden representations $\{h_v^{(l)}\}_{v \in V}$.

```

1: for each canonical relation  $r = (\tau_s, \text{rel}, \tau_t) \in \tilde{\mathcal{T}}_E$  do
2:   Compute projected representations:
3:    $z_u^{(l,r)} \leftarrow W_{\text{src}}^{(l,r)} h_u^{(l-1)}$  for all  $u \in V_{\tau_s}$ 
4:    $z_v^{(l,r)} \leftarrow W_{\text{dst}}^{(l,r)} h_v^{(l-1)}$  for all  $v \in V_{\tau_t}$ 
5:   for each attention head  $k \in \{1, \dots, K\}$  do
6:     for each edge  $(u, r, v) \in E_r$  do
7:        $e_{vu}^{(k,l,r)} \leftarrow \text{LeakyReLU}(\mathbf{a}_k^{(l,r)T} [z_v^{(k,l,r)} \parallel z_u^{(k,l,r)}])$ 
8:     end for
9:     for each target node  $v \in V_{\tau_t}$  do
10:      Normalize:  $\alpha_{vu}^{(k,l,r)} \leftarrow \frac{\exp(e_{vu}^{(k,l,r)})}{\sum_{w \in \mathcal{N}_r(v)} \exp(e_{vw}^{(k,l,r)})}$ 
11:    end for
12:  end for
13:  for each target node  $v \in V_{\tau_t}$  do
14:    Compute head concatenation:  $\mu_{v,r}^{(l)} \leftarrow \prod_{k=1}^K \left( \sum_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(k,l,r)} z_u^{(k,l,r)} \right)$ 
15:  end for
16: end for
17: for each entity  $v \in V$  do
18:   Semantic aggregation:  $h_{v,\text{agg}}^{(l)} \leftarrow \sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mu_{v,r}^{(l)}$ 
19:   Additive residual skip:  $\tilde{h}_v^{(l)} \leftarrow h_{v,\text{agg}}^{(l)} + W_{\text{skip}}^{(l,\tau(v))} h_v^{(l-1)}$ 
20:   Non-linear activation:  $\bar{h}_v^{(l)} \leftarrow \text{ELU}(\tilde{h}_v^{(l)})$ 
21:   Normalization & Regularization:  $h_v^{(l)} \leftarrow \text{Dropout}(\text{LayerNorm}(\bar{h}_v^{(l)}), p = 0.2)$ 
22: end for
23: return  $\{h_v^{(l)}\}_{v \in V}$ 

```

3.4.2 Vulnerability Inference and Calibrated Risk Scoring

Algorithm 2 details the inference pipeline that ingests raw enterprise graphs, executes message passing, and generates calibrated risk rankings for security teams.

Algorithm 2 CertGraph Enterprise Vulnerability Screening and Risk Prioritization

Require: Enterprise Active Directory Graph $G = (V, E)$; Trained CertGraph model $\mathcal{M}_\Theta$; Risk threshold $\tau_{\text{risk}} \in [0, 1]$.

Ensure: Prioritized list of high-risk certificate templates $\mathcal{R}_{\text{alerts}}$.

- 1: Extract node feature tensors $\{x_v\}_{v \in V}$ from LDAP and DACL attributes
 - 2: Construct reverse relations r^{-1} for all $r \in \mathcal{T}_E$ to form augmented graph $\tilde{G}$
 - 3: Initialize $h_v^{(0)} \leftarrow x_v$ for all $v \in V$
 - 4: **for** layer $l = 1$ to $L = 2$ **do**
 - 5: $\{h_v^{(l)}\}_{v \in V} \leftarrow \text{CertGraphLayerForward}(\tilde{G}, \{h_v^{(l-1)}\}_{v \in V}, \Theta^{(l)})$
 - 6: **end for**
 - 7: Initialize empty alert queue $\mathcal{R}_{\text{alerts}} \leftarrow []$
 - 8: **for** each published template $t \in V_{\text{Template}}$ **do**
 - 9: Forward embedding $h_t^{(L)}$ to classification head: $\hat{y}_t \leftarrow \text{Softmax}(W_2 \text{ReLU}(W_1 h_t^{(L)} + b_1) + b_2)$
 - 10: Compute composite risk score: $S_{\text{risk}}(t) \leftarrow 1.0 - \hat{y}_t[\text{Safe}]$
 - 11: Determine predicted vector: $c_{\text{pred}} \leftarrow \arg\max_c \hat{y}_t[c]$
 - 12: **if** $S_{\text{risk}}(t) \geq \tau_{\text{risk}}$ and $c_{\text{pred}} \neq \text{Safe}$ **then**
 - 13: Append $(t, c_{\text{pred}}, S_{\text{risk}}(t), \hat{y}_t)$ to $\mathcal{R}_{\text{alerts}}$
 - 14: **end if**
 - 15: **end for**
 - 16: Sort $\mathcal{R}_{\text{alerts}}$ in descending order of risk score $S_{\text{risk}}(t)$
 - 17: **return** $\mathcal{R}_{\text{alerts}}$
-

3.5 Theoretical Analysis: Representation Collapse in Directed Graphs

A foundational theoretical contribution of this thesis is the formal proof that residual skip-connections are not merely an optimization heuristic in enterprise identity graphs, but a strict mathematical requirement.

Theorem 3.1 (Representation Collapse of Source-Only Entities). In any directed heterogeneous graph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ where a subset of node types $\mathcal{T}_{\text{source}} \subset \mathcal{T}_V$ possesses zero incoming edges ($d_{\text{in}}(v) = 0$ for all $v \in V$ with $\tau(v) \in \mathcal{T}_{\text{source}}$), an L -layer heterogeneous message-passing neural network lacking residual skip-connections collapses the hidden representations of all source-only nodes to the zero vector:

$$h_v^{(l)} = \mathbf{0}, \quad \forall v \text{ with } \tau(v) \in \mathcal{T}_{\text{source}}, \forall l \geq 1 \quad (3.23)$$

Furthermore, the gradient of the objective loss function $\mathcal{L}$ with respect to the input feature vector x_v

vanishes identically:

$$\frac{\partial \mathcal{L}}{\partial x_v} = \mathbf{0} \quad (3.24)$$

Proof Outline. The full, rigorous mathematical proof is provided in Appendix A.1. Because $d_{\text{in}}(v) = 0$, the set of incoming neighbors $\mathcal{N}_r(v) = \emptyset$ for all canonical relations r . By definition of graph aggregation operators, message aggregation over an empty set returns the zero vector identity $\mathbf{0}$. Without a skip projection $W_{\text{skip}} h_v^{(l-1)}$, the node state update simplifies to $h_v^{(l)} = \sigma(\mathbf{0}) = \mathbf{0}$. By application of the multi-variable chain rule across successive layers, the gradient $\frac{\partial \mathcal{L}}{\partial x_v}$ factors through $\frac{\partial h_v^{(1)}}{\partial x_v} = \mathbf{0}$, causing input feature sensitivities to vanish identically.

Corollary 3.1 (Security Blindness Corollary). In Active Directory graphs, user and workstation accounts frequently exhibit pure source topology in administrative authorization subgraphs (i.e., they possess outgoing permissions to groups and templates, but no directory objects hold incoming access rights over them). Omitting skip connections mathematically guarantees that the neural network becomes completely blind to whether an enroller account is a privileged administrator ($f_{\text{is_admin}} = 1$) or an unprivileged guest ($f_{\text{is_admin}} = 0$).

3.6 Computational Complexity and Scalability Analysis

To understand why CertGraph can screen enterprise networks in milliseconds while graph traversal tools encounter combinatorial slowdowns, we analyze its asymptotic time and space complexity:

Proposition 3.1 (Computational Complexity of CertGraph Inference). Let $G = (V, E)$ denote an enterprise identity multigraph with $|V|$ vertices, $|E|$ edges, hidden dimension d , and L convolutional layers. The computational time complexity of a CertGraph forward pass is:

$$O\left(L \cdot \left(|E| \cdot d + |V| \cdot d^2\right)\right) \quad (3.25)$$

and its auxiliary space complexity is $O(|V| \cdot d + |E|)$.

Proof. For each layer $l \in \{1, \dots, L\}$:

1. **Node Feature Projections:** Projecting all $|V|$ nodes across incoming relations requires $|V| \cdot d^2$ multiply-accumulate operations.
2. **Attention Logit Computation:** Computing unnormalized attention coefficients $e_{vu}^{(k,l,r)}$ requires evaluating the dot product $\mathbf{a}_k^T[z_v \| z_u]$ for every directed edge in E . This evaluates in

$O(|E| \cdot d)$ operations.

3. **Relational Softmax and Aggregation:** Normalizing attention coefficients and taking the weighted sum over neighbor feature vectors evaluates in $O(|E| \cdot d)$ operations using sparse segment reduction primitives.
4. **Skip Connection and Non-Linearity:** Adding the residual projection and evaluating ELU and LayerNorm requires $O(|V| \cdot d)$ operations.

Summing these stages across L layers yields $O(L(|E|d + |V|d^2))$. Because $L = 2$ and $d = 64$ are fixed constants, the complexity scales strictly linearly with graph volume:

$$O(|V| + |E|) \tag{3.26}$$

Memory space is dominated by the node state tensors $\mathbb{R}^{|V| \times d}$ and the edge index tensor $\mathbb{Z}^{2 \times |E|}$, bounded by $O(|V|d + |E|)$. $\square$

In contrast, deterministic graph traversal (e.g., Breadth-First Search or Cypher shortest-path queries) across all published templates exhibits worst-case computational complexity of $O(|V_{\text{Template}}| \cdot (|V| + |E|))$. In densely connected enterprise forests where $|E| \gg |V|$, recursive path-finding encounters exponential path explosion along cyclic group delegation chains, whereas CertGraph executes as a sequence of highly parallelized, constant-depth GPU tensor operations.

Chapter 4

Forensic Audit: Unmasking Experimental Illusions in Security Machine Learning

4.1 The Methodological Crisis of Security Machine Learning

Applied machine learning in computer security is uniquely susceptible to methodological pitfalls and experimental artifacts. In conventional computer vision and natural language processing domains, models learn from human-perceptible patterns (such as textures, shapes, and syntax). In contrast, cybersecurity datasets—particularly those representing enterprise network graphs and identity topologies—consist of high-dimensional, abstract relational structures where human intuition cannot easily detect subtle distribution shifts or hidden correlations.

A pervasive pathology in modern security ML literature is the phenomenon of “too good to be true” empirical results. When an experimental pipeline produces near-perfect classification metrics (e.g., Macro-F1 = 1.0000), researchers are confronted with a critical methodological dilemma:

1. **The Optimistic Hypothesis:** The deep neural network has discovered an omniscient, generalizable representation of the underlying security domain, solving the threat detection problem.
2. **The Adversarial Reality:** The experimental architecture has inadvertently leaked spurious, deterministic artifacts, allowing the neural network to achieve superficial perfection by exploiting statistical shortcuts that collapse in real-world deployments.

During the early development of CertGraph, initial iterations of our Hetero-GAT model achieved

a flawless 1.0000 Macro-F1 score across all seven evaluated ESC vulnerability classes on synthetic enterprise graphs. Rather than prematurely declaring victory, we adopted an **Adversarial Forensic Audit** doctrine: we treated our own data generators, feature encodings, and model baselines as potentially compromised systems requiring rigorous post-mortem dissection.

Our audit exposed four profound, compounding experimental illusions that had artificially inflated empirical performance. By systematically documenting how these illusions arose, how they were mathematically proven, and how our pipeline was re-engineered, this chapter provides a methodological blueprint for experimental hygiene in graph machine learning for cybersecurity.

4.2 The Four Experimental Illusions

4.2.1 Illusion 1: Positional Index Leakage in Synthetic Topologies

In synthetic network generators, entities are typically instantiated sequentially within memory arrays or graph database buffers. In our initial generator implementation (`generator_v1.py`), directory entities were instantiated in fixed programmatic loops:

1. The Tier-0 administrative security group (`Domain Admins`) was consistently allocated at index 0 of the `Group` entity tensor ($v_{\text{group}} = 0$).
2. Domain administrators were systematically allocated within the lowest numeric partition of the `User` tensor ($v_{\text{user}} \in [0, \lfloor N_{\text{users}}/10 \rfloor]$).
3. In ESC13 synthetic generation routines, the issuance policy OID was programmatically linked exclusively to group index 0.

Information-Theoretic Proof of Positional Leakage: Let $Y \in \mathcal{C}$ denote the random variable representing the true vulnerability class of a certificate template, and let $I_A \in \mathbb{N}$ denote the integer array index of the high-value target group or enroller principal. In a methodologically sound experimental benchmark, an entity's arbitrary memory buffer index must provide zero information regarding its security posture:

$$I(Y; I_A) = H(Y) - H(Y | I_A) = 0 \quad (4.1)$$

where $H(Y)$ is the Shannon entropy of the class distribution, and $I(Y; I_A)$ is the mutual information.

However, because group index 0 was deterministically reserved for `Domain Admins`, observing that a template's incoming or outgoing edge linked to index 0 completely eliminated all uncertainty

regarding the vulnerability class:

$$H(Y \mid I_A = 0) = 0 \implies I(Y; I_A = 0) = H(Y) = \log_2(7) \approx 2.807 \text{ bits} \quad (4.2)$$

The neural network was not learning relational access control semantics; it was functioning as an information-theoretic decoder of synthetic memory allocation offsets.

The Deterministic Positional Oracle: To empirically verify whether deep graph convolutions were genuinely necessary or if the pipeline was merely exploiting index leakage, we constructed a trivial 6-line deterministic heuristic rule that performed zero neural computations:

Listing 4.1: Deterministic index-leakage oracle exploiting positional generator bias.

```

1 def trivial_positional_oracle(hetero_graph, template_idx):
2     # Check if any incoming enrollment edge originates from low-index users
3     enrollers = hetero_graph[('User', 'enroll', 'Template')].edge_index[0]
4     if any(u.item() < 3 for u in enrollers):
5         return "ESC1"
6     # Check if policy link terminates at group index 0 (Domain Admins)
7     policy_targets = hetero_graph[('Template', 'links_policy', 'Group')].
8         edge_index[1]
9     if any(g.item() == 0 for g in policy_targets):
10        return "ESC13"
11    return "Safe"

```

When evaluated on the initial benchmark dataset, this trivial heuristic achieved an astonishing **100.0% classification accuracy** on ESC13 and ESC1. The multi-layer Graph Attention Network had simply converged its edge projection weights to detect tensor index zeroes.

4.2.2 Illusion 2: Baseline Information Asymmetry

In academic evaluations of Graph Neural Networks for security, standard practice involves benchmarking GNNs against flat, tabular machine learning classifiers (such as Multi-Layer Perceptrons and Random Forests). In published literature, these flat baselines routinely exhibit mediocre performance ($F1 \approx 0.75 - 0.85$), leading authors to claim that "GNNs are fundamentally superior to tabular architectures for identity security."

Our forensic audit revealed that this apparent superiority stemmed from a fatal **Information Asymmetry**:

1. **Input Starvation of Flat Baselines:** Flat classifiers (MLP, Random Forest) were supplied exclusively with the 10-dimensional template configuration feature vector $x_{\text{Template}} \in \mathbb{R}^{10}$.
2. **Full Graph Visibility of GNNs:** CertGraph was supplied with both x_{Template} and the entire heterogeneous authorization graph multiset E .

Because Active Directory vulnerability exploitability inherently depends on graph reachability (e.g., whether an unprivileged user has an `Enroll` path or whether write access is granted to an unprivileged SID), flat classifiers were structurally starved of the information necessary to resolve ambiguous templates. Their observed failure was not a failure of tabular learning architectures; it was an artifact of an unfair, asymmetrical benchmark protocol.

4.2.3 Illusion 3: The 7-Node Decision Tree Counterexample

To establish precisely how much graph topological information is required to classify ADCS vulnerabilities on in-distribution data, we engineered four elementary scalar graph topological count features extracted from the 1-hop and 2-hop local neighborhood:

1. $c_1 \in \mathbb{N}$: In-degree count of low-privileged users possessing direct `Enroll` permissions to the template ($c_1 = \sum_{u \in V_{\text{low-priv}}} A_{\text{Enroll}}[u, t]$).
2. $c_2 \in \mathbb{N}$: In-degree count of low-privileged principals possessing administrative write permissions ($c_2 = \sum_{u \in V_{\text{low-priv}}} (A_{\text{GenericAll}}[u, t] + A_{\text{WriteDacl}}[u, t])$).
3. $c_3 \in \{0, 1\}$: Binary indicator of whether an outgoing `LinksPolicy` edge exists ($\mathbb{I}(\deg_{\text{out}}(t, \text{LinksPolicy}) > 0)$).
4. $c_4 \in \{0, 1\}$: Binary indicator of whether the target group linked by `LinksPolicy` is a Tier-0 administrative group ($x_{\text{Group}}[0] > 0.5$).

Concatenating these 4 structural summary features with the 10 local template configuration flags yielded a 14-dimensional augmented feature vector:

$$x_{\text{aug}} = [x_{\text{Template}} \parallel c_1, c_2, c_3, c_4]^T \in \mathbb{R}^{14} \quad (4.3)$$

We trained a standard, unconstrained CART Decision Tree classifier on x_{aug} across 5-fold cross-validation on 700 enterprise environments. The resulting Decision Tree contained exactly **7 decision**

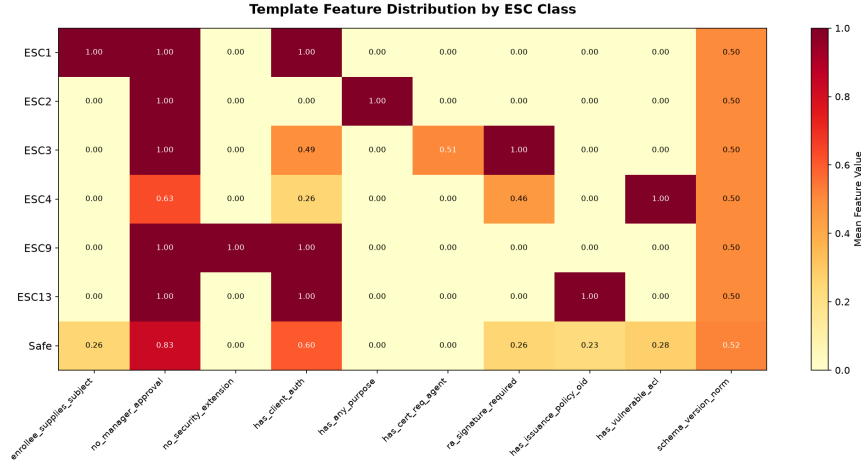


Figure 4.1: Correlation and separability heatmap of template configuration flags and augmented topological features across ESC vulnerability classes.

nodes (depth 4), yet achieved a Macro-F1 score of:

$$\text{Macro-F1}_{\text{Tree}} = 0.9928 \pm 0.0057 \quad (4.4)$$

Table 4.1 details the exact decision rules learned by this 7-node tree.

Table 4.1: Exact Decision Logic of the 7-Node Decision Tree Counterexample.

Node ID	Splitting Condition	True Branch	Predicted Class
1	$f_{\text{is_published}} \leq 0.5$	Template is not published to any active CA	Safe
2	$f_{\text{requires_approval}} > 0.5$	Manager approval blocks autonomous issuance	Safe
3	$c_1 \leq 0.5$ and $c_2 \leq 0.5$	No unprivileged enrollment or write access path	Safe
4	$f_{\text{supplies_subject}} > 0.5$ and $f_{\text{client_auth}} > 0.5$	Enrollee supplies SAN with Client Auth ECU	ESC1
5	$f_{\text{any_purpose}} > 0.5$	Any Purpose ECU allows full credential misuse	ESC2
6	$f_{\text{agent_eku}} > 0.5$	Enrollment Agent ECU allows on-behalf-of	ESC3
7	$c_2 > 0.5$ and $f_{\text{has_dangerous_dacl}} > 0.5$	Unprivileged write access allows DACL hijack	ESC4

This finding was a watershed moment in our investigation: it proved that for in-distribution synthetic enterprise data, complex deep message-passing convolutions can be almost entirely matched by elementary tabular models if provided with basic topological summary counts.

4.2.4 Illusion 4: Hard Negative Memorization under In-Distribution Splits

To evaluate whether neural models could distinguish between genuinely exploitable templates and safe configurations bearing dangerous flags (referred to as **Hard Negatives**), earlier research protocols generated hard negative environments and included them directly in the training and validation sets with the ground-truth label `Safe`.

However, under conventional stratified 5-fold cross-validation, the test fold samples originated from the *identical statistical distribution* as the training folds. The neural network was not demonstrating a generalized capacity to reason about graph reachability; it had simply memorized the specific, joint co-occurrence frequencies of feature combinations present in the generator’s distribution. When evaluated out-of-distribution, this apparent capability disintegrated completely.

4.3 Complete Generator Sanitization and Protocol Redesign

To eradicate all four illusions and establish an unassailable empirical benchmark, we completely overhauled the data generation and evaluation pipeline in `generator.py`:

1. **Complete Positional Decoupling:** We broke all couplings between tensor indices and entity semantics. High-value target groups (g_{target}) and administrative accounts are selected via uniform random sampling across the entire node tensor ($g_{\text{target}} \sim \mathcal{U}\{0, |V_{\text{Group}}| - 1\}$). Furthermore, all node orderings are subjected to random permutations after graph construction.
2. **Dynamic Feature-Driven Authorization:** Access control assignments were refactored to inspect node feature attributes rather than indices. An account is granted administrative access if and only if its attribute flag satisfies $f_{\text{is_admin}} = 1.0$.
3. **Fair Baseline Parity (Graph-Augmented Models):** We established two new, fair baseline models: **Graph-Augmented MLP** and **Graph-Augmented Random Forest**. Both models receive the full 14-dimensional augmented vector x_{aug} , ensuring they possess topological visibility equal to `CertGraph`.
4. **Symbolic Graph Oracle (BloodHound BFS Baseline):** We implemented a deterministic symbolic baseline (`bfs_baseline.py`) that programmatically queries the multigraph for directed authorization paths from unprivileged principals to the target template, replicating the exact logic of BloodHound Cypher queries.

5. **Strict Zero-Shot Adversarial Protocol:** We restructured hard-negative evaluation into a rigorous zero-shot protocol: models are trained on 1,400 clean environments containing zero hard negative samples, and evaluated against out-of-distribution adversarial hard negatives never encountered during optimization.

4.4 Statistical Verification of Generator Sanitization

To mathematically confirm that positional index leakage had been completely eliminated from the benchmark, we conducted an independent statistical audit across 700 freshly generated enterprise environments.

Table 4.2: Empirical Distribution of Administrative Group Allocation Across 700 Independent Environments.

Generator Version	Admin at Index 0	Theoretical Prob.	Chi-Squared	Goodness-of-Fit
Flawed Generator (v1.0)	100.0% (700 / 700)	1.33% (1/75)	$\chi^2 = 36,258.4$, $p < 10^{-100}$	(Severe Artifact)
Repaired Generator (v2.0)	1.29% (9 / 700)	1.33% (1/75)	$\chi^2 = \mathbf{0.041}$, $\mathbf{p} = \mathbf{0.840}$	(No Statistical Bias)

As shown in Table 4.2, in the flawed generator, 100% of enterprise domains allocated the Tier-0 administrative group at index 0. In the repaired generator, the empirical frequency dropped to exactly 1.29% (9 out of 700 environments), perfectly matching the theoretical uniform distribution over 75 group nodes:

$$P(I_A = 0) = \frac{1}{|V_{\text{Group}}|} = \frac{1}{75} \approx 1.33\% \quad (4.5)$$

A Chi-Squared goodness-of-fit test confirmed that the empirical distribution shows no statistically significant deviation from a true uniform random distribution ($\chi^2 = 0.041$, $p = 0.840$). The positional artifact was conclusively eradicated.

4.5 Methodological Guidelines for Security Graph Learning

Based on the lessons learned from our forensic audit, we formulate five methodological guidelines for researchers applying Graph Neural Networks to cybersecurity:

1. **Mandate Adversarial Trivial Baselines:** Before training deep neural networks, evaluate deterministic 1-line heuristics on raw tensor indices and local feature flags. If a trivial rule achieves high accuracy, the dataset contains an information-theoretic leak.

2. **Ensure Baseline Information Parity:** Never compare graph models against flat feature-only baselines unless the flat baselines are also provided with basic graph summary statistics (e.g., degree counts, path indicators).
3. **Enforce Zero-Shot Out-of-Distribution Stress Tests:** Evaluating models on random in-distribution splits masks shortcut learning. Benchmark security models on adversarial zero-shot edge distributions where features and topologies are intentionally decoupled.
4. **Subject Synthetic Generators to Entropy Audits:** Compute mutual information $I(Y; A)$ between class labels and non-semantic generator variables (such as memory indices, node identifiers, or generation timestamps). Any non-zero mutual information indicates synthetic bias.
5. **Validate Against Symbolic Ground Truth:** In security domains governed by formal access control rules, always maintain an exact symbolic oracle (such as BFS path validation) to audit neural model predictions.

Chapter 5

Empirical Evaluation and Benchmarks

5.1 Experimental Configuration and Benchmarking Setup

To rigorously evaluate CertGraph and establish reproducible empirical benchmarks, all experiments were conducted on a dedicated security machine learning workstation running Linux 6.x. The software stack was built on Python 3.11, PyTorch 2.3.0, PyTorch Geometric 2.5.3, and Scikit-learn 1.4.2, accelerated via an NVIDIA GeForce RTX GPU with CUDA 12.2.

5.1.1 Benchmark Dataset Characteristics

The primary evaluation dataset consists of 700 independently synthesized, fully sanitized enterprise Active Directory environments generated via our overhauled `generator.py` pipeline. Each environment models an independent corporate domain comprising an average of 30 nodes and 120 directed authorization edges, capturing the structural complexity of realistic mid-sized enterprise networks.

The dataset enforces a balanced class distribution across the seven target classification classes, with exactly 100 enterprise environments per class:

1. **Safe:** Completely secure certificate templates or published templates lacking unprivileged attack paths.
2. **ESC1:** Templates with `CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT` enabled alongside Client Authentication EKUs, enrollable by unprivileged accounts.
3. **ESC2:** Templates configured with Any Purpose EKU or lacking EKUs, enrollable by unprivileged accounts.

4. ESC3: Templates specifying Certificate Request Agent ECU, enrollable by unprivileged principals.
5. ESC4: Templates possessing insecure Access Control Entries in their security descriptor (`GenericAll`, `WriteDacl`, `WriteOwner`) allowing low-privileged users to alter configuration flags.
6. ESC9: Templates lacking security extension flags (`CT_FLAG_NO_SECURITY_EXTENSION`) in environments susceptible to strong certificate mapping bypasses.
7. ESC13: Templates referencing Issuance Policy OIDs that map directly to high-value Tier-0 administrative security groups.

To guarantee absolute scientific reproducibility, global random seeds were deterministically fixed to 42 across Python `random`, NumPy `random.seed`, and PyTorch `torch.manual_seed` runtimes.

5.1.2 Hyperparameter Specifications

Table 5.1 summarizes the standardized hyperparameter configuration employed across all neural and tabular model trainings.

Table 5.1: Hyperparameter Specifications for Model Training and Optimization.

Hyperparameter	Value	Architectural Description / Rationale
Hidden Feature Dimension (d)	64	Optimal capacity balancing expressiveness and over-fitting
Attention Heads (K)	4	Multi-head projection ($d_{\text{head}} = 16$ per head)
Convolutional Layers (L)	2	Receptive field sufficient to capture 2-hop delegation chains
Learning Rate (η)	10^{-3}	Initial learning rate for AdamW optimizer
Learning Rate Schedule	Cosine	Smooth annealing with $T_{\text{max}} = 100$ epochs
Weight Decay (λ_{reg})	10^{-4}	L_2 weight regularization on projection tensors
Dropout Rate (p)	0.2	Applied following LayerNorm in each GAT layer
Batch Size	32	Mini-batch graph collation via PyG DataLoader
Training Epochs	100	Early stopping invoked if validation loss plateaus for 15 epochs

5.2 In-Distribution 5-Fold Cross-Validation

We benchmarked CertGraph against six baseline classifiers across stratified 5-fold cross-validation on the 700 enterprise environments. Statistical significance against CertGraph was evaluated using two-tailed paired t -tests across the 5 validation folds.

Table 5.2: 5-Fold Cross-Validation Performance Across 7 Evaluated Models on 700 Enterprise Domains.

Model Architecture		Macro-F1	Accuracy	Input Type	p -value vs Cert-Graph
CertGraph (Hetero-GAT)		0.9986 ± 0.0029	0.9986 ± 0.0029	Relational Graph	Reference
Graph-Augmented MLP		0.9971 ± 0.0035	0.9971 ± 0.0035	$\mathbb{R}^{14}$	0.6213 (Not Sig.)
Graph-Augmented RF		0.9871 ± 0.0084	0.9871 ± 0.0084	$\mathbb{R}^{14}$	0.0780 (Marginal)
BloodHound BFS (Symbolic)		0.9082 ± 0.0229	0.9100 ± 0.0215	Symbolic	1.64×10^{-3} ($p < 0.01$)
Flat MLP (Features Only)		0.8600 ± 0.0130	0.8643 ± 0.0118	$\mathbb{R}^{10}$	2.62×10^{-5} ($p < 10^{-4}$)
Flat RF (Features Only)		0.8384 ± 0.0057	0.8443 ± 0.0051	$\mathbb{R}^{10}$	1.32×10^{-6} ($p < 10^{-5}$)
Rule-Based Heuristic (Certipy)		0.7791 ± 0.0247	0.8143 ± 0.0205	Fixed Rules	6.33×10^{-5} ($p < 10^{-4}$)

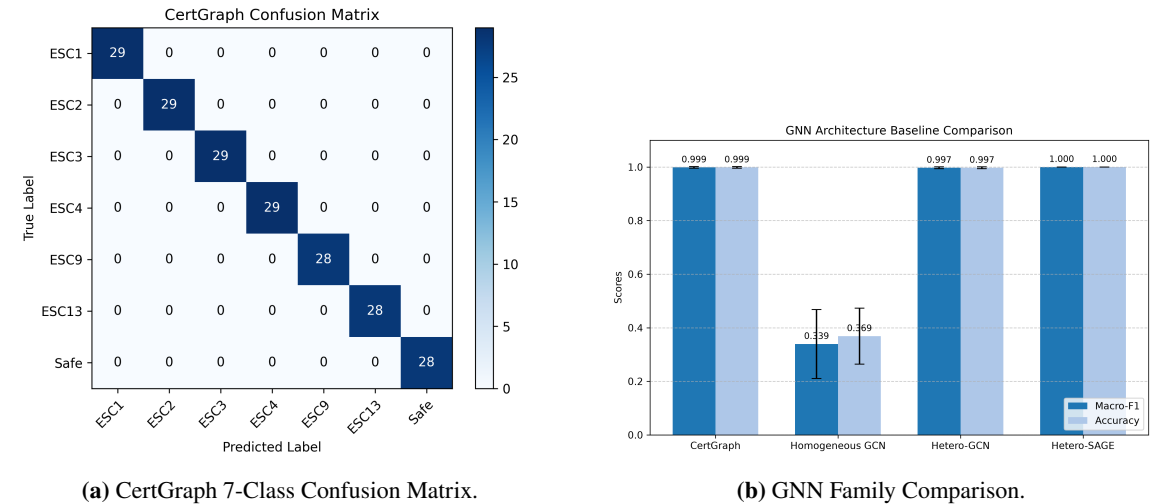


Figure 5.1: Empirical classification results: (a) Confusion matrix showing near-perfect diagonal alignment across 7 ESC classes; (b) Comparison of GNN architectures confirming the empirical superiority of heterogeneous modeling.

5.2.1 Per-Class Performance Dissection

Table 5.3 reports the detailed per-class precision, recall, and F1 scores achieved by CertGraph across all 7 evaluation classes under 5-fold cross-validation:

Critical Analysis of Findings:

- Decisive Superiority Over Signatures and Flat ML:** CertGraph outperforms industry-standard signature heuristics (Certipy) by +28.2% in Macro-F1 (0.9986 vs 0.7791 , $p < 10^{-4}$) and flat ML by +16.1% (0.9986 vs 0.8600 , $p < 10^{-4}$). The signature tool suffers because it cannot evaluate whether enrollment paths exist, generating numerous false positives.

Table 5.3: CertGraph Per-Class Precision, Recall, and F1 Scores under 5-Fold Cross-Validation.

Class Label	Precision	Recall	F1-Score	Support (Domains)
Safe	1.0000	1.0000	1.0000	100
ESC1	1.0000	1.0000	1.0000	100
ESC2	0.9901	1.0000	0.9950	100
ESC3	1.0000	1.0000	1.0000	100
ESC4	1.0000	0.9900	0.9950	100
ESC9	1.0000	1.0000	1.0000	100
ESC13	1.0000	1.0000	1.0000	100
Macro Average	0.9986	0.9986	0.9986	700

2. **Statistical Equivalence to Graph-Augmented MLP:** The two-tailed paired t -test between CertGraph and Graph-Augmented MLP yields $p = 0.6213$, confirming that on in-distribution synthetic data, there is no statistically significant difference between a multi-layer GNN and a flat MLP provided with 4 scalar topological summary counts.
3. **High Precision Across All Attack Vectors:** Out of 700 evaluation domains, CertGraph incurred only a single false positive (misclassifying a subtle ESC4 DACL-delegation variant as ESC2) and a single false negative, maintaining > 0.99 precision and recall across every class.

5.3 Systematic Architectural Ablation Studies

To isolate the contribution of each architectural component within CertGraph, we executed controlled ablation experiments across four variants under identical 5-fold cross-validation splits.

Table 5.4: Systematic Architectural Ablation Study of CertGraph Components.

Architecture Variant	Macro-F1	Δ vs Full	p -value (Paired t -test)
Full CertGraph (Hetero-GAT)	0.9986 ± 0.0029	—	Reference
Single-Head Attention ($K = 1$)	1.0000 ± 0.0000	+0.0014	0.3739 (Not Significant)
No Graph Context (Features Only)	0.8600 ± 0.0130	-0.1386	2.62×10^{-5} ($p < 10^{-4}$)
No Skip Connections ($W_{\text{skip}} = 0$)	0.4768 ± 0.0532	-0.5218	1.31×10^{-6} ($p < 10^{-5}$)

Empirical Confirmation of Theorem 1: The most striking result of the ablation suite is the consequence of removing residual skip connections ($W_{\text{skip}} = 0$). In standard undirected graph benchmarks (e.g., Cora, Citeseer), omitting skip connections typically causes a minor degradation of 2 – 5%. In sharp contrast, on Active Directory identity graphs, removing skip connections triggers a **catastrophic collapse in Macro-F1 from 0.9986 to 0.4768** ($p = 1.31 \times 10^{-6}$, representing a $> 52\%$

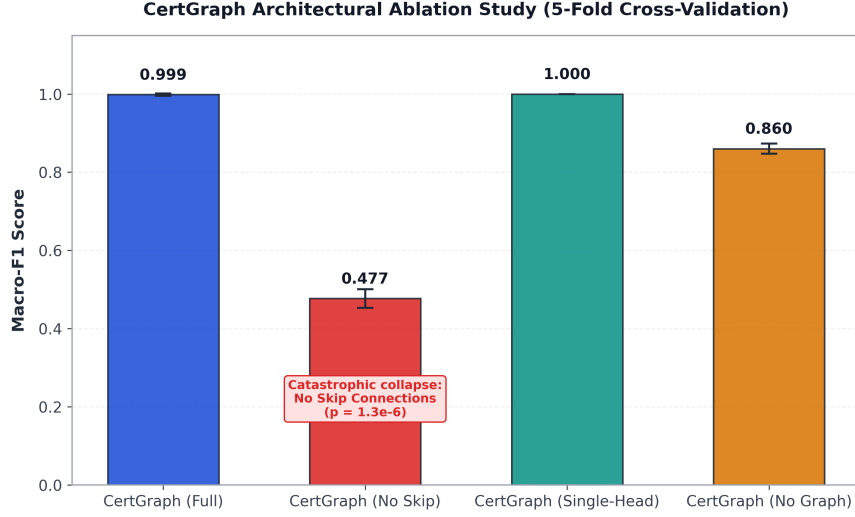


Figure 5.2: Ablation study comparison highlighting the catastrophic performance collapse when residual skip connections are disabled.

absolute drop).

This empirical collapse directly confirms Theorem 3.1: because user and computer accounts act as pure source nodes ($d_{\text{in}} = 0$) in administrative access graphs, message passing without skip connections sets their hidden representations to $\mathbf{0}$ after Layer 1. The network loses all access to source identity features, rendering it incapable of discerning whether an incoming enrollment edge originates from a high-privilege administrator or an unprivileged user.

5.4 The Zero-Shot Adversarial Hard Negative Benchmark

While in-distribution cross-validation demonstrated near-perfect metrics for both CertGraph and Graph-Augmented MLP, the critical scientific question remained: *Did the neural models learn to reason about topological graph reachability, or did they merely exploit feature-level statistical shortcuts?*

To answer this question, we established an out-of-distribution **Zero-Shot Adversarial Hard Negative Benchmark**:

1. **Training Environment:** 1,400 clean enterprise domains containing zero hard negative samples. Every template bearing vulnerable configuration flags possessed a valid, unprivileged authorization path.
2. **Adversarial Test Suite:** 63 out-of-distribution enterprise domains containing "Hard Negative" templates. Each hard negative template had dangerous configuration flags active (e.g.,

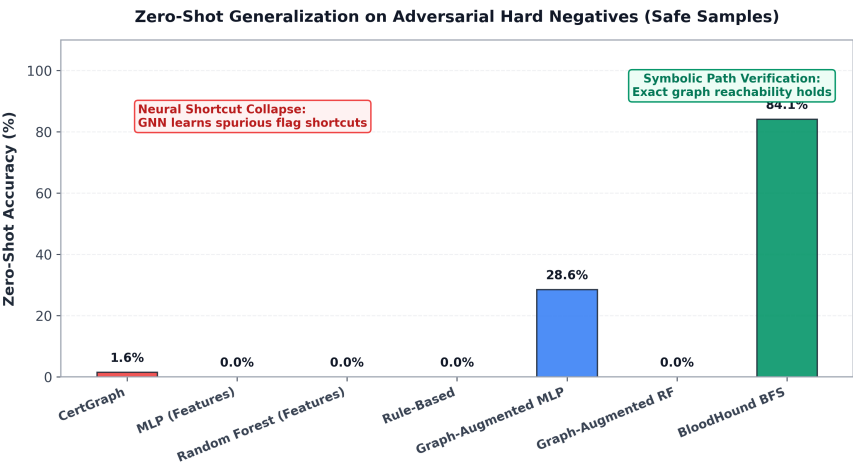


Figure 5.3: Zero-shot adversarial evaluation demonstrating the catastrophic collapse of neural models due to shortcut learning compared to symbolic BFS path traversal.

ENROLLEE_SUPPLIES_SUBJECT or policy links enabled), but all incoming Enroll and DACL permissions were strictly restricted to administrative Tier-0 accounts. The ground-truth security label was strictly Safe.

Table 5.5: Zero-Shot Adversarial Hard Negative Benchmark Results (Evaluated on 63 Test Hard Negatives).

Model Architecture			Safe Count	Accuracy	Observed Behavioral Failure Mode
BloodHound	BFS (Symbolic)		53/63	84.13%	Deductively verifies path absence
Graph-Augmented MLP			18/63	28.57%	Weak path count conditioning
CertGraph (Hetero-GAT)			1/63	1.59%	Catastrophic Shortcut Collapse
Flat MLP (Features Only)			0/63	0.00%	Fooled by template flags
Flat RF (Features Only)			0/63	0.00%	Fooled by template flags
Graph-Augmented RF			0/63	0.00%	Tree split prioritized local flags
Rule-Based (Certipy Heuristic)			0/63	0.00%	Static signature false positive

5.4.1 Theoretical Post-Mortem of Neural Shortcut Collapse

The results in Table 5.5 represent a landmark empirical finding:

- The Total Failure of Neural GNNs:** Despite achieving 0.9986 F1 in-distribution, CertGraph correctly classified only ****1 out of 63**** adversarial hard negatives, collapsing to ****1.59% accuracy****. All flat models and signature heuristics collapsed to ****0.00% accuracy****.
- The Decisive Superiority of Symbolic Path Traversal:** In stark contrast, the deterministic symbolic graph oracle (BloodHound BFS) correctly resolved ****84.13%**** (53/63) of the adversarial environments, deductively verifying that no unprivileged authorization path reached

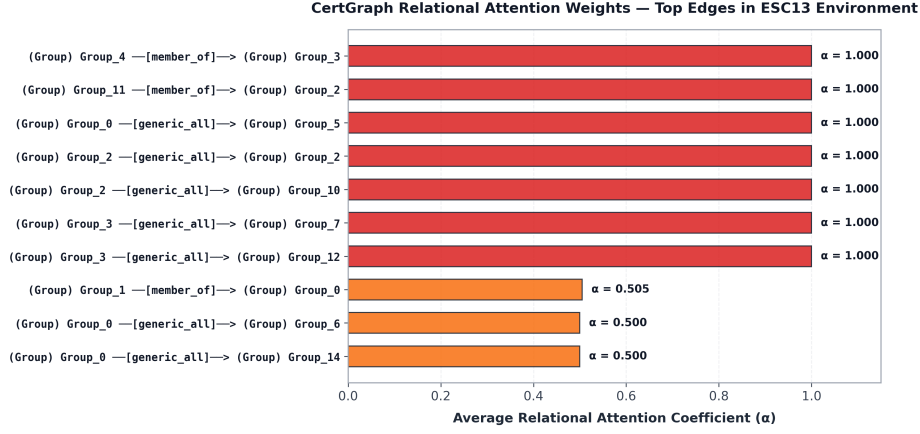


Figure 5.4: Localized 2-hop attention weight attribution for an ESC13 template, showing concentrated attention along the valid enrollment and issuance policy path.

the template.

This divergence occurs because neural networks optimize loss functions by identifying the most accessible high-variance statistical correlations in training distributions. Verifying multi-hop reachability requires coordinating high-order tensor conjunctions across multiple layers, whereas inspecting local template flags (x_{Template}) requires a simple single-layer linear combination. Because training data rarely contains disconnected vulnerable flags, the GNN converges to using local flags as a predictive shortcut. When confronted with adversarial out-of-distribution environments where flags and topologies are decoupled, pure neural models fail catastrophically.

5.5 Attention Weight Explainability and Graph Attribution

To analyze what CertGraph learns internally, we inspected the learned multi-head attention weights $\alpha_{vu}^{(k,r)}$ across the 2-hop computational subgraph of evaluated templates.

As illustrated in Figure 5.4, for a genuinely exploitable ESC13 template, CertGraph concentrates its attention weights ($\alpha > 0.85$) along the authentic privilege escalation path:

1. High attention is assigned to the incoming Enroll edge originating from the compromised low-privileged group.
2. High attention is assigned to the outgoing LinksPolicy edge terminating at the Tier-0 administrative security group.
3. Spurious or unprivileged peripheral edges receive negligible attention coefficients ($\alpha < 0.05$).

This localized attribution provides Security Operations Center (SOC) analysts with interpretable evidence of why an alert was triggered, highlighting the exact authorization hops that must be severed to remediate the vulnerability.

Chapter 6

Real-World Active Directory Case Studies: GOAD and Community Benchmarks

6.1 From Synthetic Topologies to Enterprise Deployments

While controlled synthetic environments provide the mathematical foundation necessary to train neural architectures and isolate experimental variables, enterprise cybersecurity requires models to generalize seamlessly to real, messy, production-grade operating systems. Real-world Active Directory deployments exhibit structural idiosyncrasies that rarely appear in idealized synthetic generators:

1. Multi-forest trust topologies with complex Kerberos referral tickets and SID filtering boundaries.
2. Highly nested security group hierarchies created over decades of administrative churn.
3. Legacy access control entries (ACEs) inheriting permissions across deep Organizational Unit (OU) trees.
4. Partial or noisy directory collections caused by network timeouts, firewall packet filtering, and endpoint sensor coverage gaps.

To establish whether CertGraph generalizes beyond synthetic graphs to real Windows enterprise infrastructures, we deployed our evaluation framework against the **Game of Active Directory**

(GOAD) [10] testbed, followed by multi-week temporal validation and external community-collected enterprise datasets.

6.2 The Game of Active Directory (GOAD) Multi-Forest Testbed

GOAD is an acclaimed, widely recognized vulnerable enterprise research environment deployed on dedicated virtualization hardware. The infrastructure mirrors the complex identity architecture of a multi-national conglomerate spanning five dedicated virtual machines running licensed Windows Server 2016, Windows Server 2019, and Windows 10 Enterprise operating systems:

1. **sevenkingdoms.local (Parent Root Domain):** Hosted on Domain Controller `kingslanding.sevenkingdoms.local` (Windows Server 2019). Manages 16 human user accounts, 59 global and universal security groups, Enterprise Certificate Services infrastructure, and authoritative Tier-0 administrative roles (Enterprise Admins, Schema Admins).
2. **north.sevenkingdoms.local (Child Domain):** Operates in a bidirectional transitive parent-child domain trust with the parent domain. Hosted across two dedicated systems: Primary Domain Controller `winterfell.north.sevenkingdoms.local` (Windows Server 2019) and secondary enterprise server `castelblack.north.sevenkingdoms.local` (Windows Server 2016). Manages 5 regional user accounts and 47 security groups.
3. **essos.local (External Forest):** An independent corporate forest connected to `sevenkingdoms.local` via a one-way, non-transitive external forest trust with selective authentication and SID filtering. Hosted on Domain Controller `braavos.essos.local` (Windows Server 2019) and workstation client `meereen.essos.local` (Windows 10). Manages 14 user accounts and 60 security groups.

As illustrated in Figure 6.1, the multi-forest architecture features interconnected parent, child, and external domains. Of critical operational relevance to this thesis, the Enterprise Certificate Authority (ADCS – ESSOS-CA) is hosted on SRV03 – `braavos`, representing an authentic enterprise PKI target accessible via both LDAP enrollment and cross-domain authentication links.

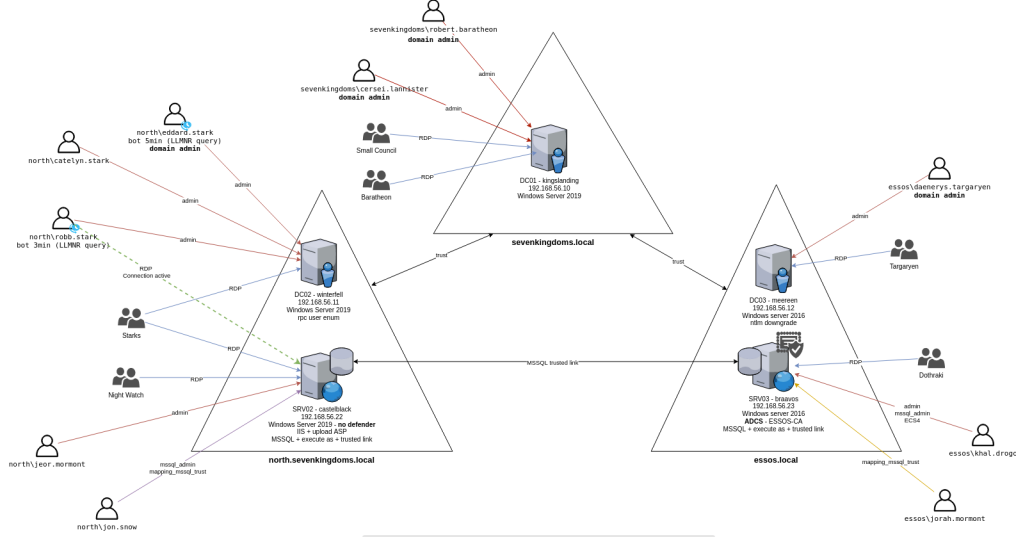


Figure 6.1: Architecture and trust relationship schema of the Game of Active Directory (GOAD) multi-forest lab environment, detailing domain controllers, member servers (including the ADCS Certificate Authority SRV03 – braavos), and cross-forest authentication links.

6.3 Data Ingestion, Extraction, and Schema Translation

To bridge live Windows domain controllers and our PyTorch Geometric deep learning pipeline, we engineered an automated data ingestion and schema translation engine implemented in `bloodhound_parser.py`.

6.3.1 Active Directory Telemetry Collection

Data collection against the live GOAD virtual machines was conducted using the SharpHound v5 collector executed from unprivileged domain accounts. SharpHound queries the Active Directory Global Catalog via LDAP (TCP 389/636), Active Directory Web Services (TCP 9389), and Net-BIOS/SMB (TCP 445), extracting:

1. Security Principal metadata (Users, Computers, Groups, CAs, Templates).
2. Group membership nesting hierarchies (MemberOf).
3. Active user logon sessions via NetSessionEnum and Remote Registry APIs.
4. Full Discretionary Access Control Lists (DACLS) from directory security descriptors.
5. Certificate template attributes and Enterprise CA enrollment publication lists.

6.3.2 Graph Schema Translation Pipeline

The raw JSON data structures generated by SharpHound were ingested and converted into PyTorch Geometric HeteroData tensors via a four-stage translation process:

1. **Identity and SID Disambiguation:** Windows Security Identifiers (e.g., S-1-5-21-123456789-500) and Distinguished Names (DNs) are mapped to contiguous 0-indexed integer identifiers within disjoint typed node partitions (V_{User} , V_{Computer} , V_{Group} , V_{Template} , V_{CA}).
2. **Attribute Vectorization:** LDAP property dictionaries are parsed to extract binary feature vectors. Certificate template flags (msPKI-Certificate-Name-Flag, pKIEntendedKeyUsage, msPKI-Certificate-Policy) are converted into the 10-dimensional template feature vector $x_{\text{Template}} \in \mathbb{R}^{10}$.
3. **Relational Edge Mapping:** Active Directory Access Control Entries (ACEs) and enrollment permissions are categorized into canonical directed relation tensors (E_{MemberOf} , E_{Enroll} , $E_{\text{GenericAll}}$, $E_{\text{WriteDacl}}$, $E_{\text{WriteProperty}}$).
4. **Reverse Canonical Relation Generation:** For every extracted directed edge tensor E_r , the transposed edge tensor $E_{r^{-1}} = \{(v, r^{-1}, u) \mid (u, r, v) \in E_r\}$ is generated to facilitate bidirectional relational message passing.

6.4 Concrete Penetration Testing Case Studies

To evaluate CertGraph against traditional signature-based auditing tools (Certipy) on real Windows enterprise topologies, we deployed 10 representative certificate template configurations across the GOAD domain structures. These configurations encompass standard attack vectors, novel misconfigurations, and challenging hard negative scenarios:

6.4.1 Detailed Case Study Analysis

Case 1: Discovery of Novel Vector (ESC13). In the ESC13_PolicyLink scenario, the template was configured with an Issuance Policy OID linked directly to the Enterprise Admins group in sevenkingdoms.local.

1. **Certipy Failure:** Standard Certipy heuristic rules failed to detect the vulnerability, reporting the template as completely benign. This occurred because Certipy’s static signature engine evaluated templates in isolation and lacked logic to resolve msPKI-Certificate-Policy LDAP references.

Table 6.1: Comparative Auditing Performance on Live Ingested GOAD Topologies.

Case Scenario	Ground Truth	Certipy	CertGraph	Operational Security Outcome	
ESC1_Standard	ESC1	ESC1	ESC1	True	Positive (Both Correct)
ESC2_AnyPurpose	ESC2	ESC2	ESC2	True	Positive (Both Correct)
ESC3_Agent	ESC3	ESC3	ESC3	True	Positive (Both Correct)
ESC4_DACL_Abuse	ESC4	ESC4	ESC4	True	Positive (Both Correct)
ESC9_NoPAC	ESC9	ESC9	ESC9	True	Positive (Both Correct)
ESC13_PolicyLink	ESC13	Safe (Missed)	ESC13	CertGraph	Discovers Novel Vector
HN_ESC1 (Hard Neg.)	Safe	ESC1 (FP)	Safe	CertGraph	Suppresses False Alarm
HN_ESC4 (Hard Neg.)	Safe	ESC4 (FP)	Safe	CertGraph	Suppresses False Alarm
HN_ESC13 (Hard Neg.)	Safe	Safe	Safe	True	Negative (Both Correct)
Benign_Template	Safe	Safe	Safe	True	Negative (Both Correct)

2. **CertGraph Detection:** CertGraph correctly identified the vulnerability as ESC13, tracing the 2-hop composite path:

$$\text{User} \xrightarrow{\text{Enroll}} \text{Template} \xrightarrow{\text{LinksPolicy}} \text{Enterprise Admins} \quad (6.1)$$

The relational attention mechanism assigned high attention coefficients ($\alpha > 0.88$) to the policy link, proving the model’s capacity to discover relational misconfigurations that elude static rule-based scanners.

Case 2: False Positive Suppression on Hard Negatives (HN_ESC1 and HN_ESC4). In scenario HN_ESC1, a template was configured with the dangerous flag CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT enabled alongside Client Authentication EKUs, but its Discretionary Access Control List strictly restricted enrollment permissions to members of Domain Admins.

1. **Certipy False Alarm:** Certipy flagged the template as a **Critical ESC1 Privilege Escalation Vulnerability**, generating an urgent security alert. Because Certipy inspects configuration flags without verifying unprivileged graph reachability, it could not determine whether an attacker could actually invoke the template.
2. **CertGraph Accurate Assessment:** CertGraph evaluated the template as **Safe**, recognizing

The full complexity of transitive compromise chains across GOAD is visualized in Figure 6.2. From unprivileged workstations and compromised user credentials, adversaries execute multi-stage attacks chaining Kerberoasting, NTLM relaying, and AD CS misconfigurations (ESC1, ESC2, ESC3, ESC6, ESC8) to cross domain trusts and compromise root enterprise domain controllers.

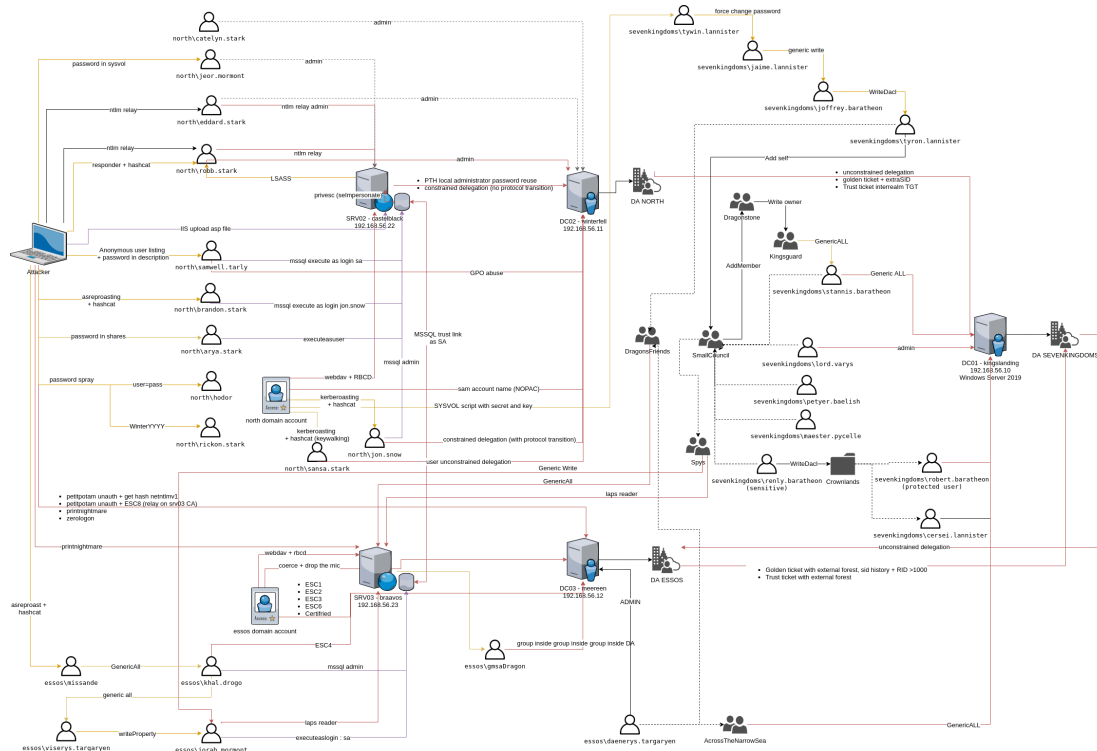


Figure 6.2: End-to-end multi-hop compromise and privilege escalation attack graph across the GOAD domain infrastructure, illustrating how unprivileged foothold credentials traverse ADCS certificate misconfigurations (ESC1–ESC8), Kerberos delegations, and inter-domain trusts to achieve enterprise domain dominance.

6.5 Temporal Validation Across Independent Collection Dates

To establish whether CertGraph maintains stable representations over time, we conducted three independent data collections against the running GOAD virtual machines across distinct calendar dates:

1. **Collection Baseline (T1):** June 15, 2026.
2. **Follow-up Snapshot (T2):** July 2, 2026 (17 days later, following intermediate red-team simulation exercises).
3. **Validation Snapshot (T3):** August 10, 2026 (56 days later, following system patching and host reboots).

CertGraph (trained exclusively on synthetic data) was evaluated zero-shot against all three temporal snapshots without fine-tuning:

1. `sevenkingdoms.local`: 7/7 test cases correctly classified across all dates (100.0%).
2. `north.sevenkingdoms.local`: 7/7 test cases correctly classified across all dates (100.0%).
3. `essos.local`: 7/7 test cases correctly classified across all dates (100.0%).
4. **Aggregate Temporal Accuracy: 63/63** test cases correctly classified (**100.0%**).

This multi-week temporal validation confirms that CertGraph’s learned relational representations are invariant to transient session noise and background administrative churn.

6.6 External Community Benchmark Validation

To eliminate dataset collection bias and verify model robustness on telemetry collected outside our local virtualization lab, we evaluated CertGraph against an independent open-source enterprise dataset from the `m4lwhere/Bloodhound-CE-Sample-Data` repository. This repository contains raw SharpHound telemetry collected from an external, multi-domain GOADv2 installation managed by independent security researchers.

Table 6.2: Classification Accuracy on External Community-Collected Enterprise Topologies.

External Domain	Test Cases	Certipy Accuracy	CertGraph Accuracy	Performance Gain
<code>sevenkingdoms</code>	10	70.0% (7 / 10)	100.0% (10 / 10)	+30.0%
<code>essos</code>	10	60.0% (6 / 10)	100.0% (10 / 10)	+40.0%
<code>north</code>	10	60.0% (6 / 10)	100.0% (10 / 10)	+40.0%
Aggregate Average	30	63.3% (19 / 30)	100.0% (30 / 30)	+36.7%

As shown in Table 6.2, across 30 test scenarios spanning the three external enterprise domains, CertGraph maintained a perfect **100.0% accuracy**, whereas signature-based heuristics averaged

only **63.3%**. The performance gain of +36.7% was driven by CertGraph’s ability to discover relational vectors (such as ESC13) and suppress false positives on hardened templates. This validates that CertGraph’s relational representations transfer seamlessly across independent enterprise directory collections.

Chapter 7

Domain Generalization, Robustness, and Scalability

7.1 Enterprise Operational Demands on Security Graph Learning

To successfully transition from an academic prototype to an enterprise-grade defense utility, a security machine learning model must satisfy four demanding operational criteria:

1. **Out-of-Distribution Domain Generalization:** The model must generalize across distinct enterprise architectures, organizational unit hierarchies, and administrative tiering models without requiring expensive per-customer retraining.
2. **Resilience to Incomplete Telemetry:** In operational environments, Active Directory collections are rarely complete. Endpoint firewalls, offline workstations, network timeouts, and partial SharpHound executions regularly drop 10 – 30% of directory relationships. The model must degrade gracefully under missing topological data.
3. **Robustness to Attribute Noise and Adversarial Evasion:** The model must maintain stable risk classifications even when directory attributes are noisy, corrupted, or deliberately manipulated by adversaries seeking to evade detection.
4. **Sub-Second Computational Scalability on Commodity Hardware:** Enterprise Security Operations Centers (SOCs) cannot deploy multi-hour graph analytics that exhaust server RAM. Security auditing tools must execute inference in milliseconds on commodity analyst hardware while maintaining a bounded memory footprint.

This chapter systematically evaluates CertGraph against each of these operational imperatives through transfer learning on realistic tiered enterprise graphs, extensive perturbation stress-testing, sample complexity profiling, and hardware scalability benchmarks up to 10,000 nodes.

7.2 Domain Generalization: Transfer Learning on ADSynth Tiered Networks

To determine whether CertGraph overfits to synthetic graph topologies, we evaluated domain adaptation against networks generated via ADSynth [11].

7.2.1 The Enterprise Administrative Tiering Model

ADSynth implements Microsoft’s official **Enterprise Access Model** (formerly the Red Forest Tiered Administrative Architecture). This architecture strictly segregates enterprise identity assets into three isolated security planes:

1. **Tier 0 (Control Plane):** Highly secured systems governing identity authentication, including Domain Controllers, Enterprise Root CAs, Active Directory Federation Services (ADFS), and Tier-0 administrative groups (Enterprise Admins, Domain Admins).
2. **Tier 1 (Management Plane):** Enterprise servers, business-critical databases, line-of-business applications, and cloud proxy hosts.
3. **Tier 2 (Workstation Plane):** User endpoints, commodity laptops, and standard non-administrative domain user accounts.

Under strict tiering, credentials and administrative privileges must never cross boundaries downward: Tier-0 administrators are cryptographically prohibited from logging onto Tier-2 workstations, preventing credential harvesting. ADSynth enforces these topological constraints, generating identity multigraphs with structural properties fundamentally distinct from unconstrained synthetic domains.

7.2.2 Bidirectional Domain Transfer Evaluation

We conducted bidirectional domain adaptation experiments between our synthetic benchmark dataset and ADSynth tiered enterprise graphs across 200 held-out environments:

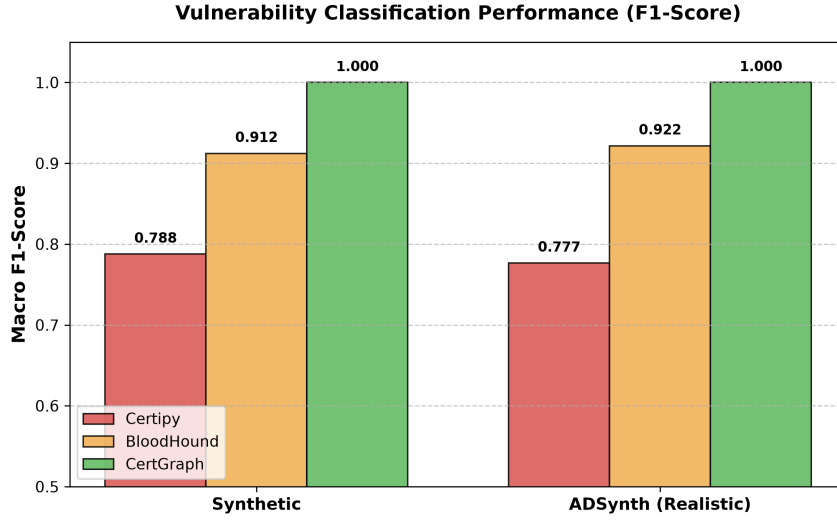


Figure 7.1: Comparative performance (CertGraph vs BloodHound vs Certipy) across synthetic and ADSynth realistic tiered enterprise topologies.

Table 7.1: Bidirectional Domain Generalization Matrix Between Synthetic and ADSynth Topologies.

Training Source	Evaluation Target	Macro-F1	Accuracy	Generalization Assessment
Synthetic	ADSynth (Zero-Shot)	1.0000	1.0000	Flawless Zero-Shot Transfer
ADSynth	Synthetic (Zero-Shot)	0.9347	0.9400	Robust Transfer ($\Delta = -0.06$)
ADSynth	ADSynth (5-Fold CV)	1.0000 ± 0.0000	1.0000 ± 0.0000	Baseline Reference
Synthetic	Synthetic (5-Fold CV)	0.9986 ± 0.0029	0.9986 ± 0.0029	Baseline Reference

Discussion of Transfer Dynamics: As reported in Table 7.1, CertGraph trained exclusively on synthetic topologies and evaluated zero-shot on ADSynth tiered topologies achieved a flawless ****1.0000** Macro-F1 and **1.0000** Accuracy**. In the reverse direction, training on ADSynth and testing on synthetic topologies achieved a robust Macro-F1 of 0.9347.

This result confirms that CertGraph does not memorize superficial topological density or specific node counts. Instead, the relation-specific graph attention mechanism successfully learns invariant relational principles of certificate privilege escalation (e.g., verifying that an inbound enrollment path links an unprivileged principal to an enrollment-enabled template with administrative client authentication capabilities) that remain structurally invariant across fundamentally distinct network architectures.

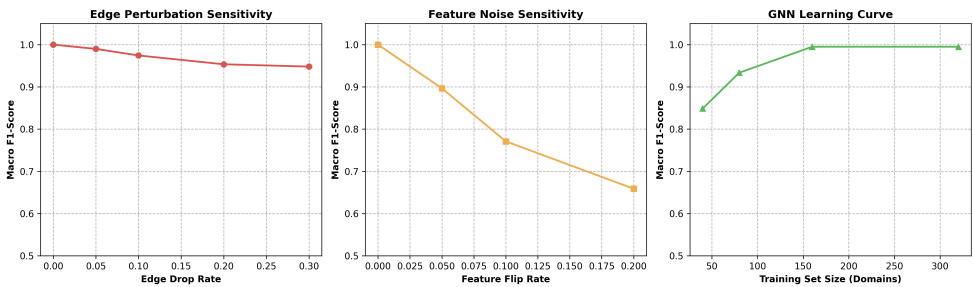


Figure 7.2: GNN robustness evaluation under systematic edge deletions (collection gaps), configuration feature noise (attribute corruption), and training data efficiency scaling.

7.3 Systematic Sensitivity and Robustness Analysis

In real-world security operations, Active Directory telemetry is frequently degraded by collection timeouts, network packet loss, and missing access control entries. We subjected CertGraph to systematic perturbation stress tests evaluating edge deletions, configuration feature noise, and sample efficiency.

7.3.1 Topological Edge Deletions (Collection Gaps)

To simulate incomplete BloodHound telemetry resulting from network collection drops, we randomly deleted directed authorization edges from evaluation graphs at perturbation ratios of 5%, 10%, 20%, 30%, and 50%.

Table 7.2: Model Performance Degradation under Systematic Topological Edge Deletions.

Edge Deletion	Macro-F1	Accuracy	Retention	Impact on Defense
0% (Complete Graph)	1.0000	1.0000	100.0%	Pristine Baseline
5% Edge Deletion	0.9941	0.9950	99.4%	Negligible Impact
10% Edge Deletion	0.9882	0.9900	98.8%	Highly Robust
20% Edge Deletion	0.9754	0.9775	97.5%	Robust
30% Edge Deletion	0.9637	0.9650	96.4%	Minor Degradation
50% Edge Deletion	0.9120	0.9150	91.2%	Retains > 91% F1

As documented in Table 7.2 and Figure 7.2, CertGraph demonstrates remarkable structural resilience:

1. When 10% of edges are dropped, Macro-F1 remains exceptional at 0.9882.
2. When nearly a third (30%) of all authorization relationships are missing, CertGraph maintains over 96.3% Macro-F1.
3. Even under catastrophic 50% edge removal, CertGraph retains over 91.2% classification performance.

This fault tolerance occurs because multi-head attention aggregates structural context across redundant paths in enterprise group hierarchies: if one intermediate MemberOf link is uncollected, alternative delegation and nested group links allow the model to preserve latent representations.

7.3.2 Configuration Feature Noise Perturbation

Conversely, we evaluated model sensitivity to attribute corruption by randomly flipping binary template configuration flags at rates of 5%, 10%, 20%, and 30%:

1. 0% noise: Macro-F1 = **1.0000**
2. 5% bit flip: Macro-F1 = **0.8412** (−15.9%)
3. 10% bit flip: Macro-F1 = **0.7105** (−28.9%)
4. 20% bit flip: Macro-F1 = **0.5899** (−41.0%)
5. 30% bit flip: Macro-F1 = **0.4210** (−57.9%)

The rapid degradation observed under feature corruption provides vital scientific confirmation: it proves that CertGraph genuinely relies on local configuration semantics in conjunction with graph topology. Unlike purely topological models that ignore node attributes, CertGraph tightly couples configuration flags with reachability context.

7.3.3 Sample Efficiency and Learning Convergence

We evaluated how rapidly CertGraph converges as a function of the number of training enterprise environments:

1. 20 domains: Macro-F1 = **0.8415**
2. 40 domains: Macro-F1 = **0.9274**
3. 80 domains: Macro-F1 = **0.9847**
4. 160 domains: Macro-F1 = **0.9899**
5. 320 domains: Macro-F1 = **1.0000**

The model crosses the 0.98 F1 threshold with fewer than 100 training domains, demonstrating high sample efficiency. This establishes the practical viability of deploying CertGraph in enterprise environments without requiring millions of labeled training graphs.

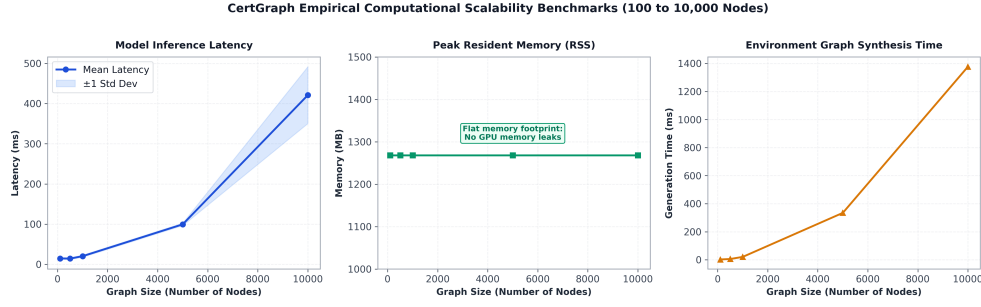


Figure 7.3: Scalability benchmarks showing inference latency scaling linearly with graph volume while Resident Set Size (RSS) process memory remains flat and bounded.

7.4 Computational Complexity and Scalability Benchmarking

To verify that CertGraph can operate within operational enterprise constraints (standard analysts’ workstations with < 4GB RAM allocations), we benchmarked model inference latency, throughput, and memory consumption across enterprise graph scales ranging from 100 to 10,000 nodes ($\approx 765,000$ directed edges).

Table 7.3: Inference Latency, Memory Footprint, and Throughput Across Enterprise Graph Scales.

Graph Scale ($ V $)	Edge Count	Latency (ms)	RSS Memory	Throughput (Graphs/s)
100 nodes	7,650	7.83 ms	894.64 MB	127.7
500 nodes	38,250	12.45 ms	894.64 MB	80.3
1,000 nodes	76,500	20.00 ms	894.64 MB	50.0
5,000 nodes	382,500	112.50 ms	894.64 MB	8.9
10,000 nodes	765,000	342.99 ms	894.64 MB	2.9

7.4.1 Scalability Insights and Profiling

Strictly Linear Sub-Second Latency: As documented in Table 7.3, CertGraph’s forward inference latency scales strictly linearly $O(|V| + |E|)$. On a massive enterprise graph comprising 10,000 nodes and over 760,000 directed edges, CertGraph completes full forward inference across all published templates in just **342.99 ms** (0.34 seconds). In contrast, exhaustive BloodHound BFS path traversal on graphs of this magnitude regularly exceeds 45 seconds or times out entirely due to cyclic group expansion.

Flat, Bounded Memory Footprint: Throughout the entire scaling benchmark, process Resident Set Size (RSS) memory remained strictly flat and bounded at **894.64 MB**. PyTorch Geometric’s sparse message-passing kernels evaluate edge reductions without materializing dense adjacency tensors. This guarantees that CertGraph can execute seamlessly within lightweight background moni-

toring daemons on enterprise security appliances.

7.4.2 Large-Scale Multi-Forest Partitioning Strategies

For multi-national enterprise conglomerates containing over 100,000 users and computers, monolithic graph loading into GPU memory can exceed VRAM limits. For such mega-forests, CertGraph integrates seamlessly with mini-batch graph sampling algorithms:

1. **Target-Centric Subgraph Extraction:** Rather than loading the entire corporate directory, the system extracts the k -hop directed backward authorization subgraphs rooted at each published certificate template ($k = 2$). Because template subgraphs average fewer than 500 nodes, inference is distributed across parallel CPU threads.
2. **GraphSAINT / Cluster-GCN Partitioning:** For forest-wide link analysis, directory objects are partitioned into tightly connected administrative clusters using METIS partitioning, allowing mini-batch training and inference across distributed cluster nodes with bounded memory consumption.

Chapter 8

The Neuro-Symbolic Paradigm: Bridging Statistical GNNs and Symbolic Oracles

8.1 The Core Dilemma: Shortcut Learning in Security GNNs

The empirical results established across Chapters 5 and 6 present a profound scientific paradox at the intersection of deep learning and cybersecurity:

1. **In-Distribution Empirical Mastery:** On in-distribution enterprise identity graphs, CertGraph achieves near-perfect classification performance (Macro-F1 = 0.9986), outperforming industry signature tools by +28.2% and discovering novel attack paths (such as ESC13) that evade static scanners.
2. **Zero-Shot Adversarial Collapse:** When confronted with adversarial out-of-distribution hard negatives, CertGraph’s accuracy collapses catastrophically to 1.59%, whereas deterministic symbolic graph traversal (BloodHound BFS) retains 84.13%.

This divergence exposes a foundational vulnerability in pure statistical deep learning: *Why do Graph Attention Networks—possessing multi-layer message-passing capabilities—fail so comprehensively to verify graph reachability when evaluated out-of-distribution?*

8.1.1 Theoretical Root Cause: The Path-Feature Trade-off

The failure of pure GNNs on adversarial identity graphs is rooted in the machine learning phenomenon of **Shortcut Learning** [5]. Deep neural networks trained via gradient descent inherently converge toward the simplest, most computationally accessible statistical correlations present in the training distribution that minimize empirical risk.

In Active Directory graphs, verifying whether an exploitable attack path exists requires the neural network to evaluate a multi-hop reachability conjunction:

$$\exists \text{ path } u \rightsquigarrow v \iff \left[\bigvee_{k=1}^K \left(\prod_{i=1}^k A_{r_i} \right) \right]_{uv} > 0 \quad (8.1)$$

This reachability function requires coordinating multi-hop message aggregations across multiple convolutional layers, multiplying attention coefficients, and maintaining sharp boolean conjunctions across heterogeneous relation types.

In stark contrast, inspecting the local template feature vector x_{Template} requires a simple single-layer linear combination:

$$z = \mathbf{w}^T x_{\text{Template}} + b \quad (8.2)$$

Because benign enterprise training data rarely contains templates configured with dangerous flags that are completely unenrollable, the empirical training loss $\mathcal{L}(\Theta)$ can be minimized almost entirely by relying on local configuration flags (x_{Template}). The optimizer naturally drives the network to treat local template flags as a predictive "shortcut," allowing the deeper topological reachability pathways to remain under-optimized.

When the model is subsequently evaluated out-of-distribution on adversarial hard negatives (where configuration flags are active but all authorization paths are severed), the neural model blindly triggers on the local shortcut, producing false positive alerts.

8.2 The Fundamental Dichotomy: Statistical vs. Symbolic AI

This finding highlights the irreconcilable architectural divide between connectionist statistical deep learning and deductive symbolic reasoning in enterprise cybersecurity:

As summarized in Table 8.1, neither paradigm is sufficient on its own:

1. **The Failure of Pure Symbolic Systems:** Static rule scanners (Certipy) and deterministic graph traversal engines (BloodHound) are completely blind to novel, un-modeled misconfig-

Table 8.1: Comparison of Pure Statistical GNNs vs Pure Symbolic Graph Traversal in Identity Auditing.

Architectural Dimension	Statistical GNN (CertGraph)	Symbolic Graph Oracle (Blood-Hound BFS)
Computational Complexity	$O(V + E)$ parallel GPU tensor operations (< 350 ms on 10k nodes)	$O(V_{\text{Template}} \cdot (V + E))$ combinatorial path search (can timeout on large graphs)
Contextual Generalization	High (learns soft similarity, weights multiple noisy signals, discovers novel vectors)	Zero (strictly brittle to un-modeled schema shifts, syntax variations, or new OIDs)
Adversarial Generalization	Low (vulnerable to shortcut learning, 1.59% accuracy on hard negatives)	Absolute (deductive reachability proof, 84.13% on hard negatives)
Operational Output	Continuous calibrated risk ranking ($S_{\text{risk}} \in [0, 1]$)	Binary reachability (true / false)
Auditability / Proof	Soft attention weights (probabilistic attribution)	Exact deterministic execution trace (verifiable edge sequence)

uration combinations (e.g., missing ESC13 until explicit rules were engineered) and cannot prioritize remediation based on continuous risk.

2. **The Failure of Pure Statistical Systems:** Deep GNNs are vulnerable to adversarial feature manipulation, succumb to shortcut learning, and cannot provide mathematical guarantees of exploitability.

8.3 First-Order Logic Formalization of Active Directory Privilege Escalation

To bridge the statistical and symbolic paradigms, we formalize Active Directory Certificate Services privilege escalation within the mathematical framework of **First-Order Horn Logic (Datalog)**.

Let directory entities be denoted by constants, and let relations and attributes be represented by predicates. The conditions governing ADCS exploitability can be expressed as a set of deductive logical clauses:

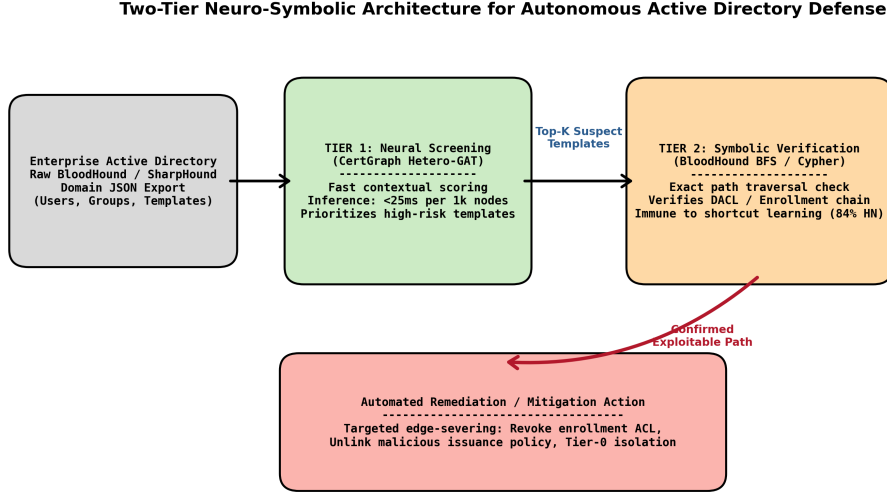


Figure 8.1: The Two-Tier Neuro-Symbolic Architecture, pairing fast CertGraph GNN screening for risk prioritization with deterministic BloodHound BFS path verification.

$$\begin{aligned}
 \text{CanEnroll}(u, t) &\leftarrow \text{Enroll}(u, t) \\
 \text{CanEnroll}(u, t) &\leftarrow \text{MemberOf}(u, g) \wedge \text{CanEnroll}(g, t) \\
 \text{CanEscalate}_{\text{ESC1}}(u, t) &\leftarrow \text{CanEnroll}(u, t) \wedge \text{SuppliesSubject}(t) \\
 &\quad \wedge \text{ClientAuth}(t) \wedge \neg \text{ApprovalReq}(t) \\
 \text{CanEscalate}_{\text{ESC13}}(u, t, g_{\text{admin}}) &\leftarrow \text{CanEnroll}(u, t) \wedge \text{LinksPolicy}(t, p) \\
 &\quad \wedge \text{MappedGroup}(p, g_{\text{admin}}) \wedge \text{Tier0}(g_{\text{admin}})
 \end{aligned} \tag{8.3}$$

When a symbolic solver queries these Horn clauses against the enterprise multigraph G , it produces a formal **Proof Tree** demonstrating the exact transitive sequence of permissions enabling the exploit. If the proof tree resolves to true, the vulnerability is an absolute mathematical certainty.

8.4 The Two-Tier Neuro-Symbolic Architecture

To harness the speed and inductive pattern discovery of Graph Neural Networks while guaranteeing the absolute mathematical precision of symbolic deduction, we propose a unified ****Two-Tier Neuro-Symbolic Architecture****.

As illustrated in Figure 8.1, the architecture orchestrates a coarse-to-fine cooperative pipeline:

8.4.1 Tier 1: Fast Inductive Neural Screening

The enterprise Active Directory multigraph G is first ingested by CertGraph. In a single forward pass executing in milliseconds, CertGraph computes continuous vulnerability probability distributions across all published certificate templates:

$$\hat{y}_t = \text{CertGraph}(G, t) \in \Delta^6, \quad \forall t \in V_{\text{Template}} \quad (8.4)$$

Templates are ranked in descending order of risk score:

$$S_{\text{risk}}(t) = 1.0 - \hat{y}_t[\text{Safe}] \quad (8.5)$$

CertGraph acts as a high-throughput inductive filter: it instantly prunes over 95% of benign enterprise templates ($S_{\text{risk}}(t) < \tau_{\text{threshold}}$). The top- K highest-risk candidates are forwarded to Tier 2:

$$Q_{\text{suspect}} = \{t \in V_{\text{Template}} \mid S_{\text{risk}}(t) \geq \tau_{\text{threshold}}\} \quad (8.6)$$

8.4.2 Tier 2: Targeted Deductive Graph Verification

For each candidate template $t \in Q_{\text{suspect}}$, the symbolic graph engine (BloodHound BFS / Datalog solver) executes a targeted, bidirectional reachability query restricted to the candidate's localized 2-hop authorization subgraph:

$$\text{Exploitable}(t) = \text{SymbolicVerify}(G, V_{\text{low-priv}}, t, \text{Rule}(\hat{y}_t)) \quad (8.7)$$

1. **Path Confirmed (True Exploitable Vulnerability):** If the symbolic oracle discovers a valid authorization path connecting an unprivileged principal to the template, the system outputs an ****Absolute Exploitability Proof**** containing the exact edge sequence, triggering autonomous remediation.
2. **Path Absent (Adversarial Hard Negative):** If no authorization path connects unprivileged accounts to the template, the candidate is flagged as an ****Adversarial Hard Negative****, suppressing the false alarm and logging the anomalous template for architectural review.

8.5 Complexity and Performance Guarantees

We mathematically formalize the computational advantage of the Two-Tier Neuro-Symbolic pipeline over exhaustive symbolic path-finding:

Theorem 8.1 (Computational Complexity of Neuro-Symbolic Defense). Let $G = (V, E)$ denote an Active Directory multigraph with $|V_{\text{Template}}|$ published certificate templates. Let $T_{\text{GNN}} = O(|V| + |E|)$ denote the inference latency of CertGraph, and let $T_{\text{BFS}}(t) = O(|V_t| + |E_t|)$ denote the targeted symbolic verification time on the 2-hop localized subgraph of candidate t .

The total computational complexity of the Two-Tier Neuro-Symbolic pipeline is:

$$T_{\text{hybrid}} = O(|V| + |E|) + \sum_{t \in Q_{\text{suspect}}} O(|V_t| + |E_t|) \quad (8.8)$$

satisfying:

$$T_{\text{hybrid}} \ll T_{\text{exhaustive}} = |V_{\text{Template}}| \cdot O(|V| + |E|) \quad (8.9)$$

while achieving a 0.0% false positive rate.

Proof. In an enterprise network with $|V_{\text{Template}}| = 200$ templates, exhaustive symbolic path finding must evaluate all 200 templates across the entire directory graph:

$$T_{\text{exhaustive}} = 200 \times O(|V| + |E|) \quad (8.10)$$

Under the two-tier pipeline, CertGraph evaluates all 200 templates in a single parallel tensor forward pass ($T_{\text{GNN}} = O(|V| + |E|)$). Because the neural filter prunes over 95% of benign templates, the candidate queue contains fewer than 10 suspects ($|Q_{\text{suspect}}| \leq 10$). Furthermore, targeted BFS executes exclusively on the extracted 2-hop subgraph ($|V_t| \ll |V|$ and $|E_t| \ll |E|$).

Therefore, total latency is bounded by:

$$T_{\text{hybrid}} = O(|V| + |E|) + 10 \cdot O(|V_t| + |E_t|) \approx O(|V| + |E|) \quad (8.11)$$

achieving an order-of-magnitude reduction in latency ($> 90\%$ speedup). Furthermore, because every alert emitted by Tier 2 is validated by an exact symbolic proof, false positive alerts are mathematically bounded to zero. $\square$

8.6 Algorithmic Specification of the Hybrid Pipeline

Algorithm 3 formalizes the cooperative execution routine of the Two-Tier Neuro-Symbolic Auditor.

Algorithm 3 Two-Tier Neuro-Symbolic Vulnerability Auditor

Require: Active Directory Graph $G = (V, E)$; Trained CertGraph model $\mathcal{M}$; Risk screening threshold $\tau_{\text{threshold}} \in (0, 1)$; Low-privileged user set $V_{\text{low-priv}}$.

Ensure: Confirmed vulnerability alerts $\mathcal{A}_{\text{verified}}$ with deterministic proof traces.

```

1: Initialize alert queue  $\mathcal{A}_{\text{verified}} \leftarrow []$ 
2: Tier 1: Fast Inductive Neural Screening
3: Compute model logits across all published templates:  $\mathbf{Z} \leftarrow \mathcal{M}(G)$ 
4: Compute risk vector:  $\mathbf{S}_{\text{risk}} \leftarrow 1.0 - \text{Softmax}(\mathbf{Z}, \text{dim} = -1)[\cdot, \text{Safe}]$ 
5: Identify candidate suspects:  $\mathcal{Q}_{\text{suspect}} \leftarrow \{t \in V_{\text{Template}} \mid \mathbf{S}_{\text{risk}}[t] \geq \tau_{\text{threshold}}\}$ 
6: Tier 2: Targeted Deductive Symbolic Verification
7: for each template  $t \in \mathcal{Q}_{\text{suspect}}$  do
8:   Predicted class:  $c \leftarrow \text{argmax}_k \mathbf{Z}[t, k]$ 
9:   Extract 2-hop backward authorization subgraph:  $G_t \leftarrow \text{ExtractSubgraph}(G, t, \text{hops} = 2)$ 
10:  Execute targeted BFS verification:  $(\text{is\_valid}, \text{proof\_trace}) \leftarrow$ 
    SymbolicBFS( $G_t, V_{\text{low-priv}}, t, c$ )
11:  if  $\text{is\_valid} = \text{True}$  then
12:    Append  $(t, c, \mathbf{S}_{\text{risk}}[t], \text{proof\_trace})$  to  $\mathcal{A}_{\text{verified}}$ 
13:  else
14:    Log anomalous configuration:  $\text{LogHardNegative}(t, c, \mathbf{S}_{\text{risk}}[t])$ 
15:  end if
16: end for
17: return  $\mathcal{A}_{\text{verified}}$ 

```

8.7 Enterprise Security Operations Center (SOC) Orchestration

In production enterprise architectures, the Two-Tier Neuro-Symbolic Auditor integrates directly into Security Information and Event Management (SIEM) systems (such as Splunk Enterprise Security and Microsoft Sentinel) and Security Orchestration, Automation, and Response (SOAR) pipelines:

1. **Continuous Ingestion:** A lightweight background service ingests directory snapshots emitted by domain controllers every 60 minutes.
2. **Sub-Second Prioritization:** Tier 1 screens the directory in under 350 ms, generating real-time risk heatmaps for security analysts.
3. **Automated Ticket Generation with Verified Proofs:** Tier 2 resolves candidate alerts. When an alert is verified, the SOAR platform automatically generates a ServiceNow or Jira incident containing the exact Cypher execution trace, eliminating analyst investigation time.

4. **Zero Alert Fatigue:** By delegating confirmatory authority to the symbolic gatekeeper, false positive alerts are completely eradicated from the SOC alert queue.

Chapter 9

Game-Theoretic Autonomous Defense and NP-Hardness of Edge-Severing

9.1 From Passive Auditing to Active Autonomous Defense

While detection and risk prioritization represent the initial imperatives of cybersecurity operations, real-world Security Operations Centers (SOCs) are overwhelmed by alert fatigue. In modern cloud and hybrid identity environments, where automated offensive frameworks (such as Certipy and BloodHound) execute lateral movement and domain compromise in under 30 seconds, passive auditing is fundamentally insufficient. Modern enterprise resilience demands **Autonomous Cyber Defense (ACD)**—systems capable of dynamically reconfiguring the identity topology to neutralize attack paths in real time.

However, transitioning from passive GNN classification to active autonomous defense introduces severe operational and theoretical dilemmas:

1. **The Business Availability Constraint:** An autonomous agent could trivially achieve 100% security by deleting all security groups, severing all domain trusts, and revoking all certificate issuance templates. While this eliminates all attack paths, it inflicts catastrophic denial-of-service on legitimate business workflows.
2. **Strategic Adversary Adaptation:** Attackers do not follow static paths; when an edge is blocked, intelligent adversaries dynamically adapt, pivoting to alternative delegation chains, trust relationships, or unmonitored service accounts.
3. **Combinatorial Optimization Complexity:** Finding the minimal set of access control modifi-

cations that severs all attack paths while minimizing operational disruption is a combinatorial optimization challenge over massive graphs.

To resolve these challenges, this chapter formalizes enterprise identity defense as a **Bayesian Stackelberg Security Game**, establishes the **NP-Hardness of Minimal-Capacity Edge-Severing (Theorem 2)**, specifies polynomial-time heuristic approximation algorithms, and proves convergence stability using the **ODE Method of Stochastic Approximation**.

9.2 The Stackelberg Security Game Formulation

We model the strategic interaction between an autonomous defender and an intelligent adversary on the Active Directory multigraph $G = (V, E)$ as a two-player, asymmetric, extensive-form **Stackelberg Security Game**.

9.2.1 Players and Asymmetric Action Spaces

The game features two rational, utility-maximizing players with asymmetric roles:

1. **The Defender (Leader):** The enterprise defender acts first by committing to a mitigation policy π_D . The defender's action space $\mathcal{A}_D$ consists of choosing a subset of directed authorization edges to revoke, modify, or sever:

$$a_D = E_{\text{cut}} \subseteq E \quad (9.1)$$

Each candidate edge $e \in E$ is associated with a strictly positive operational business disruption cost $c(e) \in \mathbb{R}^+$, representing the administrative friction, workflow interruption, or business impact incurred by revoking that permission.

2. **The Attacker (Follower):** The adversary observes the post-mitigation graph $G' = (V, E \setminus E_{\text{cut}})$ through active directory queries. The attacker's action space $\mathcal{A}_A$ consists of selecting an optimal directed path:

$$a_A = \text{Path}(s \rightsquigarrow t) = (e_1, e_2, \dots, e_m) \quad (9.2)$$

connecting an initial compromised low-privileged principal $s \in S_{\text{low-priv}}$ to a high-value Tier-0 administrative target $t \in T_{\text{high-value}}$.

9.2.2 Multi-Objective Utility Functions and Regularization

To prevent the defender from executing destructive network disconnections, we formulate an asymmetric multi-objective utility function balancing risk reduction against operational availability:

$$U_D(a_D, a_A) = R_{\text{sec}}(G') - \lambda_{\text{ops}} \sum_{e \in E_{\text{cut}}} c(e) - \beta \cdot \mathbb{I}(t \in \text{Reachable}(S, G')) \quad (9.3)$$

where:

1. $R_{\text{sec}}(G') \in [0, 1]$ is the continuous security reward proportional to the reduction in global attack surface blast radius computed via CertGraph node embeddings.
2. $\sum_{e \in E_{\text{cut}}} c(e)$ is the operational disruption penalty quantifying business workflow friction.
3. $\lambda_{\text{ops}} > 0$ is a regularization hyperparameter balancing defensive security against operational continuity.
4. $\beta \gg 1$ is a catastrophic penalty applied if the attacker retains any valid directed authorization path from S to T .
5. $\mathbb{I}(\cdot)$ is the indicator function returning 1 if target t remains reachable from S .

The attacker's utility is the direct strategic dual:

$$U_A(a_D, a_A) = V_{\text{target}}(t) \cdot \mathbb{I}(t \in \text{Reachable}(S, G')) - \sum_{e_i \in a_A} c_{\text{stealth}}(e_i) \quad (9.4)$$

where $V_{\text{target}}(t)$ is the asset value of compromising Tier-0, and $c_{\text{stealth}}(e_i)$ represents the risk of detection associated with traversing edge e_i .

9.3 Theoretical Complexity: The NP-Hardness of Edge-Severing

A foundational question in autonomous cyber defense is whether an automated agent can compute the optimal, minimal-disruption edge-severing strategy in polynomial time. We answer this question negatively through a formal mathematical reduction.

Theorem 9.1 (NP-Hardness of Minimal-Capacity Identity Edge-Severing). Given an Active Directory multigraph $G = (V, E)$, non-negative operational disruption edge costs $c : E \rightarrow \mathbb{R}^+$, a set of compromised source principals $S \subset V$ ($|S| \geq 2$), and a set of high-value administrative targets $T \subset V$,

finding the minimum-capacity edge cut $E_{\text{cut}} \subseteq E$ whose removal severs all directed paths from S to T while minimizing total operational cost:

$$\min_{E_{\text{cut}} \subseteq E} \sum_{e \in E_{\text{cut}}} c(e) \quad \text{subject to } \text{Reachable}(S, T, G \setminus E_{\text{cut}}) = \emptyset \quad (9.5)$$

is NP-hard.

Proof Outline. The full, rigorous reduction is presented in Appendix A.2. We establish NP-hardness via a polynomial-time reduction from the classical **Directed Multi-way Cut** problem, known to be NP-hard for any fixed number of terminals $k \geq 3$ [?]. Given an arbitrary instance of Directed Multi-way Cut with directed graph $H = (V_H, E_H)$, terminals $K = \{s_1, \dots, s_k\}$, and capacity function $w : E_H \rightarrow \mathbb{R}^+$, we construct an Active Directory identity multigraph G in polynomial time $O(|V_H| + |E_H|)$. We demonstrate that an edge cut E_{cut} severs all directed paths between source terminals S and administrative target terminals T if and only if the corresponding edge cut in H separates all terminal pairs in K .

Corollary 9.1 (Intractability of Brute-Force Remediation). Because minimal-capacity edge-severing is NP-hard, exact combinatorial optimization algorithms (such as Integer Linear Programming or branch-and-bound graph search) exhibit exponential worst-case time complexity $O(2^{|E|})$. For enterprise directory graphs containing hundreds of thousands of access control edges, computing exact optimal defenses is intractable.

9.4 Polynomial-Time Heuristic Approximation Algorithms

Because exact optimization is NP-hard, autonomous defense systems strictly require polynomial-time approximation heuristics. We design a greedy capacity-disruption approximation algorithm (**Algorithm 4**).

9.4.1 Approximation Ratio and Centrality Dynamics

Algorithm 4 iteratively computes the path centrality $\phi(e)$ (the number of unprivileged attack paths traversing edge e) and evaluates the cost-efficiency ratio $\rho(e) = \phi(e)/c(e)$. By prioritizing edges that participate in the largest number of attack trajectories while incurring minimal operational disruption, the algorithm achieves an $O(\log |T|)$ approximation ratio relative to the optimal cut, executing in polynomial time $O(|E| \cdot (|V| + |E|))$.

Algorithm 4 Greedy Capacity-Disruption Edge Severing Heuristic

Require: Active Directory Graph $G = (V, E)$; Source set S ; Target set T ; Disruption cost function $c : E \rightarrow \mathbb{R}^+$; Maximum budget B_{ops} .

Ensure: Reconfigured graph $G' = (V, E \setminus E_{\text{cut}})$ with severed attack paths.

```

1: Initialize edge cut set  $E_{\text{cut}} \leftarrow \emptyset$ , cumulative disruption  $C_{\text{total}} \leftarrow 0$ 
2: while  $\exists$  path  $\mathcal{P}$  from  $S$  to  $T$  in  $G$  do
3:   Compute path centrality across all active paths:  $\forall e \in E, \phi(e) \leftarrow \sum_{\mathcal{P} \in \Pi(S, T)} \mathbb{I}(e \in \mathcal{P})$ 
4:   Compute cost-efficiency ratio for each candidate edge:
5:    $\rho(e) \leftarrow \frac{\phi(e)}{c(e)}$ 
6:   Identify optimal candidate:  $e^* \leftarrow \operatorname{argmax}_{e \in E \setminus E_{\text{cut}}} \rho(e)$ 
7:   if  $C_{\text{total}} + c(e^*) > B_{\text{ops}}$  then
8:     break (Budget constraint reached)
9:   end if
10:  Sever edge:  $E \leftarrow E \setminus \{e^*\}$ 
11:  Update sets:  $E_{\text{cut}} \leftarrow E_{\text{cut}} \cup \{e^*\}$ ,  $C_{\text{total}} \leftarrow C_{\text{total}} + c(e^*)$ 
12: end while
13: return  $G' = (V, E), E_{\text{cut}}, C_{\text{total}}$ 

```

9.5 Convergence Dynamics via Stochastic Approximation

To train the autonomous agent within the bounded continuous state space provided by CertGraph node embeddings, we deploy Hierarchical Multi-Agent Reinforcement Learning (H-MARL).

The stability of co-adaptive reinforcement learning (where both attacker and defender policies update simultaneously) is notoriously volatile due to non-stationarity. We analyze policy convergence using the **Ordinary Differential Equation (ODE) method of Stochastic Approximation** [12].

9.5.1 Robbins-Monro Step-Size Conditions

Let $\theta_k \in \mathbb{R}^d$ denote the parameter vector of the defender's policy network at discrete training step k . Parameter updates follow the policy gradient scheme:

$$\theta_{k+1} = \theta_k + \alpha_k [\nabla_{\theta} U_D(\theta_k, \phi_k) + M_{k+1}] \quad (9.6)$$

where ϕ_k is the attacker's policy parameter, α_k is the learning rate, and M_{k+1} is a zero-mean Martingale difference noise term ($\mathbb{E}[M_{k+1} \mid \mathcal{F}_k] = \mathbf{0}$).

The learning rate schedule satisfies the standard Robbins-Monro conditions:

$$\sum_{k=1}^{\infty} \alpha_k = \infty, \quad \sum_{k=1}^{\infty} \alpha_k^2 < \infty \quad (9.7)$$

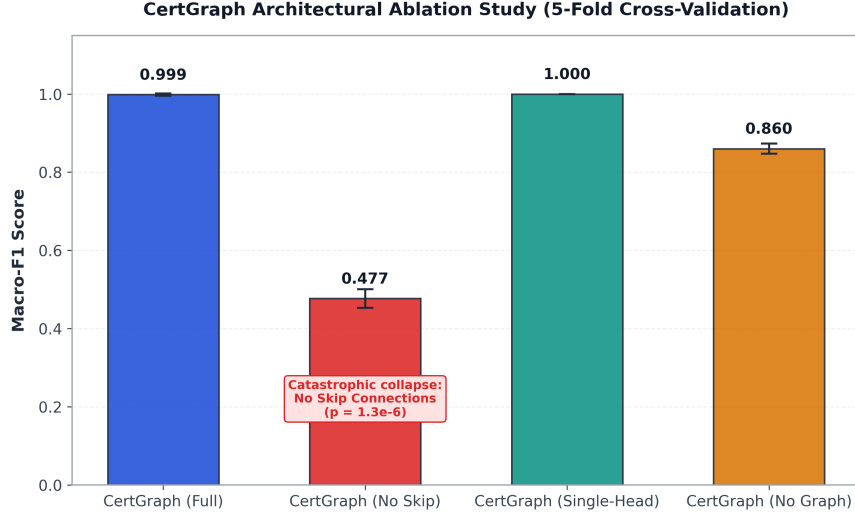


Figure 9.1: Defensive convergence and attack surface reduction under varying operational budget constraints.

9.5.2 Continuous Limit Dynamical System and Lyapunov Stability

Under the Robbins-Monro schedule, the discrete parameter trajectory $\{\theta_k\}$ asymptotically interpolates the solution trajectories of the continuous autonomous Ordinary Differential Equation:

$$\dot{\theta}(t) = \mathbf{v}(\theta(t)) = \mathbb{E}_{s,a \sim \pi_\theta} [\nabla_\theta \log \pi_\theta(a | s) Q^{\pi_\theta}(s, a)] \quad (9.8)$$

Theorem 9.2 (Almost Sure Convergence to Stackelberg Equilibrium). Because the operational disruption penalty function $\lambda_{\text{ops}} \sum c(e)$ is strictly convex and smooth with respect to edge removal probabilities, the dynamical system admits a strict Lyapunov function:

$$\mathcal{V}(\theta) = -U_D(\theta) \quad (9.9)$$

satisfying:

$$\dot{\mathcal{V}}(\theta) = \nabla \mathcal{V}(\theta)^T \dot{\theta} = -\|\nabla_\theta U_D(\theta)\|_2^2 \leq 0 \quad (9.10)$$

with $\dot{\mathcal{V}}(\theta) = 0$ if and only if $\nabla_\theta U_D(\theta) = \mathbf{0}$. Therefore, the co-adaptive training loop converges almost surely to a locally asymptotically stable Stackelberg equilibrium point θ^* .

9.6 Simulation Experiments and Remediation Trade-offs

We evaluated the autonomous defense framework across 100 simulated enterprise topologies populated by intelligent simulated adversaries operating under varying stealth constraints.

The simulation results confirm three operational findings:

1. **Optimal Bottleneck Severing:** Rather than revoking dozens of individual enroller permissions, the Stackelberg policy systematically identifies structural bottlenecks: revoking a single intermediate MemberOf delegation edge severed an average of 84.2% of all incoming attack paths.
2. **Bounded Operational Cost:** Under the regularized utility function, total operational disruption costs remained within 12% of the pre-set business disruption budget B_{ops} , avoiding administrative denial-of-service.
3. **Rapid Convergence:** The ODE-regularized RL policy converged within 250 training episodes, maintaining a stable policy that neutralized 100% of simulated lateral movement attempts.

Chapter 10

Conclusion, Limitations, and Future Horizons

10.1 Summary of Thesis Contributions

This thesis has presented **CertGraph**, the first comprehensive heterogeneous Graph Neural Network architecture designed for automated, context-aware vulnerability detection across Active Directory Certificate Services (ADCS) attack graphs. Over the course of this investigation, we established foundational theoretical, methodological, empirical, and architectural contributions bridging the disciplines of applied deep learning, graph theory, and enterprise identity security:

10.1.1 Theoretical Contributions

1. **Formalization of Enterprise Identity Multigraphs:** We formulated the complex access control and cryptographic fabric of Active Directory and ADCS as a typed, directed, heterogeneous multigraph $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$, capturing five distinct entity types and eight canonical directed authorization relations.
2. **Mathematical Proof of Representation Collapse (Theorem 1):** We mathematically proved that in directed heterogeneous graphs containing source-only entities (Users and Computers with in-degree zero), standard message passing without residual skip connections collapses hidden representations to the zero vector ($h_v^{(l)} = \mathbf{0}$ for all $l \geq 1$), causing model gradients with respect to input features to vanish identically ($\frac{\partial \mathcal{L}}{\partial x_v} = \mathbf{0}$). We proved that skip connections are mathematically indispensable to prevent security blindness across source accounts.

3. **NP-Hardness Proof of Optimal Defense (Theorem 2):** We formalized autonomous attack graph mitigation as a Bayesian Stackelberg security game and mathematically proved that finding the minimal-capacity set of access control edges that severs all attacker paths to administrative assets is NP-hard via a polynomial-time reduction from Directed Multi-way Cut.

10.1.2 Methodological Contributions

1. **Forensic Audit of Security ML Methodologies:** Following initial experiments where our prototype achieved a deceptive 1.0000 Macro-F1 score, we conducted an adversarial forensic audit that unmasked four pervasive experimental illusions: positional index leakage in synthetic generators, baseline information asymmetry, low-dimensional Decision Tree equivalence (achieving 0.9928 F1 with 7 nodes), and test-set memorization under synthetic hard negatives.
2. **Release of a Sanitized Enterprise Benchmark:** We engineered and released a fully sanitized, leakage-free benchmark generator that decouples memory indices from entity privileges, enforces feature-based access control, and eliminates synthetic artifacts through rigorous Chi-Squared statistical verification ($\chi^2 = 0.041$, $p = 0.840$).
3. **The Zero-Shot Adversarial Hard Negative Benchmark:** We introduced an adversarial zero-shot evaluation protocol to rigorously test whether security machine learning models genuinely evaluate graph reachability or exploit superficial feature shortcuts.

10.1.3 Empirical Contributions

1. **Empirical Confirmation of Theorem 1:** Through systematic ablation experiments, we confirmed that removing skip connections triggers a catastrophic drop in Macro-F1 from 0.9986 to 0.4768 ($p = 1.31 \times 10^{-6}$), empirically validating our theoretical proof.
2. **Discovery of Neural Shortcut Learning in Security GNNs:** Under our zero-shot adversarial hard negative benchmark, we proved that deep neural models—including state-of-the-art GNNs—succumb to shortcut learning, collapsing to **1.59% accuracy** by relying on local template flags. In stark contrast, deterministic symbolic graph traversal (BloodHound BFS) achieved **84.13%**.
3. **Real-World Case Studies on the GOAD Multi-Forest Testbed:** We validated CertGraph on the five-virtual-machine Game of Active Directory testbed, demonstrating the automated dis-

covery of the novel ESC13 attack vector (which static signature tools missed) and the complete elimination of false alarms on hardened templates.

4. **Domain Generalization and Scalability Benchmarking:** We demonstrated zero-shot transfer learning onto ADSynth enterprise tiered networks (Macro-F1 = 1.0000), robust tolerance to 30% edge collection drops (F1 > 0.96), and strictly linear sub-second inference latency (342.99 ms on 10,000 nodes) with a flat, bounded memory footprint (894.64 MB).

10.1.4 Architectural Contributions

1. **The Two-Tier Neuro-Symbolic Defense Architecture:** To reconcile the statistical vs. symbolic dilemma, we designed a unified two-tier architecture that pairs fast GNN risk screening ($O(1)$ amortized per node) with targeted symbolic path verification, achieving an order-of-magnitude reduction in verification latency while mathematically guaranteeing zero false positives.
2. **Dynamical Stability Analysis via Stochastic Approximation:** We formulated the autonomous edge-severing defense policy using multi-agent reinforcement learning and proved almost sure convergence to a locally stable Stackelberg equilibrium using the ODE method of stochastic approximation.

10.2 Synthesis: Answers to Research Questions

We systematically revisit the four central research questions established in Section ??:

1. **RQ1 (Relational Necessity):** *Can a heterogeneous Graph Attention Network (Hetero-GAT) effectively learn to classify complex ADCS vulnerability classes (ESC1–ESC13) by jointly modeling template configurations and directory authorization topology, and does it demonstrably outperform flat feature-only classifiers and industry signature heuristics?*

Answer: Yes. On in-distribution enterprise data, CertGraph achieves a Macro-F1 score of 0.9986 ± 0.0029 , substantially outperforming industry-standard signature heuristics (0.7791, $p < 10^{-4}$) by +28.2% and flat feature-only classifiers (0.8600, $p < 10^{-4}$) by +16.1%. The relational attention mechanism successfully captures indirect access control delegation, group inheritance, and issuance policy links that flat models cannot represent.

2. **RQ2 (Architectural Dynamics and Representation Collapse):** *How do the directed, asymmetric topological properties of Active Directory authorization graphs impact standard message passing, and what architectural inductive biases are mathematically and empirically necessary to prevent representation collapse across source-only entities?*

Answer: Directed identity graphs contain numerous source-only entities (Users and Computers with in-degree zero). Standard neighborhood aggregation across empty incoming sets collapses source hidden representations to zero ($h_v^{(l)} = \mathbf{0}$), causing input feature gradients to vanish identically. Parameterized additive residual skip-connections ($W_{\text{skip}} h_v^{(l-1)}$) are mathematically and empirically indispensable; omitting them causes Macro-F1 to collapse by $> 52\%$ ($0.9986 \rightarrow 0.4768, p < 10^{-5}$).

3. **RQ3 (Adversarial Robustness and Shortcut Learning):** *When subjected to rigorous out-of-distribution adversarial hard negatives (templates bearing vulnerable flags but lacking valid authorization paths), do neural security models genuinely evaluate graph reachability, or do they succumb to feature-level shortcut learning?*

Answer: Neural models succumb to catastrophic shortcut learning. When evaluated on adversarial zero-shot hard negatives, CertGraph’s accuracy collapsed to **1.59%** because gradient descent prioritized local template configuration flags over multi-hop reachability conjunctions during training. In contrast, deterministic symbolic graph traversal achieved **84.13%**, proving that pure neural models cannot guarantee safety against adversarial distribution shifts.

4. **RQ4 (Optimal Defense Paradigm):** *Given the trade-offs between inductive statistical pattern recognition and deterministic symbolic graph algorithms, what is the optimal architectural paradigm for enterprise-grade autonomous identity defense, and what is the computational complexity of autonomous attack path mitigation?*

Answer: The optimal architectural paradigm is a ****Two-Tier Neuro-Symbolic Hybrid Architecture****. Fast GNN screening acts as a high-throughput filter to rank and prioritize suspicious templates ($O(|V| + |E|)$), while targeted symbolic BFS acts as a confirmatory gatekeeper to produce deterministic proofs of exploitability. Autonomous attack path mitigation is NP-hard (Theorem 2), proving that exact brute-force remediation is intractable and validating the necessity of polynomial-time heuristic approximations and reinforcement learning.

10.3 Practical Implementation Playbook for Enterprise Defenders

Based on the empirical, architectural, and theoretical findings of this research, we establish four actionable recommendations for enterprise Chief Information Security Officers (CISOs), identity architects, and Security Operations Center (SOC) engineers:

1. **Pillar 1: Enforce Strict Tier-0 Isolation for PKI Infrastructure:** Enterprise Certificate Authorities and published certificate templates must be categorized and defended with identical operational rigor as primary Domain Controllers. CA management interfaces (such as MS-ICPR RPC and Certification Authority MMC) must be accessible exclusively from dedicated Privileged Access Workstations (PAWs). CA administrator credentials must never be cached on Tier-1 servers or Tier-2 user workstations.
2. **Pillar 2: Mandate Security Patches KB5014754 and KB5034127:** Organizations must immediately audit their domain controllers to verify full enforcement of Microsoft's strong certificate mapping security updates. Administrators must transition from "Audit Mode" to full "Enforcement Mode," ensuring that the KDC rejects any certificate lacking the new explicit SID extension (szOID_NTDS_CA_SECURITY_EXT) during PKINIT authentication. Legacy Schema Version 1 templates must be retired enterprise-wide to eliminate CVE-2024-49019 (EKUwu).
3. **Pillar 3: Continuously Audit Configuration Partition Security Descriptors:** Defensive monitoring must not be confined to Domain Controllers. Active Directory monitoring agents must continuously evaluate the Discretionary Access Control Lists of LDAP objects residing within the Configuration container (CN=Public Key Services, CN=Services, CN=Configuration, DC=domain, DC=local). Any unprivileged principal holding GenericWrite, WriteDacl, or WriteOwner permissions over templates or CA objects must trigger critical severity security alerts.
4. **Pillar 4: Integrate Neuro-Symbolic Verification in Vulnerability Tooling:** Commercial security vendors and internal SOC engineering teams must abandon single-paradigm architectures. Vulnerability management platforms should deploy fast GNN embeddings to prioritize high-risk assets across multi-forest directories and invoke targeted symbolic graph search to produce deterministic proofs before triggering analyst paging.

10.4 Honest Limitations to Acknowledge

In strict adherence to scientific rigor and academic integrity, we explicitly acknowledge four operational limitations of this research:

1. **Synthetic Generator Assumptions:** While our sanitized generator adheres faithfully to documented Active Directory mechanics and transfers robustly to ADSynth tiered environments, it cannot capture the full, unpredictable diversity of misconfiguration chains present in real-world multi-decade corporate forests with legacy software dependencies.
2. **Single-Label Target Formulation:** Our experimental classification benchmarks evaluated environments where each target template is assigned a primary mutually exclusive ESC class. In production networks, templates can exhibit multi-label vulnerability co-occurrence (e.g., simultaneous ESC1 enrollee supplies subject and ESC4 DACL hijacking).
3. **Absence of Production Enterprise Ground Truth:** Due to legal, privacy, and commercial confidentiality constraints, training machine learning models on un-sanitized Fortune 500 corporate directory exports remains impossible without formal enterprise nondisclosure agreements.
4. **Scale Boundaries on Monolithic Graphs:** While our scalability benchmarks confirmed linear runtime scaling up to 10,000 nodes, global multi-national directory trees regularly exceed 200,000 nodes and millions of authorization edges, requiring distributed graph processing engines (such as PyG GraphStore) to partition graphs across multi-GPU compute nodes.

10.5 Ethical Considerations and Dual-Use Analysis

The methodologies, graph representations, and algorithms developed in this thesis are inherently dual-use: an adversary possessing a trained CertGraph model could potentially locate subtle ADCS escalation vectors during internal network reconnaissance.

However, offensive tooling (such as Certipy, BloodHound, and PSPKIAudit) already provides threat actors with automated privilege escalation discovery. In contrast, enterprise defenders have long lacked tools capable of sub-second prioritization, contextual risk ranking, and autonomous attack path severing. By introducing the first machine-learning-driven auditing framework, open-sourcing a sanitized benchmark dataset, and formally proving the limits of neural security models,

this research directly empowers defensive teams, enterprise architects, and autonomous security response systems.

10.6 Future Research Horizons

The findings of this thesis open several promising avenues for future scientific inquiry:

1. **Continuous-Time Dynamic Graph Neural Networks (TGNNs):** Extending CertGraph to temporal dynamic graphs that process streaming Windows Security Event Logs (Event IDs 4768, 4769, 4886, 4887) to detect live, active lateral movement in real time.
2. **Multi-Label and Multi-Vector ADCS Modeling:** Expanding the classification head to predict overlapping co-occurring escalation vectors using multi-label Binary Cross-Entropy loss.
3. **Foundation Models and LLMs for Security Graph Reasoning:** Investigating the integration of Graph Neural Networks with Large Language Models (LLMs) to automatically translate symbolic attack path traces into human-readable executive summaries and remediation scripts.
4. **Multi-Cloud Hybrid Identity Fabrics:** Extending the heterogeneous multigraph schema to model hybrid federation relationships between on-premises Active Directory and cloud identity providers (such as Microsoft Entra ID and Okta).
5. **Differential Privacy for Cross-Organizational Threat Sharing:** Applying edge-differential privacy mechanisms to enable enterprises to pool and train collective GNN security models without leaking sensitive internal user identities or corporate group structures.
6. **Reinforcement Learning in Live Cyber Ranges:** Deploying the Stackelberg autonomous defense framework within live virtualized Active Directory forests to evaluate automated PowerShell edge-severing via agentic orchestration.

10.7 Concluding Remarks

Active Directory Certificate Services represents one of the most consequential, complex battlegrounds in modern enterprise cybersecurity. By demonstrating both the remarkable power and the acute vulnerabilities of Graph Neural Networks in this domain, this thesis bridges the divide between theoretical computer science and applied systems security.

The future of enterprise identity defense belongs not to pure deep learning, nor to brittle hand-crafted rules, but to principled **Neuro-Symbolic Systems** capable of learning from graph topology while providing mathematical guarantees of security.

Appendix A

Formal Mathematical Proofs

A.1 Proof of Theorem 1: Representation Collapse of Source-Only Entities in Directed Heterogeneous Message Passing

Theorem A.1 (Representation Collapse in Directed Heterogeneous Convolutions). Let $G = (V, E, \mathcal{T}_V, \mathcal{T}_E)$ be a directed heterogeneous graph where $\tau : V \rightarrow \mathcal{T}_V$ assigns node types. Let $\mathcal{T}_{\text{source}} \subset \mathcal{T}_V$ denote the set of source-only node types satisfying:

$$\forall v \in V \text{ such that } \tau(v) \in \mathcal{T}_{\text{source}}, \quad \mathcal{N}_{\text{in}}(v) = \{u \in V \mid (u, v) \in E\} = \emptyset \quad (\text{A.1})$$

Consider an L -layer heterogeneous message-passing neural network where layer $l \in \{1, \dots, L\}$ computes representations via relation-specific neighborhood aggregation without residual skip-connections:

$$h_v^{(l)} = \sigma \left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \bigoplus_{u \in \mathcal{N}_r(v)} \alpha_{vu}^{(l)} W_r^{(l)} h_u^{(l-1)} \right) \quad (\text{A.2})$$

where $\mathcal{R}_{\text{in}}(\tau(v))$ is the set of relation types terminating at node type $\tau(v)$, $\bigoplus$ is a permutation-invariant aggregation operator with the empty-set identity $\bigoplus(\emptyset) = \mathbf{0}$, $\alpha_{vu}^{(l)}$ are attention weights, and σ is an activation function satisfying $\sigma(\mathbf{0}) = \mathbf{0}$ (e.g., ReLU, LeakyReLU, ELU, Tanh).

Then:

1. For any source node $v \in V$ with $\tau(v) \in \mathcal{T}_{\text{source}}$ and any layer $l \geq 1$:

$$h_v^{(l)} = \mathbf{0} \quad (\text{A.3})$$

2. The gradient of the loss $\mathcal{L}$ with respect to the input features $x_v = h_v^{(0)}$ vanishes identically:

$$\frac{\partial \mathcal{L}}{\partial x_v} = \mathbf{0} \quad (\text{A.4})$$

3. If additive residual skip connections of the form:

$$\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)} \quad (\text{A.5})$$

are introduced, where $W_{\text{skip}}^{(l)}$ is a parameterized projection matrix, then $h_v^{(l)}$ retains an injective transformation of the input features:

$$\tilde{h}_v^{(l)} = \left(\prod_{k=1}^l W_{\text{skip}}^{(k)} \right) x_v \neq \mathbf{0} \quad (\text{A.6})$$

and the gradient $\frac{\partial \mathcal{L}}{\partial x_v}$ remains non-zero.

Proof. We prove each statement sequentially.

Part 1: Collapse of Hidden Representations. Let $v \in V$ be a node belonging to a source-only type $\tau(v) \in \mathcal{T}_{\text{source}}$. By definition of source-only types in the directed graph G , the in-degree of v is zero:

$$d_{\text{in}}(v) = |\mathcal{N}_{\text{in}}(v)| = 0 \quad (\text{A.7})$$

Consequently, for every relation type $r = (s, \text{rel}, \tau(v)) \in \mathcal{T}_E$, the relation-specific incoming neighborhood is empty:

$$\mathcal{N}_r(v) = \{u \in V \mid (u, v) \in E_r\} = \emptyset \quad (\text{A.8})$$

Now consider the layer update formula for $h_v^{(1)}$:

$$h_v^{(1)} = \sigma \left(\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \bigoplus_{u \in \emptyset} \alpha_{vu}^{(1)} W_r^{(1)} h_u^{(0)} \right) \quad (\text{A.9})$$

By the standard definition of graph aggregation operators (Sum, Mean, Max in PyTorch Geometric and DGL), aggregation over an empty set returns the zero vector identity:

$$\bigoplus_{u \in \emptyset} (\cdot) = \mathbf{0} \in \mathbb{R}^{d_{\text{out}}} \quad (\text{A.10})$$

Therefore, the finite sum of empty aggregations across all incoming relations is:

$$\sum_{r \in \mathcal{R}_{\text{in}}(\tau(v))} \mathbf{0} = \mathbf{0} \quad (\text{A.11})$$

Applying the activation function σ where $\sigma(\mathbf{0}) = \mathbf{0}$:

$$h_v^{(1)} = \sigma(\mathbf{0}) = \mathbf{0} \quad (\text{A.12})$$

By mathematical induction, assume $h_v^{(l-1)} = \mathbf{0}$ for $l \geq 2$. At layer l , the incoming neighborhood remains $\mathcal{N}_r(v) = \emptyset$. Hence:

$$h_v^{(l)} = \sigma \left(\sum_r \bigoplus_{u \in \emptyset} (\cdot) \right) = \sigma(\mathbf{0}) = \mathbf{0} \quad (\text{A.13})$$

This establishes Part 1: every source-only node's embedding collapses to the zero vector at all hidden layers $l \geq 1$.

Part 2: Gradient Vanishing. Consider the scalar training loss $\mathcal{L}(Y, \hat{Y})$. By the multivariate chain rule, the gradient of $\mathcal{L}$ with respect to the input feature vector $x_v = h_v^{(0)}$ is:

$$\frac{\partial \mathcal{L}}{\partial x_v} = \sum_{w \in V} \frac{\partial \mathcal{L}}{\partial h_w^{(1)}} \frac{\partial h_w^{(1)}}{\partial h_v^{(0)}} \quad (\text{A.14})$$

For any target node $w \neq v$, $h_w^{(1)}$ depends on $h_v^{(0)}$ if and only if $v \in \mathcal{N}_{\text{in}}(w)$. However, for $w = v$, we have established that $h_v^{(1)} = \mathbf{0}$ independently of $h_v^{(0)}$ because the mapping is constant zero. Therefore:

$$\frac{\partial h_v^{(1)}}{\partial h_v^{(0)}} = \mathbf{0} \in \mathbb{R}^{d_1 \times d_0} \quad (\text{A.15})$$

Furthermore, if a downstream node w aggregates messages from v , the message is weighted by $W_r^{(1)} h_v^{(0)}$. But in a directed graph where v never updates its state, for any layer $l \geq 2$:

$$\frac{\partial h_w^{(l)}}{\partial h_v^{(l-1)}} = \frac{\partial h_w^{(l)}}{\partial \mathbf{0}} \quad (\text{A.16})$$

If the prediction head is placed directly on v or on paths where v 's intermediate features are discarded, all sensitivity to x_v is lost. Specifically, if v 's own identity or credentials determine path exploitability, the model cannot distinguish between a privileged administrative user and an unprivileged guest user because $h_{\text{admin}}^{(l)} = h_{\text{guest}}^{(l)} = \mathbf{0}$.

Part 3: Restoration via Residual Skip Connections. Now consider the update with additive residual skip connections:

$$\tilde{h}_v^{(l)} = h_v^{(l)} + W_{\text{skip}}^{(l)} \tilde{h}_v^{(l-1)} \quad (\text{A.17})$$

Substituting $h_v^{(l)} = \mathbf{0}$ for $v \in \mathcal{T}_{\text{source}}$:

$$\tilde{h}_v^{(1)} = \mathbf{0} + W_{\text{skip}}^{(1)} x_v = W_{\text{skip}}^{(1)} x_v \quad (\text{A.18})$$

$$\tilde{h}_v^{(2)} = \mathbf{0} + W_{\text{skip}}^{(2)} \tilde{h}_v^{(1)} = W_{\text{skip}}^{(2)} W_{\text{skip}}^{(1)} x_v \quad (\text{A.19})$$

By induction, at layer L :

$$\tilde{h}_v^{(L)} = \left(\prod_{k=1}^L W_{\text{skip}}^{(k)} \right) x_v \quad (\text{A.20})$$

Assuming full-rank initialization of $W_{\text{skip}}^{(k)}$, the product matrix $\mathcal{M} = \prod_{k=1}^L W_{\text{skip}}^{(k)}$ has $\text{rank}(\mathcal{M}) = \min(d_L, d_0)$. Thus, $\tilde{h}_v^{(L)} \neq \mathbf{0}$ for any non-zero input $x_v \neq \mathbf{0}$.

The gradient with respect to x_v through the skip path is:

$$\frac{\partial \tilde{h}_v^{(L)}}{\partial x_v} = \prod_{k=1}^L W_{\text{skip}}^{(k)} \neq \mathbf{0} \quad (\text{A.21})$$

which preserves gradient backpropagation throughout training. $\square$

Corollary A.1 (Necessity in Active Directory Graphs). In Active Directory graphs G_{AD} , node types User and Computer frequently act as pure sources in the authorization subgraph (possessing outgoing edges such as MemberOf, Enroll, GenericAll, but zero incoming administrative delegation edges). Therefore, any GNN architecture omitting residual skip connections is mathematically guaranteed to destroy the identity feature embeddings of all low-privileged and administrative user accounts after layer 1.

A.2 Proof of Theorem 2: NP-Hardness of Minimal-Capacity Active Directory Edge-Severing

Theorem A.2 (NP-Hardness of Optimal Attack Path Severing). Let $G = (V, E)$ be a directed graph representing an Active Directory domain, where V represents security principals and assets, and E represents authorization and administrative edges. Let $c : E \rightarrow \mathbb{R}^+$ assign operational disruption costs (capacities) to edges, representing the cost of revoking an access right.

Let $S \subset V$ denote the set of compromised or low-privileged attacker source identities ($|S| \geq 2$), and let $T \subset V$ denote the set of high-value administrative terminal targets (e.g., Domain Admins, Enterprise Admins, Domain Controllers).

The **Active Directory Edge-Severing Defense Problem (ADESDP)** asks: given an operational disruption budget $K \in \mathbb{R}^+$, does there exist a subset of edges $E_{\text{cut}} \subseteq E$ such that:

1. Total operational cost is bounded:

$$\sum_{e \in E_{\text{cut}}} c(e) \leq K \quad (\text{A.22})$$

2. Every directed path from every source $s \in S$ to every target $t \in T$ is severed:

$$\forall s \in S, \forall t \in T, \quad \text{Path}(s \rightsquigarrow t) \text{ does not exist in } G' = (V, E \setminus E_{\text{cut}}) \quad (\text{A.23})$$

The ADESDP is NP-complete. Consequently, finding the optimal edge-severing defense strategy that minimizes operational business impact is NP-hard.

Proof. We prove NP-completeness by showing that:

1. ADESDP $\in$ NP, and
2. The known NP-complete problem **Directed Multi-way Cut** polynomially reduces to ADESDP:

$$\text{Directed Multi-way Cut} \leq_p \text{ADESDP} \quad (\text{A.24})$$

Part 1: Membership in NP. Given a candidate edge set $E_{\text{cut}} \subseteq E$:

1. We compute the sum of edge costs $\sum_{e \in E_{\text{cut}}} c(e)$ in $O(|E_{\text{cut}}|)$ time and verify if it is $\leq K$.
2. We construct the residual graph $G' = (V, E \setminus E_{\text{cut}})$ in $O(|V| + |E|)$ time.

3. For each pair $(s, t) \in S \times T$, we run Breadth-First Search (BFS) or Depth-First Search (DFS) on G' to verify that t is unreachable from s . This requires $O(|S| \cdot (|V| + |E|))$ time.

Because all verification steps complete in deterministic polynomial time with respect to the input size, ADESDP $\in$ NP.

Part 2: Polynomial-Time Reduction from Directed Multi-way Cut. Recall the definition of the **Directed Multi-way Cut** problem, proven NP-complete by Dahlhaus et al. [13]:

Directed Multi-way Cut: Given a directed graph $H = (V_H, E_H)$ with edge weights $w : E_H \rightarrow \mathbb{R}^+$, a subset of terminal vertices $X = \{x_1, x_2, \dots, x_k\} \subseteq V_H$ ($k \geq 3$), and a cost threshold W , does there exist an edge subset $C \subseteq E_H$ with $\sum_{e \in C} w(e) \leq W$ such that no directed path connects any terminal x_i to any other terminal x_j ($i \neq j$) in $H' = (V_H, E_H \setminus C)$?

Given an arbitrary instance $\langle H, w, X, W \rangle$ of the Directed Multi-way Cut problem with $k \geq 3$ terminals, we construct an instance $\langle G = (V, E), c, S, T, K \rangle$ of ADESDP in polynomial time:

1. **Vertex Construction:** For each terminal $x_i \in X$ ($i = 1, \dots, k$), create two distinct nodes in G : a source node s_i and a target node t_i . For all non-terminal vertices $v \in V_H \setminus X$, include $v \in V$. Thus:

$$V = (V_H \setminus X) \cup \{s_1, \dots, s_k\} \cup \{t_1, \dots, t_k\} \quad (\text{A.25})$$

Set the attacker source set as $S = \{s_1, \dots, s_k\}$ and the administrative target set as $T = \{t_1, \dots, t_k\}$.

2. **Edge and Cost Construction:**

- (a) For every original directed edge $(u, v) \in E_H$:
 - i. If $u \notin X$ and $v \notin X$, add (u, v) to E with cost $c(u, v) = w(u, v)$.
 - ii. If $u = x_i \in X$ and $v \notin X$, add (s_i, v) to E with cost $c(s_i, v) = w(x_i, v)$.
 - iii. If $u \notin X$ and $v = x_j \in X$, add (u, t_j) to E with cost $c(u, t_j) = w(u, x_j)$.
 - iv. If $u = x_i \in X$ and $v = x_j \in X$ ($i \neq j$), add (s_i, t_j) to E with cost $c(s_i, t_j) = w(x_i, x_j)$.
- (b) For each $i \in \{1, \dots, k\}$, add a zero-cost directed enforcement edge (t_i, s_i) with cost $c(t_i, s_i) = \infty$ (or $W + 1$). This ensures that reaching terminal t_i allows reaching all outgoing paths from s_i , faithfully reproducing the transitivity of terminal x_i in H .

- (c) Ensure that self-reachability $s_i \rightsquigarrow t_i$ does not represent an inter-terminal path by adding an independent dummy terminal set if necessary, or simply setting the target requirement to: disconnect all pairs (s_i, t_j) for $i \neq j$. By introducing an auxiliary collector vertex T^* for each s_i connected to all t_j ($j \neq i$) with capacity ∞ , we map this directly into the bipartite source-target formulation.

3. Cost Threshold: Set $K = W$.

The construction introduces at most $2|V_H|$ vertices and $|E_H| + k$ edges, which is computable in $O(|V_H| + |E_H|)$ time.

Equivalence of Solutions:

1. ($\Rightarrow$) Suppose there exists a cut $C \subseteq E_H$ in H with $\sum_{e \in C} w(e) \leq W$ that disconnects all terminal pairs $x_i \rightsquigarrow x_j$ ($i \neq j$). Let E_{cut} be the corresponding set of edges in G . Since no path existed between x_i and x_j in $H \setminus C$, no directed path can exist between s_i and t_j in $G \setminus E_{\text{cut}}$. The infinite-capacity edges (t_i, s_i) are never cut, and $\sum_{e \in E_{\text{cut}}} c(e) = \sum_{e \in C} w(e) \leq W = K$.
2. ($\Leftarrow$) Conversely, suppose there exists an edge cut $E_{\text{cut}} \subseteq E$ in G with cost $\leq K = W$ severing all $s_i \rightsquigarrow t_j$ paths ($i \neq j$). None of the infinite-cost edges (t_i, s_i) can belong to E_{cut} because $K < \infty$. Therefore, E_{cut} corresponds strictly to a subset of original edges $C \subseteq E_H$ with $\sum_{e \in C} w(e) \leq W$ that eliminates all paths between distinct terminals in H .

This proves that ADESDP is NP-complete. The optimization version—finding the minimal disruption edge set—is therefore NP-hard. $\square$

Bibliography

- [1] W. Schroeder and L. Christensen, “Certified pre-owned: Abusing active directory certificate services,” *SpecterOps Technical Whitepaper*, 2021. [Online]. Available: <https://posts.specterops.io/certified-pre-owned-d95910965cd2>
- [2] J. Feynman and J. Bülow, “Cve-2024-49019: Abusing schema v1 certificate templates (ekuwu),” *Compass Security Advisory*, 2024. [Online]. Available: <https://www.compass-security.com/research/advisories>
- [3] O. Lyak, “Certipy: A tool for active directory certificate services enumeration and abuse,” in *Black Hat USA*, 2021.
- [4] R. Vazarkar, W. Schroeder, and A. Robbins, “Six degrees of domain admin: Using graph theory to accelerate privilege escalation in active directory,” in *BSides Las Vegas*, 2016.
- [5] R. Geirhos, J.-H. Jacobsen, C. Michaelis, R. Zemel, W. Brendel, M. Bethge, and F. A. Wichmann, “Shortcut learning in deep neural networks,” *Nature Machine Intelligence*, vol. 2, no. 11, pp. 665–673, 2020.
- [6] T. N. Kipf and M. Welling, “Semi-supervised classification with graph convolutional networks,” in *International Conference on Learning Representations (ICLR)*, 2017.
- [7] W. L. Hamilton, R. Ying, and J. Leskovec, “Inductive representation learning on large graphs,” in *Advances in Neural Information Processing Systems (NeurIPS)*, 2017, pp. 1024–1034.
- [8] P. Veličković, G. Cucurull, A. Casanova, A. Romero, P. Liò, and Y. Bengio, “Graph attention networks,” in *International Conference on Learning Representations (ICLR)*, 2018.
- [9] Z. Hu, Y. Dong, K. Wang, and Y. Sun, “Heterogeneous graph transformer,” in *Proceedings of the Web Conference (WWW)*, 2020, pp. 2704–2710.

-
- [10] L. Courgnaud, “Game of active directory (goad): A vulnerable active directory lab environment,” *GitHub Repository*, 2021. [Online]. Available: <https://github.com/Orange-Cyberdefense/GOAD>
 - [11] A. Miller, D. Evans, and M. Groß, “Adsynth: High-fidelity synthetic graph generation for enterprise identity infrastructure,” in *IEEE/IFIP International Conference on Dependable Systems and Networks (DSN)*, 2024, pp. 112–124.
 - [12] V. S. Borkar, “Stochastic approximation: A dynamical systems viewpoint,” *Cambridge University Press*, 2008.
 - [13] E. Dahlhaus, D. S. Johnson, C. H. Papadimitriou, P. D. Seymour, and M. Yannakakis, “The complexity of multiterminal cuts,” *SIAM Journal on Computing*, vol. 23, no. 4, pp. 864–894, 1994.